



Empower users to identify phishing websites

Julien Taes

Master thesis submitted under the supervision of

Jérôme Dossogne

to be awarded the degree of

Master in cybersecurity with focus Cryptanalysis and Forensics

Academic year 2024 - 2025

I hereby confirm that this master thesis was written independently by myself without the use of any sources beyond those cited. All passages and ideas derived from other sources are cited appropriately.

1 June 2025

Abstract

What defines us as humans is our ability to develop sophisticated tools and form complex social structures. In this regard, the Internet is one of the biggest creations of our modern society. It connects the world together in an open and collaborative network of computers.

However, this new field opened a wide range of new concerns. One of the most important is trust. Because as secure as the technology can be, it will never protect us from being human. Indeed, one of the most popular types of attack online is phishing. It is particularly effective because no one is immune to deception.

In this paper, we will address this issue by focusing on how to combat phishing attacks when they make use of domain names and websites.

Our approach is to focus on the notion of trustworthiness that extends the concept of security. A website may be entirely protected in terms of confidentiality and integrity, but if the owner is malicious, it is not trustworthy.

In practice, we have reviewed the technical countermeasures from the scientific literature, but our analysis indicated that most of the approach only focuses on reactive methods by detecting phishing websites. Therefore, we also explored in depth the prevention measures used by the Internet ecosystem. However, none of the existing solutions were able to properly assess and prove the trustworthiness of any websites. Therefore, we have made propositions to empower users with both a reactive and a proactive approach.

Technically, we have designed a user-centric tool that helps users make educated decisions about whether a website is trustworthy or not. Furthermore, we also have introduced a new protocol that helps websites become more trustworthy by providing verified information about themselves. This allows the owner to be held accountable if something unexpected happens.

In conclusion, we believe that users should be the central piece when it comes to trust and that security through transparency should be the way forward to improve trust on the Internet.

Keywords: phishing websites, online trust, user-centric, transparency

Acknowledgements

People

I would like to express my deepest appreciation to all the people who help me during the production of this master dissertation. In particular:

- Jérôme Dossogne, my academic promotor, who guided me throughout the writing of this scientific work.
- Frédéric Taes, my father, who gave me the opportunities to attend events on the topics of interest of this research.
- Sébastien Ducos from GoDaddy Registry¹ and involved in ICANN Registries Stakeholder Group² for his insight on the topics related to WHOIS, GDPR and ICANN.
- Polina Malaja from the Concil of European National Top-Level Domain Registries (CENTR)³ for her insights on the topics of ccTLDs and NIS 2.
- Internet Society Belgium⁴ for supporting the implementation of the ideas developed in this paper.

Presentation

I would like to extend my sincere thanks to the organizer of the events where I have presented my research. These presentations provided me valuable feedback from various audiences. More specifically:

- The General Annual Assembly 2024 of Internet Society Belgium⁴ organized at the Brussels School of Governance (VUB)⁵.
- The CENTR Jamboree in Lyon (France) organized by the Concil of European National Top-Level Domain Registries (CENTR)³.

Workshop

I would like to mention that I had the opportunity to travel to Istanbul (Türkiye) to attend the ICANN 81 Annual General Meeting⁶. A 6 days workshop that given me in-depth knowledge of the protective measures employed by the Internet ecosystem to combat phishing.

¹<https://registry.godaddy/>

²<https://www.rysg.info/>

³<https://www.centr.org/>

⁴<https://internetociety.be/>

⁵<https://www.brussels-school.be/>

⁶<https://meetings.icann.org/en/meetings/icann81/>

Table of Contents

Abstract	I
Acknowledgements	II
Table of Contents	III
List of Figures	IX
List of Abbreviations	X
1 Introduction	1
1.1 Context	1
1.2 Attack surface	2
1.3 Research question	2
1.4 Document overview	3
2 Problem	5
2.1 Report	5
2.1.1 Anti-Phishing Working Group	5
2.1.2 Interisle	6
2.1.2.1 Phishing Landscape 2023	6
2.1.2.2 Phishing Landscape 2024	7
2.1.3 European Commission	7
2.2 Illustration	8
2.2.1 Master data fraud	9
2.2.2 Fake webshop	10
2.3 Definition	11
2.4 Research focus	11
3 Literature review	12
3.1 Definition	12
3.1.1 Trust	12
3.1.2 Social engineering	13
3.1.3 Phishing	13
3.2 Life cycle	16
3.2.1 Target	16
3.2.2 Vector	17
3.2.3 Exploit	18
3.2.4 Weapon	21
3.2.5 Objective	22
3.3 Countermeasure	23
3.3.1 Similarity	23
3.3.1.1 Textual	23
3.3.1.2 Visual	24

3.3.2 Machine Learning	25
3.3.2.1 Feature	25
3.3.2.1.1 URL	26
3.3.2.1.2 Source code	26
3.3.2.1.3 Communication	27
3.3.2.1.4 External service	28
3.3.2.2 Feature selection	28
3.3.2.3 Model	28
3.3.2.3.1 Traditional	29
3.3.2.3.2 Online learning	29
3.3.2.3.3 Deep learning	29
3.3.3 List	30
3.3.3.1 Blacklist	30
3.3.3.2 Whitelist	31
3.4 Evasion	32
3.4.1 Cloaking	32
3.4.1.1 Server side	32
3.4.1.2 Client side	33
3.4.2 Content obfuscation	33
3.4.3 URL manipulation	33
3.4.4 Living off trusted sites	34
3.4.5 Compromise trusted sites	34
3.5 Research gap	34
3.5.1 Detection	35
3.5.2 Protection	36
4 State of the ecosystem	37
4.1 Prevention measure	37
4.1.1 Top-level domain	37
4.1.1.1 gTLD	38
4.1.1.2 ccTLD	38
4.1.2 Digital certificate	41
4.1.2.1 Certificate authority	41
4.1.2.2 eIDAS regulation	42
4.2 Usability	43
4.2.1 WHOIS	44
4.2.1.1 GDPR	44
4.2.1.1.1 Issues of the temporary specification	44
4.2.1.1.2 Recommendation	45
4.2.1.1.3 Implementation of the recommendations	46
4.2.1.2 NIS 2 directive	46
4.2.1.2.1 Obligation	47
4.2.1.2.2 Identity verification	48

4.2.1.2.3	Legal vs. natural person	48
4.2.1.2.4	Databases	49
4.2.2	Browser indicator	49
4.2.2.1	Connection security	49
4.2.2.2	Identity	50
4.2.3	QWAC	50
4.2.3.1	TLS binding	50
4.2.3.2	Validation	51
4.2.3.3	Visual differentiation	51
4.3	Technical gap	51
4.3.1	Identity verification	52
4.3.2	Transparency	52
5	Requirement	54
5.1	Assessment	54
5.1.1	Base principle	54
5.1.1.1	Trust depends on identity	54
5.1.1.2	Trust is a function of the perception of risk	55
5.1.1.3	Trust is a matter of degree	55
5.1.1.4	Culture affects trust	55
5.1.1.5	Trust deepens over time	55
5.1.1.6	Trust is based on information	56
5.1.1.7	First party information is important in developing trust	56
5.1.1.8	Second party opinions are important in developing trust	56
5.1.1.9	Third-party ratings are important in developing trust	56
5.1.1.10	Formal controls are important in developing trust	56
5.1.1.11	Social controls are important in developing trust	57
5.1.2	Additional principle	57
5.1.2.1	Security	57
5.1.3	Applicable solution	57
5.1.3.1	Detection	57
5.1.3.2	Protection	58
5.1.3.3	Coverage	59
5.2	Proof	59
5.2.1	WHOIS	59
5.2.2	Digital certificate	60
6	Proposition	61
6.1	Tool	61
6.1.1	Human firewall	61
6.1.1.1	Situation awareness	61
6.1.1.1.1	Definition	62
6.1.1.1.2	Working memory	63
6.1.1.1.3	Attention	63

6.1.1.2	Implementation	64
6.1.2	Trust principle	65
6.1.2.1	Trust depends on identity	65
6.1.2.1.1	Absolute domain name	65
6.1.2.1.2	Effective domain name	65
6.1.2.2	Trust is a function of the perception of risk	66
6.1.2.3	Trust is a matter of degree	66
6.1.2.4	Culture affects trust	66
6.1.2.5	Trust deepens over time	67
6.1.2.5.1	Interaction	67
6.1.2.5.2	Lifetime	67
6.1.2.6	Trust is based on information	68
6.1.2.6.1	Website	68
6.1.2.6.2	WHOIS	68
6.1.2.6.3	Digital certificate	69
6.1.2.7	First party information is important in developing trust	69
6.1.2.8	Second party opinions are important in developing trust	70
6.1.2.9	Third-party ratings are important in developing trust	71
6.1.2.10	Formal controls are important in developing trust	72
6.1.2.10.1	Country	72
6.1.2.10.1.1	Background	72
6.1.2.10.1.2	Owner	73
6.1.2.10.1.3	Host	74
6.1.2.10.2	WHOIS	74
6.1.2.10.3	Digital certificate	75
6.1.2.10.3.1	Validation	75
6.1.2.10.3.1.1	IV certificate	75
6.1.2.10.3.1.2	OV certificate	75
6.1.2.10.3.1.3	EV certificate	76
6.1.2.10.3.2	Revocation	76
6.1.2.11	Social controls are important in developing trust	77
6.1.2.12	Security	78
6.2	Protocol	79
6.2.1	Approach	79
6.2.1.1	Target	79
6.2.1.2	Verification	80
6.2.1.2.1	Business registry	80
6.2.1.2.1.1	Process	81
6.2.1.2.1.2	Availability	81
6.2.1.2.2	Public profile	81
6.2.1.2.2.1	Process	82
6.2.1.2.2.2	Availability	82
6.2.1.3	Transparency	83

6.2.1.3.1	Business registry	83
6.2.1.3.2	Public profile	84
6.2.2	Implementation	84
6.2.2.1	Verification	84
6.2.2.2	Transparency	84
6.2.2.3	Authentication	85
6.2.3	Multiple domains	85
6.2.3.1	Verification	85
6.2.3.2	Transparency	85
6.2.3.3	Authentication	86
7	Evaluation	87
7.1	Tool	87
7.1.1	Advantage	87
7.1.1.1	Subjectivity	87
7.1.1.2	Scope	88
7.1.1.2.1	Fabricated third party	88
7.1.1.2.2	Evasion	88
7.1.2	Disadvantage	88
7.1.2.1	Performance	89
7.1.2.2	Universality	89
7.1.2.3	Evasion	89
7.1.3	Limitation	90
7.1.3.1	Usability	90
7.1.3.2	Privacy	90
7.1.3.3	Anonymity	90
7.1.4	Future work	90
7.1.4.1	Situation awareness	91
7.1.4.2	Platform	91
7.2	Protocol	91
7.2.1	Comparison with existing solutions	91
7.2.1.1	Verification	92
7.2.1.2	Transparency	92
7.2.2	Limitation	93
7.2.2.1	Usage	93
7.2.2.2	Maintenance	93
7.2.3	Deployment	93
7.2.3.1	Source	94
7.2.3.2	Website	94
7.2.3.3	User	94
8	Conclusion	95
8.1	Contribution	95
8.1.1	Literature review	95

8.1.2 State of the ecosystem	95
8.1.3 Requirement	96
8.1.4 Proposition	96
8.2 Approach	96
8.2.1 Phishing	96
8.2.2 Combat	97
8.2.2.1 Reactive	97
8.2.2.2 Proactive	97
8.3 Recommendation	98
Bibliography	99
Appendices	107
A Document statistic	107
A.1 Text	107
A.2 Reference	108

List of Figures

Figure 1	Contact data collected by EU ccTLD registries from [1].	39
Figure 2	Contact data verified by EU ccTLD registries from [1].	40
Figure 3	Timing of contact data verification by EU ccTLD registries from [1].	40
Figure 4	Methods used to verify contact data by EU ccTLD registries from [1].	41
Figure 5	Endsley's model of situation awareness adapted from [2].	62
Figure 6	Share of users seeking out brands on social media by country from [3].	83

List of Abbreviations

Domain name

TLD	Top-Level Domain
gTLD	generic Top-Level Domain
ccTLD	country code Top-Level Domain
DNS	Domain Name System
DNSSEC	Domain Name System Security Extensions
ICANN	Internet Corporation for Assigned Names and Numbers ⁷

Email

SPF	Sender Policy Framework
DMARC	Domain-based Message Authentication, Reporting and Conformance
DKIM	DomainKeys Identified Mail

European Union

EU	European Union
GDPR	General Data Protection Regulation [4]
NIS 2	Network and Information Systems version 2 [5]
eIDAS	electronic IDentification, Authentication and trust Services [6], [7]

Web

URL	Uniform Resource Locator
HTTP	HyperText Transfer Protocol
TLS	Transport Layer Security
IP	Internet Protocol address
API	Application Programming Interface

Other

WHOIS	public directory of registration information (not an acronym)
-------	---

⁷<https://www.icann.org/>

1 Introduction

This chapter will start by presenting the evolution of the Internet (Section 1.1) and how the attack surface has evolved to allow the proliferation of phishing attacks (Section 1.2). This will help us formulate the main research question (Section 1.3) and elaborate on the steps we took in this document to answer this question (Section 1.4).

1.1 Context

The Internet has changed our lives and has become the cornerstone of our digital civilization. It has changed the way we access knowledge, communicate, buy and work.

The paper [8] shares the brief history and origin of the Internet, viewed by people directly involved in its development and evolution. In the paper, these people attribute the rapid expansion of the Internet mostly to its capability to promote information sharing. They highlight that the first role of the network was to share the information about its design and operation, and that today's Internet has evolved as a widespread information infrastructure. It is now the biggest source of information available globally. But because it is fundamentally open, bad actors can also contribute to the information shared and spread misinformation and disinformation. One of the greatest challenges of tomorrow's internet is building trust in this open environment [9].

At the start of 2025, reports suggest that social media have around 5 billion of user identities registered [3, Image 342]. Furthermore, an identifier like a username or an email address is enough to find and contact the corresponding online identity [10]. Given these affirmations, it is safe to assume that the vast majority of individuals using the internet are potentially reachable by malicious actors through various communication channels like email or social media platforms.

The Internet is not limited to exchanging knowledge. It can also be used to exchange goods and services. As businesses recognized this trend, they began developing e-commerce platforms to fulfill the consumers' increasing demand for purchasing items entirely online and having them delivered directly to their doorsteps. Today, online shopping and banking have become integral components of modern consumption patterns. In Europe during the year 2024, around 60% of internet users engaged in purchasing or ordering goods and services online [11]. This significant trend underscores the growing importance of e-commerce where money, goods, and services are increasingly exchanged.

In the process of digitizing businesses, people were partially replaced by automated processes starting from Information and Communications Technology, and knowledge-intensive sectors. The need for them to be physically present grew thinner. Due to the COVID-19 pandemic, remote work increased worldwide. In many EU countries, more

than half of the workers started to work from home without ever having tried before [12]. The shift towards remote work, enabling access to tools and resources from a distance, brings about unprecedented opportunities for collaboration and productivity but also introduces new vulnerabilities. Malicious actors can now exploit these digital connections to compromise entire organizations from a remote location, significantly increasing the risk of cyberattacks.

1.2 Attack surface

The expansion of the Internet into a global network has transformed the way we connect and communicate, providing new opportunities for individuals and organizations. However, this openness also introduces new risks and vulnerabilities. Cybercriminals can now target systems and networks from anywhere in the world and deploy more effective phishing attacks.

The role of websites has significantly expanded. They not only serve as a source of information but can also be used to make financial transactions. It can be in a direct or an indirect form. The direct way is through home banking when directly accessing the bank website to manage the account. The indirect way is when checking-out on an e-commerce website. The merchant website will redirect the user to a page from the bank to validate the payment request. This new way of buying is particularly interesting for bad actors that are motivated by financial gain. They can trick the victims into giving their credit card information and cash out all the account's money.

The ability for the cybercriminals to target systems and networks from anywhere in the world and the financial incentive ultimately created a new type of cybercriminal. Moreover, as highlighted by Interpol⁸, these new cybercrimes know no national borders. Both criminals, victims and technical infrastructure are spread across multiple jurisdictions, which complicate investigations and prosecutions.

The internet provides cybercriminals with both convenience and anonymity, increasing their ability to impersonate trusted sources and execute successful phishing attacks. The repercussions of such attacks can be severe, leading to substantial financial losses and reputational damage for both individuals and organizations.

1.3 Research question

In the context of today's Internet (Section 1.1) and the increased attack surface for phishing (Section 1.2), a question arises: How to combat phishing attacks happening on the Internet?

⁸<https://www.interpol.int/en/Crimes/Cybercrime/>

Research question (RQ): How to combat phishing attacks happening on the Internet?

1.4 Document overview

This section will give an overview of the steps we took to answer the question of how to combat phishing attacks happening on the Internet (RQ).

In the first chapter (Section 2), we will define the problem we aim to address by reviewing industry reports evaluating the size of the issue and by presenting two meaningful illustrations based on real-world scenarios and current trends.

In the second chapter (Section 3), we will review the literature for the technical countermeasures of domain name and website phishing attacks. To base our research on strong foundations, we will start by formally defining the important concept and precisely depicting the anatomy of a phishing attacks. Once done, we will review the three most common countermeasures identified by scientific literature and various evasion techniques used by attackers. This will demonstrate the need to reformulate the research question and orient the research to focus on more proactive countermeasure. At the end, the reformulated research question will be “how to assess the trustworthiness of any website” (RQ1).

In the third chapter (Section 4), we will investigate the protection employed across the Internet ecosystem against domain name and website phishing attacks. This deep dive will reveal that the most common way employed to prevent crime on the Internet is through the verification of the website owner’s identity, coupled with the transparency of this information. However, no existing implementation was able to prove that information was properly verified while being usable by the whole ecosystem. This led us to formulate a second research question on “how to prove the trustworthiness of any website” (RQ2).

In the fourth chapter (Section 5), we will determine the requirements for addressing each research question that has been previously formulated. For the first question about assessing the trustworthiness of any website (RQ1) we will follow a set of principles identified by scientific research as the enabler of online trust. For the second question about proving the trustworthiness of any website (RQ2), we will analyze the existing approach to identify the expected requirements.

In the fifth chapter (Section 6), we will address these requirements and make a proposition for each of them. We will introduce the concept of human firewall to address the problem of assessing the trustworthiness before applying the trust principles. For the second question, we will introduce a new protocol to improve the trustworthiness of websites through the transparency of the underlying company controlling the website.

In the sixth chapter (Section 7), we will evaluate our propositions by highlighting their strength and weaknesses.

In the seventh chapter (Section 8), we will conclude the paper by summarizing our findings. We will also provide other potential applications of our proposed solution.

2 Problem

Before we can answer the question of how to combat phishing attacks happening on the Internet (RQ), we need to clarify the problem size and scope. To start, we will analyze reports to evaluate the scale of the concern (Section 2.1). Following that, we will illustrate the issue with two meaningful illustrations (Section 2.2). This will help us to properly define the issue (Section 2.3) and orient the research (Section 2.4).

2.1 Report

This section will investigate reports from various sources to get a first understanding of the scale of phishing when it makes use of domain names. In the scientific literature, these measurements are often grouped into a broader category that includes all forms of DNS-related abuse. Nevertheless, this categorization paradoxically lacks a clear official definition.

First and foremost, it is important to explain why measuring DNS abuse is a difficult issue. A paper from the DNS Abuse Institute⁹ gives us some explanation [13]. The difficulty lies in the fact that DNS measurements typically follow a process of aggregating, cleaning, analyzing and presenting data from multiple sources. From these steps, plenty of variations are possible. The raw data may be the same, but the final presentation will entirely depend on the objectives of the project. It is therefore indispensable to interpret those data in the context of their research and not make unproven extrapolations. In our case, we will pay attention to highlighting the objectives of each report and the specific definition used for phishing.

2.1.1 Anti-Phishing Working Group

Each quarter, the Anti-Phishing Working Group (APWG)¹⁰ publishes a report about the trends of phishing activities. These reports focus on phishing and other identity theft techniques. They measure the evolution, proliferation, and propagation of identity theft methods based on research made by member companies and industry experts.

In the reports, phishing is defined as a crime that combines social engineering and technical tactics to steal consumers' personal identity data and financial account credentials. In contrast, social engineering is defined as schemes designed to lead consumers to counterfeit websites that trick recipients into divulging financial data.

In the last report of 2023 [14], the APWG highlighted that they observed almost 5 million phishing attacks over the course of 2023, which made 2023 the worst year for phishing on record, eclipsing the 4.7 million attacks seen in 2022. The year 2023 was

⁹<https://netbeacon.org/>

¹⁰<https://apwg.org/>

also marked by the shutdown of the Freenom¹¹ service that offered free ccTLD (tk, ml, ga, cf and gq). According to APWG, the shutdown in January 2023 resulted in a significant drop in the following months. Nevertheless, at the end of 2023, phishing attacks were back to the early 2022 numbers.

2.1.2 Interisle

Each year, Interisle¹² publishes a study about the phishing landscape. These studies have the objective to collect and analyze reliable and longitudinally consistent data that companies and policymakers can use to mitigate the threat of phishing.

In these studies, phishing is defined as attacks that deceive victims with websites that appear to be run by a trusted entity, such as a bank or a merchant, but are, in fact, controlled by a criminal. The goal of the phishing page is to trick victims into divulging sensitive information, which can then be exploited to steal money directly or sell credentials to other malicious actors.

2.1.2.1 Phishing Landscape 2023

In its 2023 report [15], Interisle presented a comprehensive overview with eight conclusions that can together depict the overall phishing landscape of the year:

1. The number of phishing attacks has tripled since May 2020.
2. The number of unique domain names reported for phishing continues to increase.
3. New gTLDs are disproportionately used in phishing attempts, making up only 8% of registered domains yet accounting for 25%. Moreover, just 25 gTLDs are responsible for 90% of these attacks.
4. Malicious domain name registrations are the most common way that phishers carry out their attacks, compared to domain name compromise.
5. More than 16% of all phishing attacks use subdomain service providers, where just eight of them are responsible for 80% of those attacks.
6. In November 2022, Freenom¹³ accounted for 14% of all phishing attacks and 60% of ccTLD attacks. However, following the shutdown of its free service, those percentages plummeted.
7. 42% of all attacks are concentrated on only five US-based hosting providers.
8. Criminals too easily acquire the resources they need for phishing.

¹¹<https://www.freenom.com/>

¹²<https://interisle.net/>

¹³<https://www.freenom.com/>

2.1.2.2 Phishing Landscape 2024

For its fourth annual analysis [16], Interisle examined a vast pool of data. Nearly 3.9 million phishing reports were gathered between May 2023 and April 2024. The report distilled these findings into six crucial takeaways:

1. The total number of phishing attacks grew by nearly 50,000 attacks compared to the previous year, reaching almost 1.9 million incidents worldwide.
2. The number of unique domain names used in phishing attacks stayed around 1.1 million, but the tactics evolved. The use of subdomain providers increased by over 50% compared to the previous year, reaching 24% of all phishing attacks.
3. In addition to subdomain providers, cybercriminals moved to inexpensive new gTLD, primarily due to the shutdown of the Freenom free offer.
4. Bulk registration is more widely used, representing at least 27% of all phishing domains registered. These domains are almost always generated by a script and have no meaning. They usually consist of random characters, or two random dictionary words jammed together.
5. The top four hosting providers are US-based companies, with Cloudflare¹⁴ being the most popular choice due to its ability to offer both subdomain services and hiding the actual hosting location.
6. Domain name registration policies significantly affect the level of phishing in a TLD. Review of ccTLD pricing and policies in Europe and the Asia-Pacific region showed that more robust customer verification requirements correlate with lower levels of phishing activity.

2.1.3 European Commission

In the context of the new NIS 2 directive¹⁵, the European Commission highlighted that DNS is an essential component of the digital economy and society. For this reason, they commissioned a study [17] to assess the scope, impact, and magnitude of DNS abuse.

Due to the lack of a universally accepted definition for DNS abuse, the authors opted for a broader scope by considering any activity that makes use of domain names or the DNS protocol to carry out harmful or illegal activity.

This study examined DNS abuse between March 2021 and June 2021 across 2.7 million URLs and 1.68 million unique abused domain names, highlighting fourteen key findings around three categories. However, to stay focused on our primary investigation (RQ), we will only concentrate on the nine takeaways that are directly relevant to our investigation, rather than the side topics of spam, malware distribution, malware command and control, and denial-of-service attack attacks.

¹⁴<https://www.cloudflare.com/>

¹⁵<https://digital-strategy.ec.europa.eu/en/policies/nis2-directive/>

Overall health of TLDs

1. Considering that European Union ccTLDs account for 14.4% of the overall market share, they are by far the least abused category of TLDs with 0.8%.
2. New gTLD is more vulnerable to abuse than the other categories of TLD. They make up only around 6.6% of the global market share, yet account for 20.5% of all abused domain names.
3. However, not all new gTLD are extensively abused. The two most abused (work and xyz) represent 41% whereas the top 6 (work, xyz, top, online, site, icu) represent 60% of abused domains.

Malicious vs. compromised domains: where does the abuse occur?

The classification between malicious and compromised domains was determined by several key indicators. A domain is considered compromised if it is registered in batches with other malicious domains, flagged within the first three months of registration or uses a misspelled version of a well-known brand. The data excludes domains without registration information and free subdomain providers, as they don't fit into these categories.

4. Around 75% of phishing domain names were presumably maliciously registered.
5. Highly used TLD like European Union ccTLDs are more often compromised (42%) compared to lower used TLD like new gTLDs where maliciously registering domains is very common (98%).
6. The top five most abused registrars account for 48% of all maliciously registered domain names.
7. Phishers rely heavily on free subdomain services, which represent approximately 80,000 blacklisted phishing domains.

Adoption of DNS security extensions and email protection protocols

8. DNSSEC is underutilized, with just 4% of domains using it, and a notable 1.9% improperly set up.
9. Some European Union ccTLDs (cz, se, nl, sk) tend to have much higher adoption rates of up to 50%, largely driven by pricing incentives and technical support for DNSSEC.

2.2 Illustration

This section will illustrate how phishing attacks can be done using websites and domain names. First, with a fraud targeting big corporations (Section 2.2.1). Second, through a website targeting individuals (Section 2.2.2).

The following examples are based on attacks seen in the wild but will remain fictional to highlight only the root cause of the problem.

2.2.1 Master data fraud

Since the introduction of online payments (Section 1.1), a new type of attack has emerged. This attack is specific to companies who work with other companies, like suppliers, who they have to pay multiple times. Because to pay the several bills, all the banking information should be stored somewhere beforehand. This very precious data is generally called “master data”. In an enterprise setup, these master data is very valuable for an attacker if he manages to change them without getting noticed.

This kind of attack can be done as follows:

First, the attacker needs to have a very specific knowledge of how the company changes their master data. This can be done by an insider informant. He can be conscious of his actions and have reasons to go against his own company, or he can be unconscious because the attacker has tricked him. In both cases, an internal source has validated the information. The same result can also be done with external sources. The attacker can use open-source intelligence techniques to investigate which software is used to store the master data and which default procedure is put in place to change them.

Second, the attacker should mimic a legitimate modification request. This is generally done by email. He will ask to change the banking details by giving all the required information. He can even forge an email history to appear more convincing. But the most important thing is that the sender's email address looks legitimate. For that, the attacker could spoof the sender address. But in big enterprises like the target, solutions are in place to validate that the sender has not been spoofed (SPF, DKIM). Another solution is to use a look alike. It can be achieved by registering a domain name very similar to the company from which the request should originate. For example, when the company name is composed of multiple parts, the attacker can register the same domain with “-” between the parts.

Furthermore, in a business-to-business relationship, companies do not always have a website. They might use their domain name only for email or host webpages on an entirely different domain.

After successfully completing the modification, the attacker has gained a Man In The Middle position. It is particularly interesting when the master data that were changed are contact details. Because he can now monitor all the conversation from the company and gain even more access and valuable insight for future exploitation. In the case of banking details, that attacker generally waits for a big payment to go through and then activates a money laundering scheme to cash out the money without leaving traces.

It is important to note that most legislation does not force companies victims of this kind of attack to report it. And in the case it is reported, all the details could not be disclosed

because of their high confidentiality level. It makes the analysis of those scenarios more difficult.

2.2.2 Fake webshop

With the development of e-commerce (Section 1.1), new type of attack have emerged. Bad actors are hosting fake webshops and use them to trick victims.

In this section, we will explore the different aspects that are generally considered by users when deciding to purchase on the website. We will demonstrate that it is easy to build a website without any obvious red flags.

Brand

The branding is chosen in a highly saturated market to blend in more easily. Furthermore, this prevents the potential victim from making an online search that can incriminate the website in the first result page.

The items sold on the websites are illustrated with images generated with a realistic image generation model. This prevents the potential victim from making a reverse image search.

Domain name

The TLD is selected to leak the least information to the user. This can be done through a WHOIS proxy service that will replace the company name address and contact information with its own. Or it can be done with a WHOIS privacy service that will redact sensitive informations like names and emails.

Security

In all browsers, the website will appear with a green padlock because the communication is secured with a TLS certificate. The certificate should be issued by Let's Encrypt for two reasons. First, Let's Encrypt is the only certificate authority that is a non-profit company and therefore issues certificates free of charge. Second, the certificates they issue are only domain validated, which means that the requestor only needs to prove he has access to the main resource of the website.

To improve even more the security of the website, the DNS queries can be signed. Proving to the user that the IP resolved by the DNS has not been tampered by a bad actor. Signing the DNS query can be achieved with DNSSEC and can be activated in one click on a lot of hosting providers.

Privacy

The website implements all the legal disclaimers mandatory for European targeted websites, such as a cookie consent banner and a privacy policy. To appear the most legitimate, the privacy policy was copied from another company website with similar

objectives. Only the company name, address, and contact information has been changed with fake ones.

Propagation

The potential victims are not directly contacted by the company via emails or other similar channels because it is not what is expected of a webshop. Instead, the scammers invested financial resources to buy advertising on the web.

2.3 Definition

The two previous illustrations highlight something essential. In the first case (Section 2.2.1), the target is a company where somebody responsible for the administrative part of a master data change, has been tricked by an email coming from a legitimate looking email address. In the second case (Section 2.2.2), the target is an individual who is tricked by a URL he has seen in an ad. For both cases, the domain name is the initial part that tricked the victim. The domain and the website associated are ingeniously crafted to be hardly identifiable as a scam or a fraud.

When the victim wants to investigate, all the basic indicators are in green. More specifically, the branding, domain name and security aspects.

The branding is aligned with what the victim is expecting. All the content does not contain any typos and is always written following the appropriate language style. All the images and logos are in a high-quality format and appear professionally made.

The domain name is aligned with what the victim is expecting and does not rely on visual tricks. Moreover, the WHOIS information is purposefully hidden but only with mechanisms already used by many other websites on the Internet, like WHOIS privacy and proxy services.

The communication with the domain servers, for email or for the website content, is always secured with a TLS certificate. The certificate allows all clients to display a green padlock next to the domain name and ensure that the communication is secured. It is also always domain validated to leak the least information about the true owners and be straightforward to deploy and automate.

2.4 Research focus

To solve the issue highlighted in the previous section (Section 2.3), we need to review the scientific literature to understand what are the technical countermeasures for domain name and website phishing attacks. It will help us understand why phishing is still a major concern (Section 2.1) and how the two illustrations (Section 2.2) are covered by existing solutions.

3 Literature review

This chapter presents an overview of the scientific literature for the problem previously defined (Section 2). We will begin by drawing essential definitions (Section 3.1) and detailing the life cycle of a successful attack (Section 3.2). This strong foundation will enable us to look at the most common technical countermeasures (Section 3.3) and various evasions techniques (Section 3.4) for domain name and website phishing attacks and identify research gaps (Section 3.5).

Note that, all referenced materials are primarily sourced from peer-reviewed scientific literature, ensuring high standards of quality and validity. In cases where non-peer-reviewed sources are utilized, their credibility will be assessed and interpretations made accordingly, with a focus on minimizing potential biases.

3.1 Definition

To properly explain all the concepts related to the subject, an initial common definition must be established. This foundational step ensures a shared vocabulary, facilitating coherent discussion of subjects such as phishing, whose meanings can vary depending on the context.

The explanation of the definition will follow a layered approach, with each term building upon the previous one to provide a comprehensive understanding. Beginning with the fundamental concept of trust (Section 3.1.1), the definition will then expand upon it by introducing the concept of social engineering (Section 3.1.2), which in turn will be further explained through the lens of phishing (Section 3.1.3) as its integral component.

3.1.1 Trust

When discussing trust in scientific literature, trust and trustworthy are two terms who are often employed interchangeably. However, in our research, we have decided to distinguish the terms and follow the definition made in a paper that focuses on defining trust in both an offline and online environment [18]. Given that this article has been peer-reviewed and cited around 70 times since its publication in 2010, we consider it a legitimate source.

Trustor: The subject that trusts a target entity (trustee).

Trustee: The entity that is trusted.

Entity: A person, a store, a bank, a service, a product, etc. It can be identified by its properties such as name, identification, picture, signature, store location, and stated policies.

Trust: Trust is defined as the willingness of the trustor to rely on a trustee to do what is promised in a given context, irrespective of the ability to monitor or control the trustee, and even though negative consequences may occur.

Trustworthy: A trustworthy entity is an entity that behaves according to its promised role.

Furthermore, trust undergoes three distinct phases, each with its characteristics:

1. Initially, trust is built through a process of establishing relationships, fostering open communication, and demonstrating reliability. This initial phase sets the foundation for the development of trust, where the trustor begins to place confidence in the trustee's abilities.
2. Following this initial stage, the trust becomes stabilized, where the trustor and trustee have established a shared understanding and mutual respect. At this point, the trustor feels secure in relying on the trustee to fulfill their obligations, and the relationship becomes more stable.
3. However, this stability can eventually give way to dissolution, where the trust is broken or compromised due to a breach of trust, lack of transparency, or other factors. This final phase marks the end of the trust relationship, leaving both parties feeling vulnerable and potentially re-evaluating their interactions with each other.

3.1.2 Social engineering

According to the Common Attack Pattern Enumerations and Classifications (CAPEC) category definition¹⁶, social engineering is all the attacks that rely on psychological manipulation to trick people into performing actions or divulging confidential information. More broadly, it is a category focused on manipulating and exploiting people's vulnerabilities. Furthermore, the term usually refers to deceptive tactics used to gather information, commit fraud, or gain unauthorized access to computer systems.

3.1.3 Phishing

Due to the potential impact of phishing definitions on our research, it is essential to establish a precise definition that encompasses the variability observed across the

¹⁶<https://capec.mitre.org/data/definitions/403.html>

existing literature. In this regard, we have settled for a systematic review of the literature [19]. Even if this paper reviews literature only up to August 2013, it can be reasonably assumed that the definition of phishing has not undergone significant changes since then. Any subsequent developments in the subject are primarily driven by the evolving tactics employed by malicious actors. The analysis of the existing literature was conducted through a comprehensive review of papers from reputable academic databases such as ACM digital library¹⁷, IEEEExplore¹⁸, and Scopus¹⁹. Furthermore, the paper peer-review process has provided an additional layer of credibility to its findings, enhancing confidence in the legitimacy and accuracy of its conclusions.

Following their methodology, the researchers grouped the concepts into three categories based on how common they appeared in the 2548 results, which led them to 113 definitions. Here are listed the results of all the identified concepts and their respective groups:

Group 1 Concepts that appear in over 50% of papers and are widely accepted as true by the scientific community.

1. Mentioning information
2. Mentions a target
3. Phishing is digital
4. Phishing is Internet-based
5. Using deception

Group 2 Concepts that appear in fewer than 50% of papers, but still considered a consensus by the community.

1. Phishing is fraud
2. Mentions an offender
3. Using persuasion
4. Mentions the later abuse of information
5. Related to identity theft
6. Related to social engineering

Group 3 Concepts that do not meet the criteria for either group and therefore do not have a consensus from the scientific community.

1. Communication from target to offender
2. Communication from offender to target
3. Phishing is a criminal activity
4. Using impersonation
5. Phishing uses websites
6. Phishing uses messages
7. Mentions a trusted third party

¹⁷<https://dl.acm.org/>

¹⁸<https://ieeexplore.ieee.org/>

¹⁹<https://www.scopus.com/>

We can now use the same process that in the original paper to build our own definition.

3.1.3.1 Scalability

Following the original paper, we can merge the concepts of digital (Group 1.3) and Internet-based (Group 1.4), as they are redundant and used in the same way. It is noted that keeping the concept of Internet-based aligns with the more general scope, and therefore will be the one privileged. Nevertheless, this proposition is not acceptable as described by the authors. This choice means that we do not consider SMS to be phishing. The authors have brought an innovative vision to propose a better alternative. They assert that phishing has been facilitated by the Internet's ability to mass-distribute messages. Which led them to redefine the Internet-based concept into the scalability concept. This is a vision we also share, as highlighted in a previous chapter (Section 1.1).

3.1.3.2 Third party

The paper got rid of the concept of trusted third party (Group 3.7) because it is inherited from the impersonation concept (Group 3.4). However, our research suggests that scammers are using clever tactics where they pretend to be something they're not, even if it's just an idea or concept. They attempt to build a “fabricated third party” by replicating the behavior and feel they believe their target desires. In short, the concept of a trusted third party is not suitable in its exact form, as it assumes the existence of a corresponding entity, which may not be present.

Real third party: Entity that is legitimate.

Fabricated third party: Entity that replicate the behavior and feel of another real third party without copying it.

3.1.3.3 Communication

Third, all concepts related to a specific communication channel (Group 3.1, Group 3.2) can be eliminated, as they will be further examined in a following investigation (Section 3.2.2).

3.1.3.4 Criminal

Finally, we note that the notion of phishing as a criminal activity (Group 3.3) is dependent on national legislation, which presently lacks universal scope. Therefore, this concept should be eliminated.

In conclusion, the definition of phishing must include the concept of information (Group 1.1), target (Group 1.2), scalability (Section 3.1.3.1), deception (Group 1.5) and third party (Section 3.1.3.2).

Phishing: Scalable act of deception whereby impersonation of a real or fabricated third party is used to obtain information from a target.

3.2 Life cycle

In this section, we will explore phishing in depth by proposing a comprehensive life cycle that maps out every crucial step involved in executing a successful attack. Each step will be dissected in detail and supplemented by meaningful examples to illustrate the key concepts.

Our proposition is inspired by the Lockheed Martin's Cyber Kill Chain²⁰, widely recognized by the cybersecurity community. This framework is focused on identifying and preventing cyber intrusion activity. The model identifies what adversaries must complete to achieve their objective. Adversaries are defined as Advanced Persistent Threats (APTs), with "advanced" and "persistent" highlighting that they are targeted, coordinated and purposeful, and "threat" indicating intent, opportunity, and capability. In our research scope, we consider attackers to be advanced threats but not persistent. We suggest a modified version of the framework without persistence attributes, effectively removing the Installation and Command and Control phases.

Our proposed life cycle for a phishing attack consists of five distinct phases:

1. Reconnaissance: select the target, determine the most effective vector to use and choose the exploit.
2. Weaponization: turn the exploit into a weapon by crafting a deliverable payload.
3. Delivery: deliver the payload to the target using the selected vector.
4. Exploitation: wait for the exploit to make effect on the target.
5. Actions on Objective: take action to achieve the desired objectives.

In the following sections, a more detailed exploration of the key terms will be presented.

3.2.1 Target

To categorize the various types of targets, we will draw inspiration from a paper [20] that proposes a layered approach. However, we will adapt the terms to reflect what is broadly used by the cybersecurity community.

Mass phishing

It is a type of attack targeted at a large group of individuals. This type of attack may seem convenient, as it doesn't necessitate a lot of investment in terms of design. However,

²⁰<https://www.lockheedmartin.com/en-us/capabilities/cyber/cyber-kill-chain.html>

despite its ease of creation, the attack's success rate remains low due to a lack of personalization, making it less effective overall.

Mass phishing: Phishing targeting a large group of individuals.

Spear phishing

It is a subset of mass phishing that targets a specific organization or group, requiring more planning and effort than its counterpart. In contrast, the attack's success rate is higher.

Spear phishing: Phishing targeting an organization or a group.

Whaling

It is a subset of spear phishing that specifically targets high-level executives. The attack requires substantial time and effort to construct, with a success rate comparable to spear phishing.

Whaling: Phishing targeting a high-level executive of an organization or a group.

3.2.2 Vector

In this section, we will analyze and discuss the diverse tactics used in phishing attacks that have been documented in academic research and by the cybersecurity community.

Email

Email remains the most well-known vector where attackers launch phishing campaigns by sending emails with malicious links or attachments. They often try to spoof the sender email address when no additional security measures are in place and therefore appear more legitimate.

SMS

With the increasing adoption of online delivery and two-factor authentication via SMS, phishing attacks over SMS seems to have gained significant traction. Such attacks are called “smishing”. In most cases, attackers send a fake delivery notification SMS to the victim, claiming that a package cannot be delivered, and prompt them to click on a link to resolve the issue.

Smishing: Phishing through SMS.

Voice

With the creation of Voice over Internet Protocol (VoIP), a new type of phishing has emerged: “vishing”. This sophisticated scam can leverage advanced technology, including deepfake voices, to make phone calls that are nearly indistinguishable from real ones. The attacker will pose as someone else, convincing the victim to take action.

Vishing: Phishing through Voice over Internet Protocol (VoIP).

Social media

Over the years, social media has become an increasingly popular platform for communication worldwide. This shift in technology has not gone unnoticed by scammers, who are now exploiting social media to send phishing scams similar to those found in email. Additionally, attackers are also using companies' own customer service resources on social media platforms against them. By impersonating a company's customer service team, the scammer can connect with dissatisfied customers who have shared their frustrations online and then redirect them to a fake website in an attempt to resolve the issue. This type of attack is commonly referred to as “angler phishing” by cybersecurity experts.

Angler phishing: Phishing through social media.

QRCode

The COVID-19 pandemic has accelerated the global adoption of QR Codes as a convenient way to store information. However, this commodity also creates an opportunity for phishing attacks. Attackers can create malicious QR Codes that mimic legitimate ones, making it difficult for users to distinguish between them without scanning them. For instance, it would be easy for an attacker to replace a restaurant's QR Code, typically used to access its online menu, with a malicious version. This type of attack is commonly referred to as “quishing” by the cybersecurity community.

Quishing: Phishing through QR Code.

3.2.3 Exploit

During our research of the topic, we found numerous ways to register a domain name to be used in deceptive attacks. According to ICANN, this type of abusive registration is called “cybersquatting” when the intent is to coincide with a commercial trademark or the name of a well-known person²¹.

²¹<https://www.icann.org/en/icann-acronyms-and-terms/cybersquatting-en/>

Cybersquatting: Abusive domain name registration with the intent to coincide with a commercial trademark or the name of a well-known person.

This section will examine common techniques used to register domain names for phishing purposes, but only when the desired domain name is already taken by the legitimate entity. This means that it does not apply for fabricated third party.

Look-alike

The most basic set of attacks consists of registering look-alike domains and exploiting the target's lack of vigilance. This can be achieved by making subtle changes, like replacing the letter "l" (U+006C) with the capital letter "I" (U+0049) or the capital letter "O" (U+004F) with the number "0" (U+0030).

TLD Squatting

"TLD squatting" involves registering the same domain name but with a different TLD. This type of cybersquatting takes advantage of the fact that many users may not notice or care about the difference between ".com" and other TLDs.

TLD Squatting: Cybersquatting through a different TLD.

Combosquatting

"Combosquatting" involves adding a keyword to a domain name, often intending to exploit specific search terms or keywords. For example, a domain like "microsoft-support.com" might be registered by someone looking to capitalize on searches for Microsoft issues.

Combosquatting: Cybersquatting through the addition of keywords.

Typosquatting

"Typosquatting" is a type of cybersquatting where domains are registered with intentional typos. The purpose is to capitalize on the common keyboard layout errors that some users might make. For example, a domain like "goggle.com" might be registered by someone hoping to intercept users who meant to visit the official "google.com" website.

Typosquatting: Cybersquatting leveraging typing mistakes.

Soundsquatting

“Soundsquatting” involves creating a domain name that sounds similar to the legitimate website. For example, a domain like “utube.com” might be registered by someone looking to capitalize on searches for “youtube.com”.

Soundsquatting: Cybersquatting through similar sound.

Dotsquatting

“Dotsquatting” involves adding or removing dots to a domain name. As a result, the domain name is spelled identically as the legitimate one in terms of letters. For example, a domain like “www.chat.gpt.com” or “wwwchatgpt.com” might be registered instead of the legitimate “www.chatgpt.com”.

Dotsquatting: Cybersquatting through the insertion or omission of dots.

Levelsquatting

“Levelsquatting” involves using a domain name as a subdomain, often with unrelated main domains. For example, a domain like “example.com” might be registered as “example.com.long-domain.com”.

Levelsquatting: Cybersquatting with the legitimate domain as a subdomain.

IDN homograph

The Internationalized Domain Name (IDN) homograph attack involves exploiting domain names that use other alphabets. The trick lies in replacing a character with its corresponding look-alike in another alphabet. For instance, the Latin “o” (U+006F) can be substituted for the Greek “o” (U+03BF) or the Cyrillic “o” (U+043E).

Internationalized Domain Name (IDN) homograph: Cybersquatting with substitution from other alphabets.

Bitsquatting

“Bitsquatting” is an attack that remains entirely on luck. But once performed, it is invisible to the end user. It was introduced in [21] by researchers who found a way to exploit naturally occurring bit flips in the computer memory. These bit flips are often caused by manufacturing defects, overheating or cosmic rays. They argued that even if this phenomenon is rare, due to the large number of devices connected to the Internet, the impact is non-negligible. The idea behind the attack is to register domains that are a bit

flip variation of the domain targeted. Which means that in the case of a bitflip, the user will be automatically redirected to our domain without him being aware of it.

Bitsquatting: Cybersquatting leveraging naturally occurring bitflips.

3.2.4 Weapon

In this section, we will explore various methods for implementing the exploits discussed in the previous section (Section 3.2.3) and applying them to the broader context of information security.

For a phishing campaign involving a fake website, attackers have two different options. They can use a compromise website or build their own in-house.

3.2.4.1 Compromised website

Compromised websites can be acquired through various means. It can be through manually exploiting vulnerabilities to gain full control of the website, or even gaining access to the hosting provider itself. Alternatively, these websites can be obtained from darknet marketplaces, where skilled sellers typically handle the hacking phase.

3.2.4.2 In-house website

Since the perceived legitimacy of a website varies with each user (Section 2), building a convincing phishing website requires the same core steps as building a legitimate website. It necessitates four essential components:

1. Client-side code that defines the website's visual elements, complemented by server-side code handling critical functions.
2. A hosting provider to run the server-side code and his requirements like a database. Furthermore, the hosting provider provides global accessibility. It allows any internet user to fetch the client-side code from anywhere in the world and run it on his computer via a web browser.
3. A registered domain name to make it appear more trustworthy compared to relying on an IP address.
4. A TLS certificate to protect the communication between the user and the hosting provider when accessing the client-side code.

The client and server-side code can either be developed by the attacker or purchased as a pre-made “phishing kit” from darknet marketplaces.

Phishing kit: Pre-made phishing website sold by cybercriminals.

Choosing a hosting provider is relatively easy. Ideally, the attacker should opt for a hosting provider that accepts anonymous payment methods, such as cryptocurrencies or anonymous credit cards. They must also verify that the provider does not actively scan for phishing scams on its infrastructure to prevent their account from being banned or reported to the authorities.

The choice of a TLD can impact the perceived legitimacy of a website. Furthermore, attackers should be aware that certain ccTLDs and gTLDs have specific requirements that must be met to register and maintain a domain.

For the certificate, Let's Encrypt²² is the clear top pick, thanks to its market dominance and status as the first free certificate provider.

3.2.5 Objective

In this section, we will discuss the objectives of a phishing attack.

According to the Common Attack Pattern Enumerations and Classifications (CAPEC) category definition²³, phishing is used to reveal some confidential information that is very frequently authentication credentials. This is consistent with the consensus investigation on phishing (Section 3.1.3), which also confirms its connection to the later abuse of information. Furthermore, it also makes links with fraud and social engineering. Based on the CAPEC definition of social engineering (Section 3.1.2), it can be concluded that social engineering involves deception for information gathering, fraud, or computer system access. By examining these definitions, we have identified two critical concepts: data collection and fraud, highlighting the scope and intent behind phishing attacks.

We propose a model that defines objectives by leveraging the two concepts of data gathering and fraud. This approach draws inspiration from [22], which defines a “valuable acquisition phase” that is composed of “valuables” and “valuables misuse” steps. The study also highlights two forms of data gathering, including automated methods used in website-based phishing and manual approaches involving direct communication between attackers and victims.

In conclusion, our suggested model consists of two stages:

1. Data collection: attacker acquiring valuable data, which can include sensitive information such as credentials (e.g., username and password), credit card details, identity documents, and other personally identifiable information.
2. Fraud: fraudulent activities that can be carried out with the collected data. For instance, the stolen data can be sold on the black market, used to gain unauthorized access to accounts, make purchases, commit identity theft, or engage in other forms of fraud.

²²<https://letsencrypt.org/>

²³<https://capec.mitre.org/data/definitions/98.html>

3.3 Countermeasure

In this section, we will provide an overview of the most common technical countermeasures for domain name and website phishing attacks.

To do this thoroughly, we have selected a peer reviewed survey [23] published in February 2023 in the well-known Institute of Electrical and Electronics Engineers (IEEE) journal. Compared to existing surveys, the paper is focused on both list-based, similarity-based and machine learning-based detection approach. Its main objective is to allow readers to easily navigate the state of the art of this extensively investigated research field. It provides readers with a broad, comprehensive and up-to-date overview of the main solutions proposed in the literature for detecting phishing websites. This objective is seen by the authors of the paper as a significant strength of their survey, as they believe no existing work provides the same level of depth. Another important added value is the work done to highlight the main strengths and weaknesses of the three categories of detection methods.

Their methodology involved retaining a selected subset of 600 papers, accounting for approximately 13.6% of their total corpus, which were then distilled down to 127 papers by focusing exclusively on topics within the three categories. This rigorous filtering process ensured they only retained the most groundbreaking and impactful works. In our analysis, we will use the PageRank algorithm [24] to help us keep only the most significant paper for each concept relevant to our study.

However, using this paper alone for our research has a main limitation. The phishing definition of the researchers is only considering impersonation of known brands, which fails to account for our broader definition of phishing (Section 3.1.3) that encompasses scenarios where no brand is involved. As a result, we must reevaluate each countermeasure in light of whether it could be applied to either a real or fabricated third party.

3.3.1 Similarity

Websites that impersonate real third parties closely mimic their legitimate counterparts, making them difficult to distinguish. Therefore, comparing the similarity with known third parties is a good indicator of this kind of phishing attack. To spot these impostors, similarity is detected through textual or visual clues. The textual content is both the text and the underlying structure of the page, while the visual content is its appearance.

3.3.1.1 Textual

For website textual similarity detection, research typically focuses on analyzing page text and layout which are technically represented using HTML, CSS, and the DOM. The HyperText Markup Language (HTML) is the language used to structure the website. It is coupled with Cascading Style Sheets (CSS) to style and layout the pages. Together, they

represent the static part of the source code of most webpages. Nevertheless, this source code is not used as such by the browser. It is converted into the Document Object Model (DOM) as an internal map of a web page's structure.

As an example, the research conducted in [25] used retrieval information algorithms to extract and analyze valuable insights from the text embedded within the HTML. The algorithm roughly works in four key steps. Initially, we calculate the TF-IDF score for each term, balancing its frequency within a document with its rarity across the entire corpus. Next, we distill this information into a lexical signature composed of the top five terms. Then, we query search engines to obtain results for this signature. Finally, we classify the website as legitimate if it appears among the N most relevant results, and as phishing otherwise.

Furthermore, a common way to spot copied websites is to look for unique textual content like product descriptions or customer reviews and use search engines to list all other websites that used the same text. However, this approach is now limited by the widespread availability of Large Language Models (LLM) that can easily rephrase content. Nevertheless, this method is still relevant in the case of visual similarities.

3.3.1.2 Visual

Visual similarities in phishing detection is typically reduced to an image matching problem resolved with computer vision techniques. Research in this area generally considers keypoint or signatures to represent the images.

Keypoints are specific points on an image that help identify unique features. For example, the paper [26] proposed a schema based on Scaled Invariant Feature Transform (SIFT) that can extract a collection of keypoints that are independent of image transformation like translation, scaling, and rotation. In practice, the similarity is calculated on the logo itself by comparing the results to a database of known brand logos. More precisely, the similarity is evaluated by determining the proportion of matching keypoints to the total keypoints found in the authentic logo. Ultimately, a final classification decision is made by applying a threshold to distinguish genuine sites from potentially malicious ones.

The signature is a lightweight representation of the image. For example, in the paper [27], the signature is composed of colors and the centroid of its position distribution in the image. In practice, the images are standardized into a lower-resolution square image with consistent dimensions, then the distance between two signatures is calculated using Earth Mover's Distance formulas. At last, a unique threshold is used for each suspected page to distinguish genuine sites from potentially malicious ones.

To conclude, the main survey [23] helped us highlight some limitations, advantages, and disadvantages of both textual and visual similarity detection techniques.

The main limitation with similarity-based detection methods is their reliance on a dataset composed of legitimate websites. If a website is not present in the dataset, the

counterfeit version cannot be detected. In other terms, this method can only detect real third party. Moreover, this creates a significant vulnerability that evasion techniques (Section 3.4) can exploit, as they can reduce the effectiveness of the detection techniques or even outsmart them entirely. Furthermore, relying solely on a threshold-based classification system introduces subjectivity into the analysis, as the choice of threshold can significantly impact the results.

However, when a genuine website is included in the dataset, it offers the ability to identify zero-hour attacks.

Nevertheless, this comes with an impact on the performance. The methods can be computationally intensive, especially when processing screenshots, and storage intensive as they require storing large amounts of legitimate websites. Moreover, relying on external services like search engines can introduce latency and slowdowns.

3.3.2 Machine Learning

Machine learning is a very popular topic these days. It is also the case for website phishing detection, where the area is extensively researched. The problem is usually reduced to a binary classification problem to distinguish legitimate from phishing websites. Traditionally, it is solved by selecting a set of features fed into a machine learning model that will classify the data as legitimate or malicious. In the literature, this kind of approach primarily differs by the range of features and the learning algorithm employed to build the models.

In our case, we will only focus on this type of approach by following the work done in the main survey [23] where the focus is only on providing a very high-level analysis and highlighting strengths and weaknesses. This means that solutions presenting unconventional approaches will not be discussed.

3.3.2.1 Feature

For phishing detection, features can be gathered from either the client side or through external sources. The client side involves extracting information directly from the user's perspective, such as the URL (Section 3.3.2.1.1), source code (Section 3.3.2.1.2) or communication information (Section 3.3.2.1.3). Meanwhile, external services (Section 3.3.2.1.4) like search engines, DNS records, and WHOIS databases provide data based on the URL. This external data serves more as a layer of reinforcement, rather than an entirely new source, as it is built upon the existing information gathered on the client side.

When it comes to getting detailed characterizations, researchers often look at features that are made up of multiple types of properties coming from different sources. The idea is that one type of property is not generally enough to make an educated decision. Moreover, in the case where only one key feature is sufficient, relying on machine learning is unnecessary.

3.3.2.1.1 URL

URL-based properties typically refer to characteristics that can be derived from the URL string through both lexical and statistical analysis.

On one hand, lexical properties refer to the structure and composition of the text after breaking it down into individual tokens using known delimiters, such as periods, colons, and forward slashes. For example, the researchers in [28] started by extracting all the words in the hostname and path using known delimiters. Next, they employed the bag-of-words technique to assign a binary feature to each token that indicates its frequency of occurrence. However, this method sacrifices valuable information regarding the original token sequence. To solve this problem, they suggested a solution that can differentiate between tokens based on where they came from.

On the other hand, statistical properties focus on patterns that are present at the character or word level. For example, in the paper [29], researchers examined the statistical property by looking at the relationship between words in the hostname and the path of the URL. More specifically, they referred to it as the intra-URL relatedness and evaluated the level of similarity using the Jaccard index.

In conclusion, the main survey [23] concluded that these features offer several benefits. Because they are only based on the URL, they eliminate the need for a full-page download, allows rapid detection, and ensures safe extraction. However, they can still be vulnerable to URL manipulation (Section 3.4.3).

3.3.2.1.2 Source code

The source code serves as a textual blueprint for the webpage. As a result, it is possible to capture the layout through textual properties. Furthermore, by rendering the source code, we can reveal its visual component and accurately depict its appearance through visual properties. In either case, the methods that can be employed are very similar to those presented in a previous section (Section 3.3.1).

3.3.2.1.2.1 Textual properties

Textual properties can focus on the general aspects by considering the number and frequency of certain terms or tags. In contrast, they can be more specific by inspecting the content associated with those tags like the title, copyright, form, or anchor.

For instance, in addition to the features proposed in [25], the enhanced version [30] proposed two original features that are particularly pertinent to our study. The first thing they suggested was a feature that outlines suspicious forms defined by having an input tag with sensitive keywords like “password” or “credit card” and sending the data to an insecure location. Their next suggestion was to verify that the page's domain appears as the most frequently used domain across all the links present in its HTML.

Additionally, another innovative approach [31] proposed to look at abnormal DOM object and HTTP transactions. More precisely, this approach is based on the idea that every website claims an identity, either explicitly or implicitly. By examining abnormal

behavior compared to an honest website, they were able to effectively detect phishing websites.

3.3.2.1.2.2 Visual properties

Visual properties generally use representations from computer vision for object detection and image classification. This means that they share many similarities with the concept already introduced in a previous section (Section 3.3.1). For example, the paper [32] uses color histogram and Histogram of Oriented Gradients (HOGs) instead of the Scaled Invariant Feature Transform (SIFT) previously introduced. From a technical standpoint, color histograms represent the spacial distribution of colors. In contrast, HOG works by counting the occurrences of gradient orientation within localized regions, and subsequently generating a histogram based on the magnitude and orientation of the gradient.

In conclusion, the main survey [23] concluded that these properties are robust to both content obfuscation (Section 3.4.2) and cloaking (Section 3.4.1) evasion techniques. However, their implementation has a negative impact on performance, due to delays during the extraction phase and storage requirements. Furthermore, since they require downloading the page and parsing it, this could add even more delay and lead to safety concerns.

3.3.2.1.3 Communication

Communication properties can be derived from both the HTTP response received from the web server and the TLS certificate used to secure the communication.

For instance, in [33] a combination of textual and communication properties is extracted from the hyperlinks present in the webpage. The textual properties include metrics such as the number of hyperlinks and the proportion that point to the same domain as the webpage. In contrast, the communication properties represent the frequency of broken or redirected hyperlinks identified through the response codes and the presence of empty hyperlinks, that keep users on the same page.

Another example is [34], which leverages both HTTP headers and certificate information. The HTTP header properties include the field names and the count of standard and non-standard fields. In contrast, the certificate properties are the issuer's company name, certificate validity duration, age, and the number of second-level domains assigned to the certificate. Furthermore, this method also considers the presence of an extended validation and whether it is considered valid by web browsers.

In conclusion, the main survey [23] concluded that communication properties offer a significant advantage by their capacity to detect redirection (Section 3.4.3), but they also introduce a notable performance bottleneck when making the requests. Additionally, because these properties require downloading the entire page, there's a risk of compromising safety and security.

3.3.2.1.4 External service

External services are used to improve webpages description through network and reputation properties. The network aspect uses only the host and domain name to query third-party services like DNS or WHOIS. Meanwhile, the reputation factor considers the full URL to measures the ranking and popularity.

For instance, several papers that have been featured in this section (Section 3.3.2.1) have improved their outcomes by using external services.

The [28] approach uses WHOIS, IP and geographical properties gathered from external sources. More precisely, WHOIS properties are composed of the registrant and registrar information along with the registration, update, and expiration date of the domain. Additionally, IP properties refer to the Autonomous System or the IP prefix. Furthermore, geographical properties include data on the continent, country, or city where an IP address is assigned.

The [25] approach makes heavy use of search engine. The primary characteristic is the position in search engine results for key terms present in the webpage. In contrast, [30] proposes to extend this idea by also querying the copyright company name along with the domain or hostname.

The [29] approach uses search engines queries to evaluate the intra-URL relatedness.

Because search engines like Google²⁴ are based on the PageRank algorithm [24], some research directly used Google's PageRank as a reputation ranking system.

In conclusion, the main survey [23] concluded that the benefit is the ability to have up-to-date information without downloading the page. In contrast, relying on third-party services introduces significant delays due to the need for external requests. Furthermore, this approach is not foolproof, as compromised websites may still report false negative.

3.3.2.2 Feature selection

When the set of features is too big, it can lead to overfitting and increase the computational requirement. By selecting a subset of feature, it is possible to mitigate those issues while improving the accuracy.

For example, [35] proposed a new feature selection framework called "HEFS" that leverage existing filters measures. Moreover, HEFS can find the optimal number of features by looking at how filter measure values are distributed.

3.3.2.3 Model

To solve the binary classification of whether a website is phishing or not, many supervised learning algorithms have been studied in the literature. These include traditional methods as well as newer ones like online and deep learning.

²⁴<https://www.google.com/>

3.3.2.3.1 Traditional

The main survey [23] reveals that traditional machine learning methods such as Support Vector Machine, Random Forest, and Logistic Regression dominate the field of phishing detection, with other popular choices including K-Nearest Neighbors, Decision Tree, Adaboost, and Naive Bayes.

In practice, research papers usually experiment with multiple algorithms to find the one that works best for their specific environment. Despite the inability to directly compare results across various settings, Random Forest consistently emerges as a superior performer.

Furthermore, it is not always necessary to select the most effective algorithm when multiple models can be combined using ensemble learning.

For instance, [36] enhances phishing webpage detection with a two-layer ensemble learning approach. This involves a primary layer composed of a Gradient Boosting Decision Tree (GBDT), XGBoost and LightGBM model. The predominant output is selected for the second layer, where the same process is applied. The final decision is made by combining the features of both the first and second layers into a new GBDT model.

3.3.2.3.2 Online learning

As phishing constantly changes, detection methods need to be able to respond in real-time to emerging threats to remain effective. To solve this problem, pioneer work done in [37] explored online learning approaches for detecting malicious websites. They showed that online learning is particularly appropriate for datasets that are too large to be effectively processed and when the sets of features are constantly evolving.

In other words, online learning models enable real-time detection by not training on the entire database at once, but by allowing the model to be continuously fed with new information.

According to the main survey [23], the three most common algorithms in this field are the Perceptron, Confidence-Weighted and Passive-Aggressive algorithm. However, online learning has not been a focus of interest in the literature, since it is computationally expensive and cumbersome to control and protect, since the model changes frequently.

3.3.2.3.3 Deep learning

Deep learning approaches are categorized by their capacity to extract features on their own.

According to the main survey [23], the more commonly used algorithms are Convolutional Neural Network, Long Short-Term Memory, Deep Neural Network and Multilayer Perceptron. These algorithms mainly differ by the number of layers and the type of connection between the layers. Furthermore, Convolutional Neural Network and Long Short-Term Memory stand out as the most effective for phishing classification.

To conclude, the main survey [23] helped us identify the limitation, advantages, and disadvantages of machine learning approaches.

The main limitation of machine learning approaches is when they are used as a black box. To be able to extract a meaningful set of features, it is important that researchers have a strong domain knowledge. Otherwise, they will not be able to detect fabricated third party. Moreover, it is imperative that they remain informed about the latest tactics employed by cybercriminals and how they modify the design of their website to evade detection (Section 3.4).

With the right engineering, machine learning approaches have the advantages of being able to detect new types of attacks by making extrapolation based on the training data. Furthermore, these implementations are generally fast and effective. This means that they can identify phishing on the fly.

However, performance is mostly dependent on the features extracted from the webpages. All of them have different trade-offs. Features extracted from the URL (Section 3.3.2.1.1) are fast and light on resources but vulnerable to URL manipulation (Section 3.4.3). In contrast, features extracted from the source code (Section 3.3.2.1.2) are robust to some evasion techniques (Section 3.4) but resource intensive and can lead to safety issues.

3.3.3 List

Because phishing detection can be reduced to a classification problem, it is possible to pre-assign categories to URLs beforehand. This eliminates the need for users to make these decisions themselves. In practice, this kind of information would be shared in the form of a list. These lists can be categorized as either blacklists, which contain notorious phishing sites, or whitelists, which contain a collection of reputable websites.

3.3.3.1 Blacklist

Due to their simplicity, blacklists have become an essential feature in many popular browsers to protect its users from known malicious URLs. For example, big players like Chrome²⁵, Safari²⁶, and Firefox²⁷ uses Google Safe Browsing²⁸. Meanwhile, Microsoft's Edge browser²⁹ employs its own SmartScreen technology.

Nevertheless, simple blacklists have some limitations. Even with regular updates, there will always be a lag between a URL being added to the blacklist and it actually being blocked by users' web browsers. Furthermore, attackers can use evasion technique to slightly change the URL (Section 3.4.3) and not being matched to their entry in the

²⁵<https://www.google.com/chrome/>

²⁶<https://www.apple.com/safari/>

²⁷<https://www.mozilla.org/firefox/>

²⁸<https://safebrowsing.google.com/>

²⁹<https://www.microsoft.com/edge/>

blacklist. To counter those limitations, some research proposed employing predictive approaches.

For example, the paper [38] extends traditional blacklisting by incorporating variations of the URLs present in the blacklist. To achieve this, they apply several lexical heuristics, including switching the TLD. Because this technique can generate plenty of invalid URLs, they use a two-step approach before adding the URL to the list. First, they verified that the URL exists, then used similarity detection (Section 3.3.1) to ensure that the generated URL is also phishing. Furthermore, when determining whether a URL is present in the blacklist, they used an approximate matching algorithm. The algorithm uses information such as the resolved IP addresses, hostnames, and directory structure to determine if a URL is a version of a URL present in the blacklist.

3.3.3.2 Whitelist

Most research takes the assumption that popular websites are legitimate and use top-ranked domains as a source of legitimate URLs. Nevertheless, research in [39] showed that all main ranking lists (Alexa³⁰, Cisco Umbrella³¹, Majestic³² and Quantcast³³) contain at least some malicious domains. Furthermore, they showed how it is trivial for an attacker to alter those lists. To address the issues, researchers created a unified list and added an option to filter out unwanted domains. Moreover, the new list is designed to be less susceptible to manipulation, with its rankings determined by the domain's overall popularity across multiple lists. In other words, compromising one list will only slightly improve the ranking in the combined list.

While a clean whitelist provides a solid foundation, it is not applicable to every scenario. For this reason, other approaches proposed to build an individual list for each user.

For example, the paper [40] maintains a whitelist on the user computer composed of the most trusted login user interfaces that have withstood repeated successful logins. The login user interfaces are defined using the website URLs, server IP addresses, TLS certificates, HTML form signatures, and precise location in the DOM of sensitive fields such as username and password. Furthermore, a warning is received when a login form that is not present in the list is detected.

Similarly, the paper [41] maintains a whitelist composed of all the websites visited by the user that have been checked to be legitimate. The list stores the URL as well as the IP address of the server. Technically, the check is done by a basic machine learning model using hyperlinks features.

³⁰<https://www.alexa.com/> (discontinued in 2022)

³¹<https://umbrella.cisco.com/>

³²<https://majestic.com/reports/majestic-million/>

³³<https://www.quantcast.com/>

Furthermore, we can note that the design of password managers inherently supports a form of individual whitelisting for login forms. Because each credential is stored alongside its domain, it will only be proposed for entry on the legitimate website.

To conclude, list-based detection is simple and fast and applicable for both real and fabricated third party. Nevertheless, it cannot protect against zero-hour attacks. Solutions like predictive blacklist and individual whitelist provide important improvement, but are still not capable of detecting new types of phishing attacks. The main survey [23] concludes that list-based approaches are effective at raising suspicion, but need to be coupled with other methods for further refinement.

3.4 Evasion

This section focuses on the techniques employed by attackers to evade the detection methods introduced in the previous section (Section 3.3). While the list of methods is not exhaustive, it covers both common and more sophisticated evasion techniques. Furthermore, it will highlight the phishing detection methods that each evasion technique is designed to bypass.

3.4.1 Cloaking

The cloaking techniques work by presenting different versions of the webpage based on specific conditions. This allows the attacker to selectively display malicious content only to targeted victims while blocking access to unwanted clients like crawlers, sandboxed environments, and anti-phishing tools. In practice, such clients can be detected either on the server or on the client itself.

3.4.1.1 Server side

When the server determines whether the client is a potential victim or not, it performs the check before sending the webpage. As a result, when benign webpages are sent they do not include any malicious code, defeating both similarity (Section 3.3.1), machine-learning (Section 3.3.2) and list-based (Section 3.3.3) detection methods.

A simple approach involves restricting access to the phishing site within a limited time frame. If the victim attempts to revisit the site outside this window, they are presented with a benign version instead.

The most well-known technique for detecting cloaking remains the use of characteristics extracted from the HTTP request sent by the client, such as IP, User-Agent, HTTP referrer, or cookie information. In some cases, IP can also be used to estimate a client's geolocation. However, researchers in [42] have developed a method to detect this type of cloaking by requesting the page using variations of these characteristics and by applying similarity techniques (Section 3.3.1).

3.4.1.2 Client side

When it is not the server that determines whether the client is a potential victim or not, it's a malicious payload that runs on the victim's computer that makes the decision. Even if the payload will not activate the malicious part when an adversary is detected, these cloaking techniques cannot prevent detection methods (Section 3.3) from analyzing the source code directly.

Since the malicious payload is written in a language that can be interpreted by the browser, such as JavaScript, it is possible to identify simple crawlers by monitoring whether code is being executed. Moreover, the malicious payload could be flagged as malicious through both static and dynamic code analysis.

Generally, the most common technique to make the distinction between computer and human is by using Completely Automated Public Turing Test to tell Computers and Humans Apart (CAPTCHA) [43]. However, in cases of phishing cloaking, displaying a pop-up or waiting for a click or mouse movement is already sufficient to detect the unwanted client. This means that to have effective visual properties from similarity (Section 3.3.1.2) and machine learning (Section 3.3.2.1.2.2) methods, the tools should first simulate the behavior of human by interacting with the website to reveal the phishing material.

3.4.2 Content obfuscation

Attackers can use various techniques to obfuscate the content of a webpage, whether it is through its source code or visual appearance.

Obfuscating the source code is a technique used to make it difficult for humans to understand while preserving its functionality for machines. For instance, by adding unnecessary code elements or replacing text with images, attackers can evade detection methods that rely on source code analysis, including those based on similarity (Section 3.3.1.1) and machine learning (Section 3.3.2.1.2.1) techniques.

By comparison, obfuscating the visual targets the visual detection used in similarity (Section 3.3.1.2) and machine learning (Section 3.3.2.1.2.2) techniques. Obfuscation is achieved by modifying the visual appearance sufficiently to evade detection without being too notable for the victim. Common tactics employed include image distortion or rotation.

3.4.3 URL manipulation

The attacker could also obfuscate the URL to prevent both humans and machine from making association with a known malicious URL. By rendering the URL meaningless, this will bypass the machine learning URL features (Section 3.3.2.1.1) and blacklist (Section 3.3.3.1).

Additionally, a new type of attack relies on using another domain and redirecting the user to the same destination. In practice, many trustworthy websites offering URL shortening services can be used to set up a link that will redirect to the malicious domain.

3.4.4 Living off trusted sites

Another range of trustworthy services can be exploited if they allow user-generated content to be hosted through their platform or offer customizable subdomains to their clients. In both cases, it can be used to trick victims into believing that the website is trustworthy since the domain name is from a well-known trustworthy service. This method targets both whitelist (Section 3.3.3.2) and machine learning-based external services (Section 3.3.2.1.4), as they rely on URL verification rather than content inspection to determine legitimacy.

3.4.5 Compromise trusted sites

Instead of exploiting a well-known trustworthy service, attackers may legally hijack unprotected domain names. This can occur when the domain name owner fails to renew it or when the domain name is abandoned for legitimate reasons like a company ceasing its activities. In such cases, whitelist (Section 3.3.3.2) and machine learning-based external services features (Section 3.3.2.1.4) may be vulnerable if they do not remove the domain from their database following a change of ownership.

Similarly, a resourceful attacker could compromise and take control of an entire service to alter its content while maintaining the reputation of the legitimate website. As a countermeasure, a similarity analysis (Section 3.3.1) can be employed to detect compromised websites. By comparing versions over time, it is possible to detect major modifications that could indicate the website has been compromised and that its content has been replaced.

3.5 Research gap

This chapter had for objective to review the literature on the technical countermeasures for domain name and website phishing attacks. It has been concluded that similarity (Section 3.3.1), machine-learning (Section 3.3.2) and list-based (Section 3.3.3) detection methods are the common technical countermeasures for domain name and website phishing attacks. However, these methods are subject to several evasion techniques (Section 3.4) that can significantly limit their efficacy. Moreover, the two illustrations from our problem definition (Section 2.2) are examples of attack that can render some detection methods completely ineffective, which constitutes a research gap. It also shows the need to consider protection methods as a potentially more effective countermeasure.

3.5.1 Detection

The similarity techniques (Section 3.3.1) are not applicable if the legitimate counterpart is not present in the dataset. For the master data fraud illustration (Section 2.2.1), the company impersonated has a very low traffic and targets a niche sector, which means that the probability of being present in the dataset is near zero. For the fake webshop illustration (Section 2.2.2), the website is not a copy of a legitimate counterpart, which means that it cannot be detected by similarity. In other words, the similarity technique is not a scalable solution that can protect the entire Internet but only a subset of legitimate companies, primarily well-known.

The machine learning (Section 3.3.2) performance vastly depends on the selection of features. The model needs to be able to make a classification based on discriminant features. In the fake webshop illustration (Section 2.2.2) the website is built as a legitimate service and no discriminant features are extractable from the URL and the source code. By opposition, in the master data fraud illustration (Section 2.2.1), both the URL and the source code impersonates a legitimate brand. However, many evasion techniques (Section 3.4) can make it difficult to find features that are significantly different from the legitimate counterpart. Specifically, when there is no website associated with the domain name or when the website follows the same best practice as any other legitimate website in terms of branding, domain name and security aspects. Furthermore, even if some external data used as features can be effective, this information is commonly used as reinforcement for URL and source code features.

The list-based (Section 3.3.3) approaches have been identified as effective at raising suspicion, but need to be coupled with other methods for further refinement. This is because this approach only applies to websites that have been categorized as either phishing or legitimate. In the case our illustrations (Section 2.2), this approach will only be effective after a multistep process that can take time. First, a user or an automated agent needs to discover the website, then report it to the list manufacturer. Next, the report needs to be validated before being added and distributed to all other users.

In conclusion, we have identified two main research gaps of detection methods for domain name and website phishing attacks:

1. There is no clear technical distinction between what is considered trustworthy and what is considered phishing. The decision is subjective and varies based on the approaches.
2. Detection methods primarily focus on mass phishing where a well-known website is copied. These detection methods do not consider fabricated third party into the potential threads. Furthermore, they are not effective against malicious websites that are only used once or for specific targets, like in the case of spear phishing and whaling. Therefore, there is a need to develop a general approach that can also target these more sophisticated scenarios.

Based on those research gaps, we propose to refine the research question and focus on how to assess the trustworthiness of any website.

Research question 1 (RQ1): How to assess the trustworthiness of any website?

3.5.2 Protection

Combating phishing attacks happening on the Internet (RQ) using only reactive methods is a valid solution. However, the literature review has highlighted that it does not cover all the use cases due to the limitation of each method (Section 3.3) and evasion techniques (Section 3.4).

Furthermore, reports on the topic of phishing happening on the Internet (Section 2.1) showed that the problem is increasing over the years. But that some characteristics seem to impact the prevalence of attacks. For instance, new gTLDs, free ccTLDs and subdomain service providers are common exploited services. Moreover, reports have identified the domain name registration policies in Europe and the Asia-Pacific region to significantly affect the level of phishing in a TLD. Therefore, we propose to further investigate the more proactive methods employed to protect against domain name and website phishing attacks.

4 State of the ecosystem

This chapter focuses on the proactive methods employed to protect against domain name and website phishing attacks. At first, we will investigate the prevention measures implemented across the Internet ecosystem (Section 4.1). Then, we will evaluate the usability of their implementation (Section 4.2), which allows us to identify technical gaps (Section 4.3).

4.1 Prevention measure

In general, to prevent an individual from engaging in any illegal activities through an entity, this entity will first verify its identity. This helps protect the entity from malicious behavior and “hit-and-run” behavior, as the individual is accountable for the damage they could inflict.

In the case of domain names, implementing an identity verification process enables internet service providers and, in certain situations, law enforcement agencies to take down malicious activities. Furthermore, providing these verified information about the entity behind the website to the public allows a better accountability through transparency.

This approach is supported by multiple studies that reveal that criminals mask their true identity and hide their tracks before committing illegal activities. On a broader scale, the World Bank [44] has shown that, in the vast majority of the grand corruption cases analyzed, the complexity and inaccessibility of information about corporate entities is a key enabler of corruption, organized crime and money laundering. Furthermore, in the case of domain names, a study [45] found that when domain names are registered with the intent of engaging in illicit or malicious Internet activities, various tactics are employed to evade providing viable contact information.

In practice, when an identity verification occurs, it is typically conducted at either the top-level domain (Section 4.1.1) or the digital certificate level (Section 4.1.2). At the top-level domain level, the registrant's identity and contact information can be verified and made publicly available through WHOIS services. In contrast, at the digital certificate level, the certificate authority may conduct further investigations for the entity requesting a high-assurance certificate and embed the verified information into the certificate.

4.1.1 Top-level domain

During the domain lifecycle, registrant verification is conducted by either the registrar or reseller according to their contractual relationship with the registrant. Meanwhile, the verification process differs among top-level domains. The ccTLDs are subject to their

respective country's legislation, while gTLDs fall under ICANN's policies regulated in the United States. Upon completion, some data provided during this process becomes public through WHOIS services.

4.1.1.1 gTLD

In the case of gTLDs, most registrars are accredited by ICANN, which requires them to fulfill contractual obligations defined in the Registrar Accreditation Agreement [46]. At the time of registration, these registrars must collect all relevant information from the registrant, including name, organization, and postal address. However, to complete the registration process, they should verify that contact can be established through email or telephone, after which a confirmation is requested. Notably, during this verification step, neither the accuracy of the provided name nor the organization is verified.

Moreover, in the contract, ICANN defined two services that can alter the WHOIS data available to the public. First, privacy services offer the possibility to redact the names and replace the email addresses with more private ones. Second, proxy services are companies that register the domain on behalf of the registrant, resulting in the proxy company's information appearing in the WHOIS data instead of the registrant's.

WHOIS privacy service: Option to redact the names and replace the email addresses with more private ones in the publicly accessible WHOIS results.

WHOIS proxy service: Companies that register the domain on behalf of the registrant, resulting in the proxy company's information appearing in the WHOIS data instead of the registrant's.

4.1.1.2 ccTLD

Compared to gTLDs, ccTLDs are not subject to ICANN policies and contractual obligations. Each entity manages their registration policies, registrar accreditation, and WHOIS according to national legislation. But they work with ICANN to address technical problems that affect the global community, ensuring Internet security, stability, and operability.

For the scope of our research, we have chosen to concentrate our investigation on European ccTLDs as they are bound by legislation that also influence the broader global environment.

4.1.1.3 Europe

In terms of identity verification in European ccTLDs, the Council of European National Top-Level Domain Registries (CENTR) published a paper [1] which offers an overview of various approaches used across the European Union.

The 26 survey members report collecting at least the name, email, and country of the registrant (Figure 1). However, only around 50% reported performing data validation through syntax checks on the received registration data. Furthermore, only a limited number of registries proactively verify the data (Figure 2). Due to the cumbersome nature of the verification process, this is typically done on an ad-hoc basis (Figure 3). These checks are most commonly triggered by third-party complaints, change of registrar, failure of technical check and incomplete data. Overall, the most common methods of verification for legal entities involve looking up information in external registries and databases, whereas for natural persons, it relies on a scanned copy of a valid identity document (Figure 4).

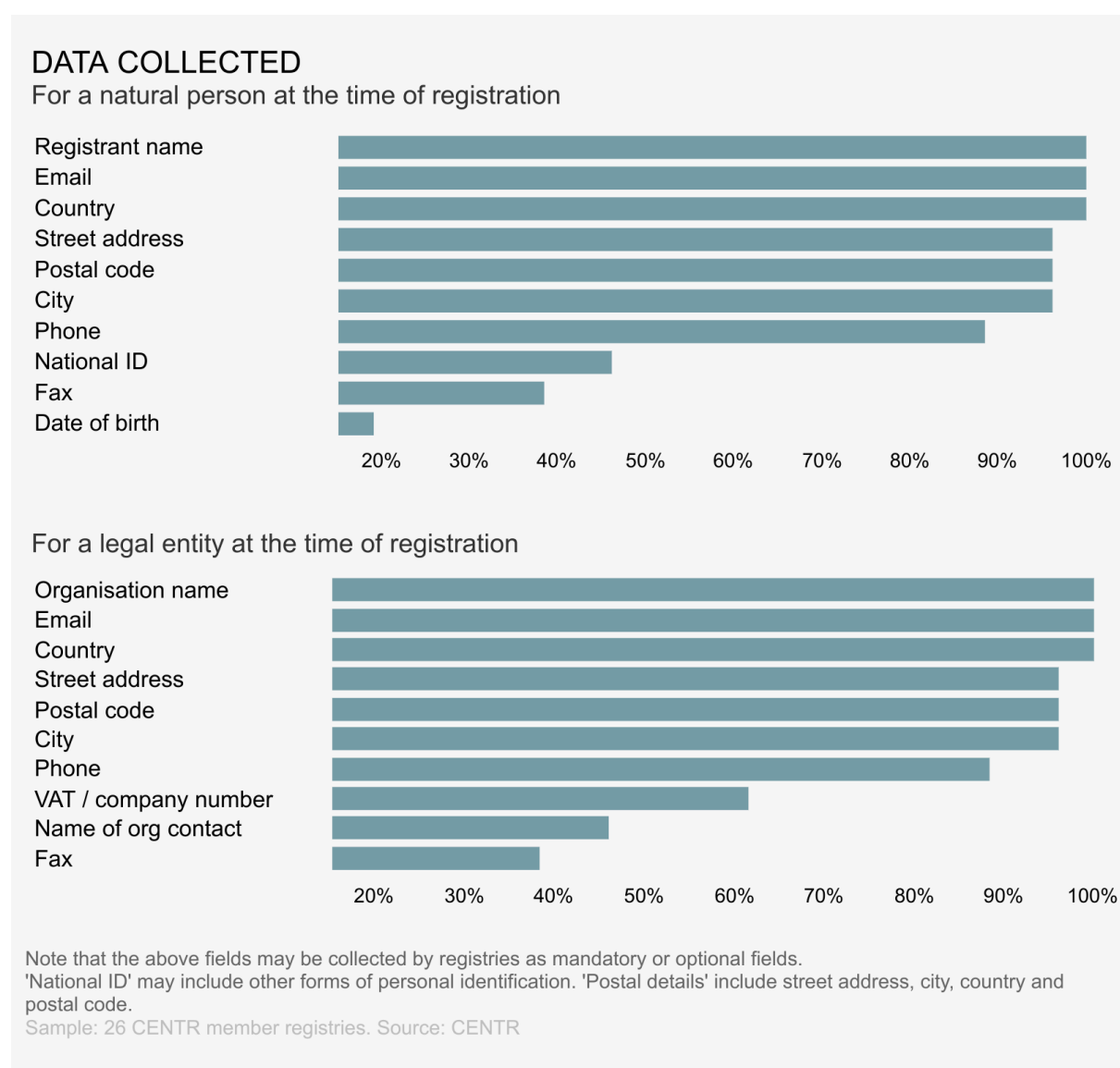


Figure 1: Contact data collected by EU ccTLD registries from [1].

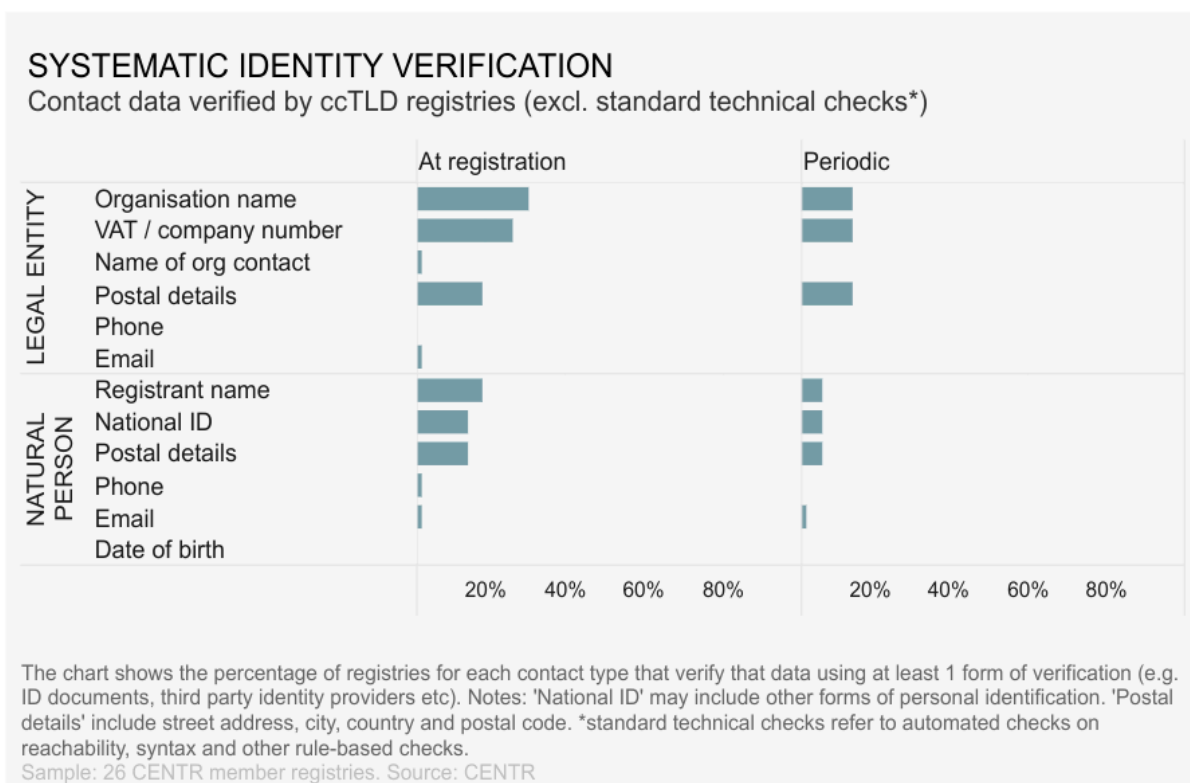


Figure 2: Contact data verified by EU ccTLD registries from [1].

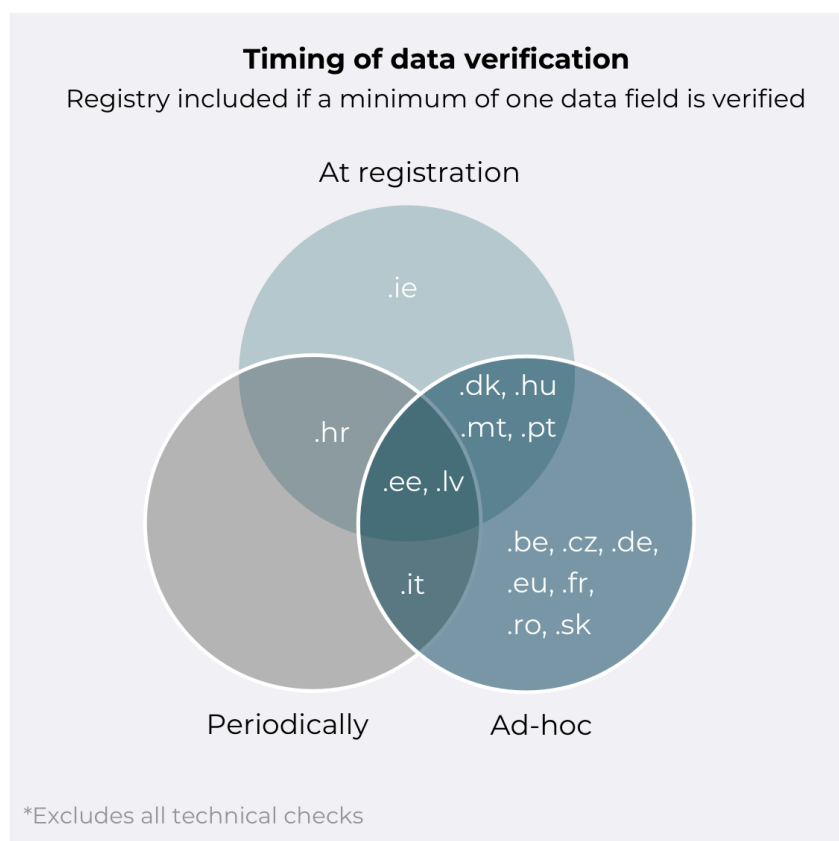


Figure 3: Timing of contact data verification by EU ccTLD registries from [1].

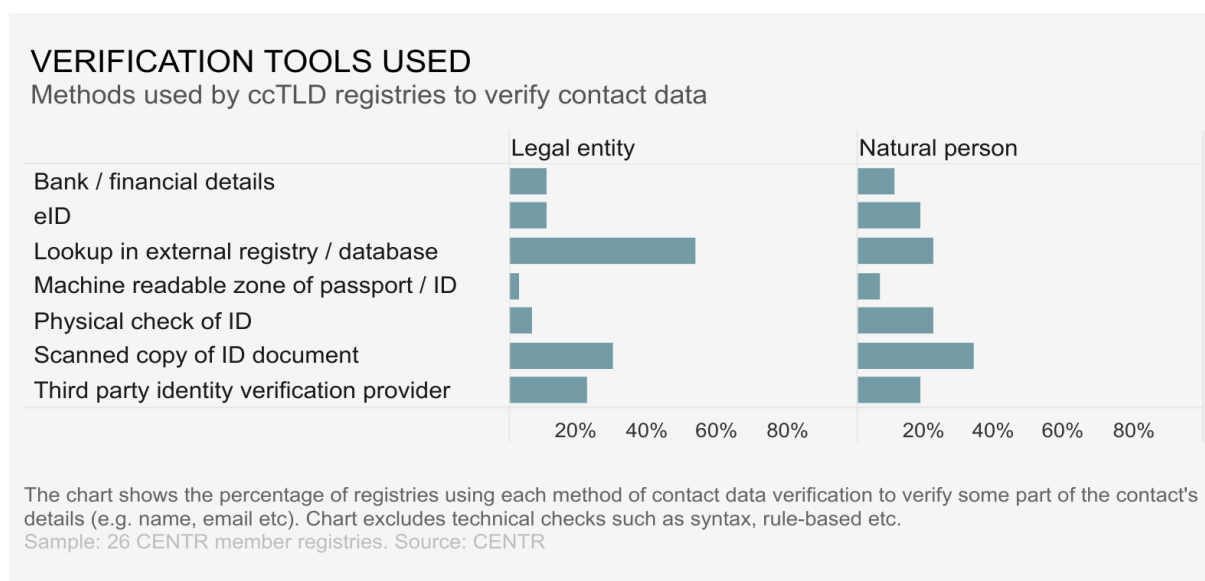


Figure 4: Methods used to verify contact data by EU ccTLD registries from [1].

4.1.2 Digital certificate

A digital certificate is an electronic document used to prove the identity of the website. These certificates can be used to encrypt the communication between the client and the server using the TLS protocol and cryptographic keys. Furthermore, these certificates can also contain additional information about the owner of the website after a thorough examination by traditional certificate authority (Section 4.1.2.1) or trust services in the context of the eIDAS regulation (Section 4.1.2.2).

4.1.2.1 Certificate authority

By default, certificate authorities always verify the domain ownership of the certificates they issue. In the majority of the cases, this is the only verification done and a Domain Validated (DV) certificate is issued. But certificate authorities also provide certificates with higher levels of verification. For natural person, Individual Validated (IV) certificate are issued after verifying the identity of the individual. In contrast, for legal persons, Organization Validated (OV) certificates are issued by validating the company information.

Domain Validated (DV) certificate: TLS certificate where the domain has been verified by the certificate authority.

Individual Validated (IV) certificate: TLS certificate where the domain and owner (individual) has been verified by the certificate authority.

Organization Validated (OV) certificate: TLS certificate where the domain and owner (organization) has been verified by the certificate authority.

Furthermore, to mitigate phishing attacks, certificate authorities have developed Extended Validation (EV) certificates, which involve a strict authentication procedure to formally identify the controlling entity and provide additional details such as business location or incorporation.

Extended Validation (EV) certificate: TLS certificate where the domain and owner (organization) has been verified by the certificate authority with a strict authentication procedure.

However, in practice, the high price of these EV certificates presents a major obstacle to their widespread adoption as an effective phishing countermeasure. A monitoring done by SSL Labs³⁴ analyzing 150,000 of the most popular websites revealed that in May 2024 only around 3.5% of these sites have EV certificates.

Additionally, in 2017, researchers demonstrated the limit of this method by obtaining multiple EV certificates for malicious use. In [47], the author registered a company named “Identity Verified” to deceive victims by displaying it as such in the URL bar of all major browsers. Similarly, in [48], the author successfully registered a company called “Stripe, Inc.” using the same name as the well-known brand. This was possible because the company was incorporated in Kentucky, rather than Delaware, where the real one is. Both attacks were effective due to the misleading user interface, which only displayed the company name and country in the URL bar.

Due to those limitations, Google made a study [49] to evaluate the positive impact of EV indicator. The conducted a large-scale field experiment through Google Chrome³⁵, analyzing users' behavior when the EV indicator was present or absent from the URL bar. However, they were unable to find evidence of significant improvements. Based on this research, Google Chrome decided in 2018 to remove the EV indicator from the URL bar and move it to the page info³⁶. Following that, Safari³⁷ and Firefox³⁸ also moved the EV indicator out of the prominent user interface.

4.1.2.2 eIDAS regulation

The objective of the regulation on electronic identification and trust services [6] and its amendment [7] is to facilitate secure cross-border transactions and mutual recognition

³⁴<https://www.ssllabs.com/ssl-pulse/>

³⁵<https://www.google.com/chrome/>

³⁶<https://chromium.googlesource.com/chromium/src/+HEAD/docs/security/ev-to-page-info.md>

³⁷<https://cabforum.org/2018/06/06/minutes-of-the-f2f-44-meeting-in-london-england-6-7-june-2018/#apple-root-program-update>

³⁸https://groups.google.com/g/firefox-dev/c/6wAg_PpnIY4/

of digital identification. It also introduces trust services in charge of managing electronic signature, seals, timestamp, and certificates [7, Article 3 (16)]. The regulation is intended to be applied as such by all members of the Union. Therefore, the technical implementation is managed on the European Union level.

More precisely, the regulation introduces a trust service for website authentication. These entities deliver electronic attestation that makes it possible to authenticate a website and links the website to the natural or legal person to whom the certificate is issued [7, Article 3 (38)]. This system intent to provide a high level of confidence in the identity of the owner of a website that chooses to participate, and it should contribute to the building of trust [7, Recital 65].

In detail, a qualified trust service provider can issue a Qualified Certificate for Website Authentication (QWAC) if he meets the certain requirements [7, Article 45 (1)]. More precisely, the certificate should contain the domain name(s) operated by the natural or legal person to whom the certificate is issued [6, Annex IV (e)]. For a natural person, the certificate should contain at least the name or a pseudonym [7, Annex IV (c)]. If a pseudonym is used, it shall be clearly indicated. For legal persons, the certificate should contain a unique set of data unambiguously representing the legal person [7, Annex IV (c)]. This should at least contain the name and where applicable the registration number as stated in the official records.

Qualified Certificate for Website Authentication (QWAC): Digital certificate for a natural or legal person within the scope of the eIDAS regulation.

In terms of objective and implementation, QWAC is very similar to EV certificates.. Nevertheless, QWAC brings added value inherent to the requirements of the regulation which imposes risk management, strict security obligations and a clear liability for the qualified trust service provider. Furthermore, there are legal obligations regarding the proper identification of the person requiring the certificate and a supervision model that ensures the proper implementation of the requirements by qualified trust service providers³⁹.

4.2 Usability

This section focuses on the factors impacting the usability of the prevention measure investigated in a previous section (Section 4.1). We will explore the impact of European legislation on the data available through WHOIS services (Section 4.2.1). As well as the research conducted to assess and improve the usability of browser security indicators (Section 4.2.2) and QWACs (Section 4.2.3).

³⁹<https://digital-strategy.ec.europa.eu/en/news/questions-answers-trust-services-under-eidas/>

4.2.1 WHOIS

The WHOIS service has been developed as a “white page” where Internet users can get information about domain names. However, with the introduction of the European GDPR regulations, certain information may now be required to be redacted (Section 4.2.1.1). Nonetheless, the European NIS 2 directive has for intent to improve the cybersecurity across the European Union by imposing that the identity and contact information in the WHOIS are available, complete, and accurate under certain conditions (Section 4.2.1.2).

4.2.1.1 GDPR

With the implementation of the GDPR in 2018, ICANN has updated its contact with all gTLD registry and ICANN accredited registrars. They introduced a temporary specification [50] that supersedes the Registrar Accreditation Agreement presented in a previous section (Section 4.1.1.1). More precisely, the specification states that personal information regarding a natural person subject to the GDPR such as the registrant name, address, and contact information must be redacted unless the registrant has given their consent.

4.2.1.1.1 Issues of the temporary specification

Research suggests that most registry and registrars are not equipped to make the distinction between legal and natural entities. A study made by ICANN [51], reported that numerous registries and registrar operating outside the framework of the GDPR said they did not differentiate, simply because no law or policy required them to do so. In contrast, another work [52] made by ICANN, reviewed the 33 European ccTLDs and 21 appear to utilize a form of differentiation.

Moreover, registrar are businesses that continuously need to renew their customer base. This at least occurs annually when the registrar has to contact the registrant to renew its domain name. Due to the ease with which customers can switch providers, the user base with contact information is a critical data for the business. For these reasons, these commercial entities often choose not to publicly disclose information about their customers through WHOIS services. This behavior led the ecosystem to shift into using WHOIS privacy and proxy services by default. For example, GoDaddy⁴⁰, NameCheap⁴¹ and Squarespace⁴² now offer proxy services by default and without additional cost.

To summarize, following the simplistic implementation of the GDPR by registry and registrar and their business incentives, not only European data subjects' data are now redacted, but also data belonging to non-EU citizens. As well as data belonging to commercial entities, which are not in the scope of the GDPR.

⁴⁰<https://aboutus.godaddy.net/newsroom/company-news/news-details/2022/GoDaddy-Domains-Now-Include-Stronger-Privacy-Protection/default.aspx>

⁴¹<https://www.namecheap.com/security/domain-privacy-service/>

⁴²<https://support.squarespace.com/hc/en-us/articles/205812438-Whois-privacy/>

The impact of these modifications has been further investigated in [53] by the Messaging, Malware and Mobile Anti-Abuse Working Group (M3AAWG) and the Anti-Phishing Working Group (APWG). The survey concentrated on cybersecurity practitioners, which include personnel responsible for maintaining protective services and products, personnel responsible for directly defending the network of their employers, and academic researchers. The findings reveal that the WHOIS has become an unreliable and less meaningful source of threat intelligence. As a result, the researchers encouraged ICANN to provide access to relevant information about the legal persons while protecting natural persons' privacy, and to deploy a system where lawful request could be treated following GDPR legislation.

4.2.1.1.2 Recommendation

ICANN responded to these issues by implementing an Expedited Policy Development Process (EPDP) on the Temporary Specification for gTLD Registration Data⁴³. The process is led by the Generic Names Supporting Organization (GNSO) Council, who propose a set of recommendations to be voted by the ICANN board before being implemented.

Phase 1

The first phase submitted two recommendations worth mentioning. First, they suggested that the organization field in WHOIS will be published if the registrant gives consent and be redacted or deleted otherwise [54, Recommendation #12]. This was only partially approved by the ICANN board because of the issues related to deleting information. Second, they recommend that registrars and registries are permitted to differentiate between registrations of legal and natural persons, but are not obligated to do so [54, Recommendation #17]. This was approved as such by the ICANN Board.

Phase 2

The second phase primarily focused on the design of a System for Standardized Access/Disclosure of Non-Public Registration Data (SSAD) [55]. The objective is to provide a predictable, transparent, efficient, and accountable mechanism for the access and disclosure of non-public registration data. Both a centralized and decentralized model were considered, but neither was significantly better. As a result, a hybrid model was proposed where requests would be centralized and disclosure decision would typically be made by contracted parties. This model offers the benefits of being a single location with standardized request, review, and response while offering a built-in authentication process.

Phase 2A

An extension to the second phase focused specifically on the issues of the distinction between legal and natural person. They recommended creating one or more fields in the

⁴³<https://icann-community.atlassian.net/wiki/spaces/EOTSFGRD/>

WHOIS database [56, Recommendation #1]. These fields should be added to specify the legal status of the registrant as either a legal person or a natural person. Furthermore, these fields should be used to indicate whether any registration data contains personal information.

4.2.1.1.3 Implementation of the recommendations

The recommendations from the first phase (Phase 1) were implemented in the Registration Data Policy [57]. More specifically, it stated that the registrar must provide the opportunity for the registrant to specify his organization and that if the registrant agrees to its publication, the registrar must publish it. However, if the registrant does not agree to its publication, the registrar may redact the registrant organization value in the WHOIS response but is not forced to. Furthermore, it stated that registry and registrars may consider whether registration data belongs to a legal person or contains personal data, but are not required to.

The SSAD from the second phase (Phase 2) is implemented as the Registration Data Request Service (RDRS)⁴⁴. The RDRS is a proof of concept for a ticketing system that handles requests for access to nonpublic registration data related to gTLDs. The service is intended for consumer protection advocates, cybersecurity specialists, government officials, intellectual property professionals, law enforcement personnel, ICANN community members and others with a legitimate interest⁴⁵.

Registration Data Request Service (RDRS): ICANN's proof of concept for a ticketing system that handles requests for access to nonpublic registration data related to gTLDs.

However, due to strict requirements, the service has denied around 66% of the 2081 closed requests since its launch in November 2023 [58]. As a result, the efficacy of such a system is still under active evaluation.

The recommendations from the extension of the second phase (Phase 2A) are still discussed as of 2025. However, the implementation of the NIS 2 directive and the geopolitical landscape might significantly influence the discussion.

4.2.1.2 NIS 2 directive

The directive on Security of Network and Information Systems (NIS) has for objective to improve the cybersecurity posture of the most important European infrastructure. Because it is a directive, the obligation needs to be transposed into national law before being applicable. Which means that implementation can differ across countries.

Since the second version [5], the scope of essential service has been extended to all top-level domain name registries, as well as DNS service providers [5, Article 3 (b)].

⁴⁴<https://rdrs.icann.org/>

⁴⁵<https://www.icann.org/rdrs-en/>

Furthermore, the importance of having access to domain name registration data to a legitimate access seeker has been acknowledged as essential for the prevention and combat of DNS abuse and the detection and response to incidents [5, Recital 110].

4.2.1.2.1 Obligation

The directive is applicable to DNS service providers, TLD name registries and entities providing domain name registration services established or offering services within the European Union [5, Article 26]. The Member States are enforcing six major requirements to these services on the subject of the database of domain name registration data [5, Article 28].

In the first paragraph [5, Article 28 (1)], TLD name registries and entities providing domain name registration services are required to maintain accurate and complete domain name registration data in a dedicated database. They should also treat these data with due diligence, following data protection law.

In the second paragraph [5, Article 28 (2)], the database of domain name registration data is required to contain the necessary information to identify and contact the holders of the domain name. Such information shall include the domain name, the date of registration, the registrant name and contact information. Furthermore, if the registrant does not administer the domain name itself, the contact information of the point of contact responsible for the administration should also be present.

However, the fourth paragraph [5, Article 28 (4)] only requires TLD name registries and entities providing domain name registration services to make publicly available the domain name registration data who is not personal data. Moreover, this should be done without undue delay after the registration of a domain name.

In the third paragraph [5, Article 28 (3)], TLD name registries and entities providing domain name registration services are required to have policies and procedures to ensure the accurate and complete information of domain name registration data. This should include verification procedures. Furthermore, these policies and procedure shall be made publicly available.

In the fifth paragraph [5, Article 28 (5)], TLD name registries and entities providing domain name registration services are required to provide access to specific domain name data to the legitimate access seeker. However, the request should be lawful and duly substantiated. Furthermore, if the data requested contains personal information, the process should be done in accordance with data protection law.

In the last paragraph [5, Article 28 (6)], TLD name registries and entities providing domain name registration services are required to cooperate with each other to prevent the duplication of domain name registration data.

4.2.1.2.2 Identity verification

As mentioned in the third paragraph of the article 28 [5, Article 28 (3)], procedures should be put in place to verify domain name registration data. However the binding part of the directive does not give a clear explanation on how the verification should be done.

Nevertheless, contextual information and implementation advice are given in the recital 111 [5, Recital 111]. It is explained that the TLD name registries and the entities providing domain name registration services are expected to adopt and implement proportionate verification procedures that align with industry best practices. And whether possible, follow the progress made in the field of electronic identification. Furthermore, it is recommended that at least one means of contact has to be verified.

In other words, this means that the intended implementation is aligned with the risk-based approach already adopted by some European ccTLDs as explored in a previous section (Section 4.1.1.2). Therefore, the impact of the directive on European ccTLD will only be to standardize this practice and provide incentive to adopt electronic identification procedures. For example, it would push forward the advancements done in eIDAS to solve the issue of identification across European border.

4.2.1.2.3 Legal vs. natural person

The second paragraph of the article 28 [5, Article 28 (2)] states that the domain name registration data must contain the registrant name. And the fourth paragraph [5, Article 28 (4)] states that this information must be public if it is not a personal data. This obligation highlights the need to distinguish between legal and natural person, as discussed in a previous section (Section 4.2.1.1.1).

In practice, the recital 112 [5, Recital 112] provides insight about which data should be publicly available and under which conditions for both legal and natural person.

For legal persons, the TLD name registries and the entities providing domain name registration services should make publicly available at least the name and telephone number of the registrant. In this context, the registrant name refers to the name of the organization. Which means that in the WHOIS, it will force the organization field to be always publicly available and complete when it refers to a legal person. Furthermore, the email address should be published if it does not contain any personal data, such as in the case of email aliases or functional accounts.

For natural person, any personal data should be redacted under the GDPR. However, following the obligation from the fifth paragraph [5, Article 28 (5)], the recital precise that personal and non-personal registration data should be disclosed without undue delay to legitimate access seeker. And that it could be done through any tool that could implement policies and procedures following the guidance and standard developed by the multi-stakeholder governance structure at international level. In other words, the RDRS or a similar tool will probably be used to this extent.

4.2.1.2.4 Databases

From the first paragraph of the article 28 [5, Article 28 (1)], we know that the domain name registration data will be accurate, complete and stored in a dedicated database. However, the obligation does not give more details on how it should be implemented following the technical protocol already in place. Nevertheless, the recital 109 [5, Recital 109] gives direction by mentioning that the accurate and complete database of domain name registration data is referred as WHOIS data. In short, we can fairly assume that WHOIS services are the intended implementation.

Yet, the sixth paragraph of the article 28 [5, Article 28 (6)] requires the TLD name registries and entities providing domain name registration services to cooperate with each other to prevent the duplication of domain name registration data. This is incompatible with the current architecture of WHOIS, which is designed as a set of independently operated and distributed databases that are responsible for their portion of the Internet's identifiers. In practice, each database is managed by either a registrar or a registry. This means that the directive will force European registrars and registries to maintain a unique set of registrant's information. It will be a challenge when the registrant has registration across different country. Nonetheless, this issue is intended to be resolved in Europe by the eIDAS European identity proposition.

4.2.2 Browser indicator

Because we focus on phishing that operates through domain names, browsers which resolve the domain name and render the page are of importance. At first, connection security indicators were used to indicate to the user that a website is safe. But with the growth of deceptive websites, there has been a need to also use identity indicators to help the user evaluate the trustworthiness of the website.

4.2.2.1 Connection security

To rethink the connection security indicators in Chrome⁴⁶, Google made a study [59]. The researchers focused on improving indicators that teach people that HTTP is less secure than HTTPS. This proposition was later implemented with Chrome 53 by displaying "Secure" with a green padlock for valid HTTPS, "Not secure" with a red triangle for invalid HTTPS and only "Not secure" in gray for HTTP. However, their analysis also suggested that the indicator for valid HTTPS was broadly perceived as an overall security indicator, not specifically as a connection security indicator. To prevent this side effect, Google followed the global adoption of HTTPS⁴⁷ and when the proportion was significant enough, they took progressive step to definitely mark HTTP as "Not secure" and remove secure indicators for HTTPS that were misleading⁴⁸.

⁴⁶<https://www.google.com/chrome/>

⁴⁷<https://transparencyreport.google.com/https/overview/>

⁴⁸<https://www.chromium.org/Home/chromium-security/marking-http-as-non-secure/>

4.2.2.2 Identity

In their research about EV certificates [49], Google also examined other identity indicators present in the user interface. Using a large-scale field experiment, they analyzed the variation of URL highlighting and discovered that none of the configuration makes users uncomfortable to logging in to a phishing website. They concluded that both EV and URL identity indicator are ineffective, which corroborates the findings from the prior studies exposed in their paper.

Nevertheless, from their experimental results and review of prior work, the researchers recommend to focus on negative indicators because users do not react as intended to positive or neutral security indicators. Furthermore, researchers also recommended the security community to focus on triggering active warning when the identity of the website is suspicious.

4.2.3 QWAC

Seven years after their first definition in eIDAS in 2014, QWAC usage remains very low. Therefore, to increase their adoption, the European Commission has proposed an amendment in 2021 [7]. The new proposed paragraph states that providers of web-browser shall recognize and ensure support and interoperability with QWAC [7, Article 45 (1a)]. Furthermore, the identity data and other attributes be displayed in a user-friendly manner. However, many stakeholders have raised concerns about binding QWAC with TLS (Section 4.2.3.1), validating with a third-party (Section 4.2.3.2) and imposing visual differentiation in the user interface (Section 4.2.3.3).

4.2.3.1 TLS binding

According to Mozilla [60] and Internet Society [61], cryptographically bind a QWAC with a TLS certificate could dramatically weaken web security and privacy as well as going against the principle of voluntary collaboration, technical neutrality and interoperability.

Technically, using a QWAC as a TLS certificate means that web-browsers need to add Trust Service Provider (TSP) from eIDAS to the list of trusted root. This could break the security and privacy of TLS when an incorrect or insecure certificate is issued because a malicious actor could intercept and manipulate the content of any request by performing a spoofing or Man-in-the-Middle attacks. Furthermore, the framework created by eIDAS for TSP is less favorable than the best practices of website authentication that have been created by consensus and required to be included in the root certificate authority store of web-browser like Mozilla Firefox⁴⁹.

Moreover, adding TPS to the web-browser trusted root list violates the concept of voluntary collaboration and the recital 67 [6, Recital 67] which mentions that other means or methods to authenticate a website should not be impeded. Furthermore, mandating that QWAC are bound to a TLS certificate also goes against the recital 27

⁴⁹<https://www.mozilla.org/firefox/>

[6, Recital 27] that specifies that the regulation should be technology-neutral and the recital 72 [6, Recital 72] that specifies that the implementation should be interoperable with existing standards and technical specification.

After two years of discussion, the Parliament has taken notice of the issues and voted to adopt new safeguards [7, Recital 65]. It clarifies that the recognition of QWAC only affects the purpose of attesting the link between the domain name and the natural or legal person that owns it. The implementation by web-browsers should not impact the web security, domain authentication and encryption of web traffic, and they are given the freedom to choose the most appropriate technology.

As a technical solution, Mozilla and other browsers have proposed a alternative to TLS binding called nt-QWAC where the QWAC certificate is separate from the TLS certificate [60]. This non-TLS version of QWAC was implemented by the European Commission in a pilot [62] as an X.509 attribute certificate [63] cryptographically linked to a TLS certificate. This version offers the possibility to store attributes like the purpose of the website and a reference to a GDPR compliance attestation.

4.2.3.2 Validation

According to Mozilla [60] and Internet Society [61], validating QWAC with a remote third-party service introduces new threats.

In terms of security, the implementation of a new protocol to validate QWAC certificate will increase the attack surface due to added complexity and can create new opportunities for man in the middle attacks. Furthermore, an external validation serves no security purpose. A third-party validation could only prove that the certificate is valid in the context of the validation service TLS connection and not in the context of the user's connection.

In terms of privacy, an external validation service will be able to collect sensitive information on its user's browsing activity. Moreover, such a service could be able to group multiple request to the same user and make accurate profiling.

4.2.3.3 Visual differentiation

The proposition of displaying QWAC certificate in a user-friendly manner could be interpreted as a requirement to differentiate those certificates from others. However, as already explored in a previous section (Section 4.2.2), special certificate displays in the prominent user interface do not have the intended impact.

4.3 Technical gap

This chapter had for objective to review the proactive methods employed to protect against domain name and website phishing attacks. Our exploration suggests that the most common prevention measures implemented by the Internet ecosystem is to

verify the owner's identity and show this information to the users. However, both the identity verification (Section 4.3.1) and transparency (Section 4.3.2) aspects suffer from limitations that impact their ability to effectively protect against domain name and website phishing attacks.

4.3.1 Identity verification

The identity verification is not common between gTLDs because the process is expensive and there is no legal incentive (Section 4.1.1.1). Unlike the European ccTLDs where this practice is now mandatory due to the NIS 2 regulation (Section 4.2.1.2). Despite this, the regulation recognizes that the verification process can be expensive and adopts a risk-based approach to focus on the most suspicious registration (Section 4.2.1.2.2). However, this is only a valid proposition from the point of view of the regulator and the ccTLDs. From the user perspective, the risk may not be the same. This is the case for spear phishing and whaling, where only the target is at risk.

By comparison, digital certificate propose a more universal approach that does not involve biased risk evaluation (Section 4.1.2). However, this proposition does not solve the problem of the high cost of the verification process. This is the main reason why high assurance certificates are only used by big corporations and highly sensitive and regulated industries.

In conclusion, no effective solution has been found in terms of cost and, by extension, availability. This indicates that the research should focus on more scalable methods to circumvent this limitation.

4.3.2 Transparency

For TLDs, the transparency is done through the WHOIS who display the registration information. But most information is not always available because of the use of privacy or proxy services. Moreover, the GDPR require the redaction of personal information (Section 4.2.1.1). Even if RDRS allows accessing those data, it is only available for very specific use cases. The issue of the redaction of information of public interest like the company of the registrant is currently being treated by ICANN (Section 4.2.1.1.3), who propose new fields in the WHOIS to deliver these valuable information without redaction (Section 4.2.1.1.2). However, the accuracy of the data is still a major concern.

The NIS 2 directive tries to solve the issue of data accuracy by imposing verification procedures for the registration information (Section 4.2.1.2). But acknowledges that systematic verification is not viable and recommends a risk-based approach where only the most suspicious registration need to be validated (Section 4.2.1.2.2). Added to the fact that domain registration data is not necessary for the technical and security aspect of the DNS, actors outside the scope of NIS 2 could stop collecting registration data because they are not forced to.

By comparison, digital certificates do not have the problem of accuracy because each attribute present in the certificate has been verified by the issuer (Section 4.1.2). Nevertheless, EV certificates have been proven to be vulnerable to attacks using deceptive and colliding entity names, largely due to the misleading user interface (Section 4.1.2.1). This issue was investigated, but research on EV indicator in browser interface has not found effective ways to display the data to have the intended result (Section 4.2.2.2). By comparison, QWAC also suffers from the issue of visual differentiation but also introduces privacy and security issues due to remote validation and is only applicable in Europe (Section 4.2.3).

In conclusion, there is a need to have a more scalable way to prove the trustworthiness of a website, whether it is through the owner identity or other methods.

Research question 2 (RQ2): How to prove the trustworthiness of any website?

5 Requirement

In this chapter, we will establish the requirements needed to answer the research question of how to assess the trustworthiness of any website (RQ1) and how to prove the trustworthiness of any website (RQ2). First, by adapting existing concepts around trust that can be used for the assessment (Section 5.1). Second, by analyzing the existing approaches to identity the expected requirements of a better system of proof (Section 5.2).

5.1 Assessment

In this section, we will establish the requirements of a proposition that can answer the question of how to assess the trustworthiness of any website (RQ1). To achieve this, we have decided to return to the foundations of what trust in an online environment means. More precisely, we will rely on pioneer work done in [64] who identified the principles that enable trust in an online environment. We will use these principles as our main requirements (Section 5.1.1).

Since this paper was published in 2002, we will also consider more recent studies that have supplemented these principles over time. In particular, the paper [18] from where the definition of trust introduced in a previous section (Section 3.1.1) was borrowed from. Indeed, this paper also conducted a comprehensive review of the existing literature to extract fundamental trust principles and proposed addition principles that are of interest for our research. Therefore, we will use some of them as additional principles (Section 5.1.2).

Finally, we will explore all the solutions already presented and highlight which trust principle they satisfy (Section 5.1.3). This will also help identify the gaps that are still present and how certain solution already solve certain trust principle.

5.1.1 Base principle

In this section, we draw inspiration from the research presented in [64]. We will adapt the principles outlined in the study to suit our specific research.

5.1.1.1 Trust depends on identity

To effectively record the history of interactions with an entity over time, a unique identifier is required. This unique identifier serves as a consistent reference point, allowing us to link various interactions to the same entity. While this token can be linked to an offline identity, its constancy is the primary requirement for maintaining an accurate and comprehensive record of interactions.

When designing online trust infrastructure, it is important to find a balance between anonymity and transparency. Anonymity allows entities to control their shared information, providing them with autonomy. On the other hand, transparency creates an environment where trust can thrive by enabling accountability.

5.1.1.2 Trust is a function of the perception of risk

When faced with an uncertain event in which the expected loss can be greater than the expected gain, people need to make a non-rational choice based on trust. Therefore, risk is the core of trust. This risk incentive is also highlighted in our definition of trust (Section 3.1.1). More specifically, by the notion of the lack of the ability to monitor or control the trustee.

5.1.1.3 Trust is a matter of degree

Another way to define trust is as the degree to which the truster holds a positive attitude toward the trustee's goodwill and reliability in a risky exchange situation. This new formulation shows how trust is granular and that trusters need to be able to customize how much they value different aspects of trust. Furthermore, the degree is something personal and will depend on the situation and the person or the group of people that will assess the trust.

5.1.1.4 Culture affects trust

The decision of whom to trust is largely based on an individual's values and social norms. But more importantly, these two factors are influenced by the sociological focus of the country in which the individual has been educated. The population's mentality can be characterized as either individualistic or collectivistic. In individualistic cultures, there is a greater emphasis on personal autonomy, self-expression, and achievement, whereas in collectivistic cultures, group harmony, interdependence, and social cohesion take precedence. In terms of trust, individualistic culture tends to be more characteristic-based and give any entity the same assumptions. On the other hand, collectivist culture tends to be more institutional-based and give the entity representing the authority more trust.

5.1.1.5 Trust deepens over time

People do not give their trust blindly because it will represent an unjustified risk. Instead, trust is developed as a gradual process that starts with a low-risk exchange. Then, if the other party meet the expectations, the individual can incrementally increase his investment. This allows to progressively move to greater levels of risk. Over time, the fulfillment of small commitments will add up and individuals will be more likely to trust the other party.

5.1.1.6 Trust is based on information

In order for a user to trust a company website or another individual, he first needs to “get to know them”. For that to happen, the other party needs to share information about himself. This is particularly true for online environments because they necessitate more information to establish trust compared to an offline environment. Indeed, in an offline setup, the physical interaction through visual and verbal interaction are powerful trust-building mechanisms. By comparison, online environments need to rely on other dimensions.

5.1.1.7 First party information is important in developing trust

First party information refers to data that is communicated directly by the source. In our case, this information is provided by the owner of the website and will contain information about himself and its business. More specifically, information about the service, the policies, and the products.

Moreover, in the case of websites that target an audience from different cultural or geographical backgrounds, it becomes especially crucial for users to have access to this information to validate their expectation.

5.1.1.8 Second party opinions are important in developing trust

Second party information is information about others' experience with the same website and their feedback. When aggregated, it is used to build a reputation system that tracks the historical interactions between users and a given website. This kind of information is generally unstructured and potentially unreliable because the source can be unknown or anonymous. Because of this, information of this type is viewed more as an opinion and is given less weight when determining trust than information from verified first parties.

5.1.1.9 Third-party ratings are important in developing trust

Third-party rating are opinions from experts. These experts are trusted third parties that formalize and amplify the reputation of websites. It can be in the form of seals of approval that act as a proof that the website is following a set of rules established by the authority delivering the certification.

Moreover, these third-party ratings are particularly important in an online environment because, compared to an offline environment, a website tends to lack the same visual and social clues available in the physical world.

5.1.1.10 Formal controls are important in developing trust

Formal controls use codified rules, goals, procedures and regulations to define what is the expected behavior. They also define what are the consequences, in terms of penalties and sanctions, for the company when it does not conform.

5.1.1.10 Formal controls are important in developing trust

To be efficient, formal controls have to be tracked over time and provided in a record history to be used to evaluate future behavior based on past behavior.

5.1.1.11 Social controls are important in developing trust

Social controls are organizational and cultural values and norms used to encourage a desirable behavior. They are present in the context of community and organization, where people need to deal with each other.

To be efficient, social controls have to be tracked over time and provided in a record history to be used to evaluate future behavior based on past behavior.

5.1.2 Additional principle

In this section, we will explore the most relevant principle outlined in [18] that are not covered in the previous section (Section 5.1.1). We will interpret these additional principles through the lens of our research.

5.1.2.1 Security

Security is essential to protect the information that will be transferred between the user and the website. More precisely, the integrity of the information. Without it, the user would not be able to trust that their data has not been tampered with by a bad actor.

Moreover, in the case the involves sensitive data, the confidentiality must also be guaranteed. Otherwise, anybody monitoring the communication could retrieve them with ease.

5.1.3 Applicable solution

In this section, we will explore the detection (Section 5.1.3.1) and protection (Section 5.1.3.2) approaches and for each of them we will evaluate which base trust principle (Section 5.1.1) they satisfy. Once done, we will be able to evaluate the overall coverage (Section 5.1.3.3).

Meanwhile, we can already note that every solution makes use of domain names or URLs to identify and track a potentially malicious website or webpage. Therefore, all of these solutions satisfy the principle of identity (Section 5.1.1.1).

5.1.3.1 Detection

In this section, we will explore the different applicable approaches introduced in the literature review (Section 3). This means that we will exclude similarity detection, as this method has already been proven inadequate to the research at hand (Section 3.5.1).

Machine learning features

Machine learning features (Section 3.3.2.1) are composed of the URL, source code, communication and external services. Both URL and source code are based on

properties directly provided by the website. Therefore, they satisfy the principle of first party information (Section 5.1.1.7). Moreover, the communication features are based on properties from the HTTP response and the TLS certificate. In the case of the HTTP response, the information coming directly from the server. Therefore, it also satisfies the principle of first party information (Section 5.1.1.7). By comparison, the TLS information comes from the owner but has been verified by a third party, which is also the case for external services features. Therefore, they satisfy the principle of third-party ratings (Section 5.1.1.9). Furthermore, external services that act as reputation system apply a set of rules that satisfy the principle of formal (Section 5.1.1.10) and social (Section 5.1.1.11) controls.

Machine learning models

Machine learning models (Section 3.3.2.3) are classification algorithms that separate malicious from legitimate websites. Generally, such models produce a binary output, but a linear model can also be used by making the classification based on a threshold. In this case, the output number represents the risk of a website being malicious. This illustrates that some machine learning models satisfy the principle of risk (Section 5.1.1.2) and the principle of degree (Section 5.1.1.3). However, the risk and the degree is only from the model's perspective.

List

Blacklist is an aggregation of third party reported of malicious websites, whereas whitelist are typically based on the popularity of the website. In either case, the information is coming from third-parties, which satisfies the principle of third-party rating (Section 5.1.1.9).

5.1.3.2 Protection

In this section, we will explore the different approaches introduced in the state of the ecosystem chapter (Section 4).

Identity verification

The process of identity verification used by some TLDs and certificate authorities apply a set of formal and social rules. Therefore, it satisfies the principle of formal and social controls (Principle 10, Principle 11). Yet, the identity verification is not a widely developed practice. Only ccTLD verifies the owner's identity based on the risk evaluated by the registrar, which means it satisfies the principle of risk (Principle 2). However, the risk is from the registrar perspective.

Transparency

The transparency of information satisfies by definition the principle of information (Section 5.1.1.6) whether it is through the WHOIS or digital certificates attributes. Furthermore, the information transmitted through digital certificates can come from the owner directly or being added by the certificate authority, which satisfies both

the principle of first party information (Section 5.1.1.7) and third-party ratings (Section 5.1.1.9).

5.1.3.3 Coverage

From the two previous sections about detection (Section 5.1.3.1) and protection (Section 5.1.3.2), we can conclude that no approaches address all the base trust principle (Section 5.1.1).

Moreover, the principle of risk (Section 5.1.1.2), degree (Section 5.1.1.3), culture (Section 5.1.1.4) and time (Section 5.1.1.5), are heavily dependent on the user's perspective. A technical solution that does not involve humans can at best only assess the trustworthiness from the perspective of the solution, but never from the intended user.

5.2 Proof

In this section, we will establish the requirements of a proposition that can answer how to prove the trustworthiness of any website (RQ2). To make an exhaustive list of requirements, we will analyze why every other solution could not meet the expectations. In particular, we will explore the typical ways used to share information about the owner of a website, introduced in the previous chapter (Section 4).

5.2.1 WHOIS

The WHOIS is by far the most popular website owner's information sharing system. But to be scalable to this level, it cannot force the verification of the information transmitted. Even in the case of NIS 2 where this process is mandatory, the verification only happens on a risk basis (Section 4.2.1.2). Therefore, our solution should **be scalable while enabling verification**.

However, the WHOIS information accuracy can be impacted by employing privacy and proxy services. This behavior has become more common since the introduction of the GDPR and the transition to proxy by default by industry leader registrar (Section 4.2.1.1.1). As a result, the valuable WHOIS information is not as available as before, which weakens its relevance. Therefore, our solution should **enable the global availability of valuable information**.

To this problem, the RDRS has been proposed by ICANN. However, due to regulation restriction, the system needs to manually treat the requests. This allows the administrator to verify that the request is lawful. Therefore, only very specific individuals have their request approved. Moreover, the overall process is very slow. Consequently, it highlights that our solution should **deliver data quasi instantaneously and to everyone**.

5.2.2 Digital certificate

Digital certificate offer high assurance that the data baked inside is authentic and verified. However, some verification procedures are most of the time not automatable. This means that the process usually requires manual investigation, which impacts the price of the certificate. In practice, the high cost is the main reason why digital certificates are not widely used. Therefore, our solution should **not be expensive and ideally free of charge**.

Since the introduction of QWAC in the eIDAS regulation, new payers have emerged. However, the infrastructure needed to deploy QWAC is incompatible with the existing infrastructure built by certificate authority and web browsers (Section 4.2.3). This means that Europe has to develop its own public key infrastructure, which is challenging to put in place and manage while guaranteeing strong security. Furthermore, this new infrastructure will only be available inside of Europe. Therefore, to be globally available, simple to put in place and manage, our solution will need to **be built on existing infrastructure**.

6 Proposition

In this chapter, we will make propositions to answer the research question of how to assess the trustworthiness of any website (RQ1) and how to prove the trustworthiness of any website (RQ2). They will be built to cover the requirements from the previous chapter (Section 5). Practically, we will design a tool to help users assess the trustworthiness by themselves (Section 6.1), and we will introduce a new protocol to improve the transparency of websites (Section 6.2).

6.1 Tool

In this section, we will design a tool to assess the trustworthiness of any website (RQ1). To achieve this, we will build upon the trust principles established as requirements in the previous chapter (Section 5.1).

In practice, we begin by addressing how the user will be involved in the decision-making process by introducing the concept of human firewall (Section 6.1.1). Based upon this, we will build propositions by developing on every trust principles (Section 6.1.2).

6.1.1 Human firewall

A technical solution that does not involve humans faces major limitations. The system can only assess the trustworthiness from the solution's perspective and not the intended user's perspective. Moreover, fully automated solutions can lead to out-of-the-loop syndrome, where the operator loses its ability to monitor and understand the system. This can have significant performance implications. Beyond that, we believe that because the user is the target, he should be involved in the decision-making process. For these reasons, we introduce the concept of “human firewall” as a way to involve humans in the decision-making process of whether a website is trustworthy or not.

Human firewall: Involving humans in the decision-making process of whether a website is trustworthy or not.

However, decision-making involving humans is challenging. Therefore, we will build our propositions around the well-studied concept of situation awareness (Section 6.1.1.1). This concept will help us implement a solution better suited for humans (Section 6.1.1.2).

6.1.1.1 Situation awareness

Decade long research made by Endsley on situation awareness is summarized in [2]. The paper reports that the most difficult part of many jobs requiring accurate decision-making is building and maintaining a high level of situation awareness. People tend to

struggle more with figuring out what to do and understanding what is happening in the situation than doing the task itself. It also applies to the most experienced professionals, who may fail to perform well if they lack accurate situation awareness.

In this regard, this paper will serve as a base to clearly define situation awareness (Section 6.1.1.1.1). This will help understand the common human restrictions in terms of working memory (Section 6.1.1.1.2) and attention (Section 6.1.1.1.3) in achieving a high level of situation awareness.

6.1.1.1.1 Definition

In all of her papers, Endsley defines situation awareness as the perception of the elements in the environment within a volume of time and space, the comprehension of their meaning and the projection of their status in the near future.

Situation awareness: Perception of the elements in the environment within a volume of time and space, the comprehension of their meaning and the projection of their status in the near future.

But more importantly, this definition highlights three hierarchical phases, where each level represents a higher level of situation awareness.

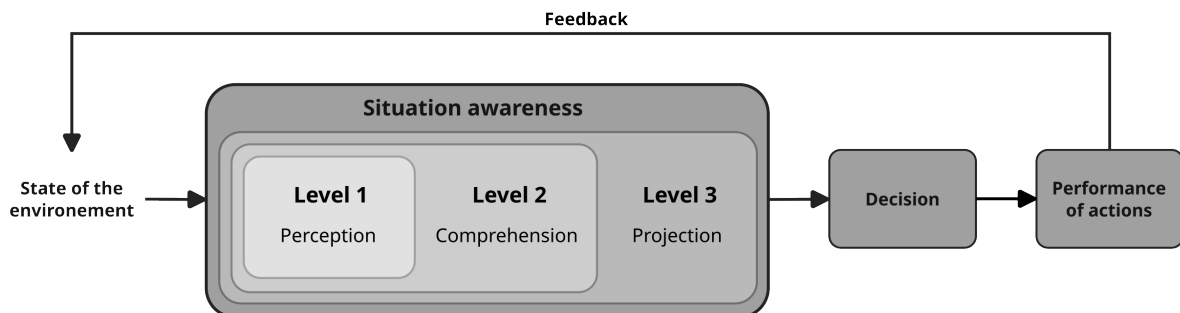


Figure 5: Endsley's model of situation awareness adapted from [2].

Level 1

The first level is the perception of the status, attribute, and dynamics of the relevant elements in the environment. The information may be perceived through direct observation or assisted by sensors and displays.

Level 2

The second level is the comprehension of the current situation based on the synthesis of disjointed elements from the first level. By putting information together, the individual creates a comprehensive picture of the environment and assigns meaning to the objects and events. However, in complex systems, novice decision makers may lack the expertise to effectively integrate the information along with pertinent goals.

Level 3

The third level is the projection of the future status of the environment. It is based upon the knowledge acquired in the first level and the comprehension of the situation from the second level. It is the highest level of situation awareness and the end goal for every decision maker that wants to be accurate.

6.1.1.1.2 Working memory

Compared to long-term memory who has a potentially infinite capacity, the working memory is limited. Humans can process and retain around 7 ± 2 pieces of information at the same time [65]. As a result, several issues can arise when the user needs to manipulate a lot of data, process different sources of information or understand complex features.

Similarly to technological approaches, the intuition is to provide more data to improve the situation awareness. Even if this can improve the first level of situation awareness, it will reduce the ability to comprehend and project information needed to reach higher levels of situation awareness. Moreover, when the amount of information is too high, the users may exceed their working memory capacity. Therefore, we propose to **provide only the information necessary for a good situation awareness**.

When users have to process different sources of information, such as on systems with multiscreen interfaces, the working memory capacity is a significant limit. The users must retain the information from one source before switching to another. As a result, systems that require people to remember information increase the likelihood of situation awareness errors. Therefore, we propose to **group data visually in one interface to keep all the data available and reduce the working memory overhead**.

Systems tend to become increasingly more complex over time. However, complexity negatively impacts each level of situation awareness. First, it slows down the individual's ability to absorb data. Second, it undermines the person's ability to correctly interpret the information. Last, it makes it more challenging to predict the future states. Therefore, we propose to **reduce the complexity by labeling information based on meaning rather than the technology involved**. This allows everyday users to correctly interpret information and project future states.

6.1.1.1.3 Attention

To achieve good situation awareness, individuals need to cover all the different aspects of the environment. This demands to constantly switch attention. However, attention is a limited supply that can lead to issues when the individual is focused on only one aspect or distracted by inappropriate signals.

Attentional tunneling happens when an individual stops his scanning behavior to focus on certain environmental aspects. If he forgot to continue evaluating the rest of the information, this can lead to partial situation awareness. The situation awareness of reviewed aspects will be good, but the rest will stay inaccurate. This phenomenon is

accentuated by stressors like workload, anxiety, and fatigue where people tend to take premature decision. Therefore, we propose to **display the most important information first**. Like that, it will guarantee that if attention drops afterward, the most essential information has been perceived.

When capturing information from the environment, humans are more sensitive to certain features. The color red, movement, and flashing light attract individuals attention toward it. These features are tools that can be used to improve situation awareness when placed correctly. But unnecessary distraction will degrade the situation awareness. Therefore, we propose to **use these salient properties to highlight patterns known to have a higher probability of being exploited**.

6.1.1.2 Implementation

Based on the insight from the previous section (Section 6.1.1.1), we will implement the human firewall as a way to achieve the third level of situation awareness. Our approach will consider the limitation of human working memory (Section 6.1.1.1.2) and attention (Section 6.1.1.1.3).

To make a wise use of the limited working memory capacity, we will optimize the presentation of information. First, by keeping only the data necessary to develop good situation awareness. Second, by grouping all the data visually in one central interface. Third, by labeling information based on meaning instead of complex names.

To make the best use of the limited attention capacity, we will guide the user towards the most important information. For that, we propose a classification in three categories corresponding to each level of situation awareness. This allows to display all the information leading to the third level at first. Furthermore, we propose to add another category for information necessitation highlighting.

Information

The first category contains all the necessary information to build the first level of situation awareness. Therefore, they will be displayed impartially to help the user make their own comprehension and projection.

Hint

The second category is composed of data that can help the user reach the second level of situation awareness. They provide meaningful insight on the interpretation of information. Therefore, they will be added on top of information as guides from the user decision.

Decision

The third category is composed of the data that can be used to directly assess the trustworthiness of any website. This allows to easily achieve the third level of situation awareness. More specifically, it notifies the user that a decision about the trustworthiness status is already known either by himself or by a trusted third party.

Alert

The additional category regroups all the information or hints that are known to be frequently used by attackers. This distinction allows users to pay attention to unusual pattern and prevent habituation.

6.1.2 Trust principle

In this section, we will address every trust principles identified in the previous chapter (Section 5.1).

6.1.2.1 Trust depends on identity

A domain name identifies a website. However, the definition of what is a domain name differs based on the usage. The absolute version is used for technical purpose (Section 6.1.2.1.1), while the effective version is used to identify the entity that controls the domain (Section 6.1.2.1.2).

6.1.2.1.1 Absolute domain name

The Fully Qualified Domain Name (FQDN) is the technical identity used by the DNS protocol. It is composed of a list of labels separated by a dot that represents the exact location in the tree hierarchy.

Fully Qualified Domain Name (FQDN): Version of domain name that specifies its exact location in the tree hierarchy of the DNS.

The server at this location resolves the FQDN to an IP address that the client will connect to using the HTTP and TLS protocol.

As a result, the FQDN is the identity we will use when assessing the trustworthiness of the server or the communication to it.

6.1.2.1.2 Effective domain name

Registering a domain name is only possible at certain levels in the DNS tree. The root zone is controlled by IANA⁵⁰, which delegate the control of each child to a registry. This is referred to as the top-level domain (TLD). Most TLD offer commercial services

⁵⁰<https://www.iana.org/>

where users can register second-level domain. Afterward, the owner controls the rest of the three and can create third level domains and beyond. This is commonly referred to as subdomains.

However, with the evolution of the Internet, some entities controlling a second level domain started to develop business involving the registration of third level domains and beyond for their clients.

Subdomain service provider: Entity controlling a second level domain, who allows the registration of third level domains and beyond for their clients.

These subdomain service providers complicated the identification of the effective domain name. Fortunately, we can use the community-maintained list containing all the known domain suffixes⁵¹ to take this issue.

As a result, the effective domain name is the identity we will be use when assessing the trustworthiness of the entity controlling the website.

6.1.2.2 Trust is a function of the perception of risk

Because the perception of risk is personal and subjective, we will not use technical solutions to try to evaluate this aspect. Instead, we will rely on our concept of human firewall (Section 6.1.1) by letting the user decide by himself based on the information from the other trust principle.

6.1.2.3 Trust is a matter of degree

The trust is granular and the amount of trust given varies depending on the individual. We could propose technical solutions to help the user track each aspect of trust, but we have decided to propose a simpler method. By relying on our concept of human firewall (Section 6.1.1), this processing and aggregation can be done in the user head.

6.1.2.4 Culture affects trust

The national culture impacts the trust-building process. People educated in individualistic culture tend to be more characteristic-based, while collectivist culture tends to be more institutional-based. Therefore, we could adjust the information we give to the user based on its country of origin, but we wish to offer a simpler solution that does not need configuration and can be adapted to the vast majority of people. As a result, we have decided to rely on our concept of human firewall (Section 6.1.1). The user will weight which data is more adapted to his culture from both characteristic and institutional information.

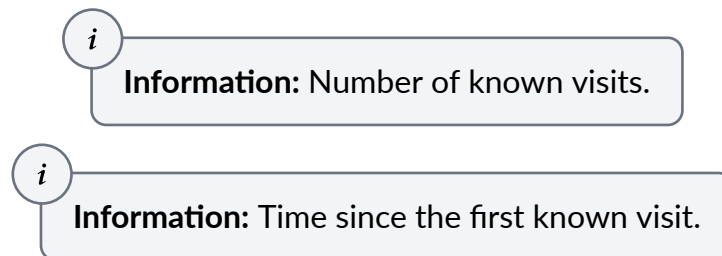
⁵¹<https://publicsuffix.org/>

6.1.2.5 Trust deepens over time

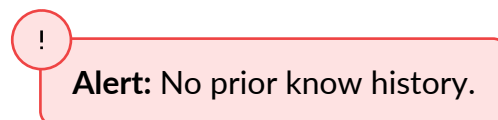
Trust deepens over time following successful interaction with the user. Nonetheless, we propose to extend this concept by arguing how the lifetime of a domain also influences the user perception of trustworthiness.

6.1.2.5.1 Interaction

To emphasize the importance of past interaction in the assessment of trustworthiness, we will display information about the user browsing history with the website. More precisely, we propose to display the number of visits and the duration since the first visit. However, these values may not be accurate because they are only tracked on the user browser and can be cleared easily. We could propose a solution to track independently the browsing history, but this will introduce other concerns in terms of privacy. Instead, we propose to indicate that the information is an estimation based on known data.



Furthermore, we propose to highlight when the website is visited for the first time. This allows the user to quickly notice irregularities with his expectation. For example, a user's regular websites showing no previous visit can indicate a potential phishing attack.



6.1.2.5.2 Lifetime

We argue that we can use the time since the registration as an indicator of trustworthiness. For that, we take for assumption that there are actors constantly scanning the Internet and taking down phishing websites. Notably, registries [66, Specification 6 Section 4] and registrars [46, Section 3.18] who have a contractual obligation to take mitigation actions against well-evidenced DNS Abuse. Therefore, we can fairly assume that a website still up is either legitimate or not yet scanned. Furthermore, the more time passes, the more likely the website will be analyzed. As a result, we can consider that after a reasonable time, the probability of a website being malicious will be negligible.

Based on that, we propose to alert the user when a website is newer than a reasonable threshold. From scientific research [67], we know that a significant number of lifetimes last exactly one year, which corresponds to the minimum registration term. Therefore, we propose to alert the user when a website has been registered for less than a year.



Alert: Newly registered domain (< 1 year).

6.1.2.6 Trust is based on information

For a user to trust a website, he first needs to get to know it. It can be achieved through many dimensions. Nevertheless, in our research, we have found that information about the owner is an important aspect to prevent phishing (Section 4). Additionally, this information is generally publicly available when present directly on the website (Section 6.1.2.6.1), accessible via the WHOIS protocol (Section 6.1.2.6.2) or embedded in digital certificates (Section 6.1.2.6.3).

6.1.2.6.1 Website

The information about the owner of a website is typically located in the footer of the pages or on a dedicated “about”, “privacy policy” or “legal information” page. Legal requirements may also force the presence of some information at specific locations.

For example, the GDPR [4, Chapter 3 Section 2] imposes that the identity and the contact details of the controller and, where applicable, of the controller's representative is transmitted to the user. Similarly, in some country like Belgium [68, Art.2:20] and Germany [69, Teil 2 §5 (1)], commercial websites are required to provide imprints which include the name, address, contact, and other legal identification information.

Because retrieving this information is challenging, we have chosen not to exploit this source of information but use other means where the location is predictable and standardized.

6.1.2.6.2 WHOIS

The WHOIS services are a valuable source of information because they provide standardized information for the vast majority of websites. However, the introduction of the GDPR significantly impacted the information available, as explored in depth in a previous chapter (Section 4.2.1.1). The WHOIS became an unreliable and less meaningful source of threat intelligence. One of the major adjustments adopted to reduce this issue is the differentiation between individual and organization.

Individual

When the registrant is an individual, all the information that can be used to identify him is considered personal data. While most countries do not have laws in place to protect personal data, this is not the case in Europe. The GDPR impose that the personal data of individuals is redacted in the WHOIS. Which means that under the GDPR, no information is exploitable for our use case. Nevertheless, outside of Europe, the WHOIS contains the name, the address, and contact details about the individual owning the domain name. As a result, we propose to display the relevant information when available. We believe that the registrant name is the necessary information to correctly identify

an individual. However, we propose to also display the individual's approximate location to better identify him while keeping some privacy.

i

Information: Domain registrant name and approximate location.

Organization

Domain names can also be registered by companies. In this case, the owner has the possibility to declare additional information about the company to be displayed in the WHOIS. This includes the name and the address of the company. Therefore, we propose to display the relevant information when available. Based on the deceptive attack on digital certificate explored in a previous chapter (Section 4.1.2.1), we know that the company name and country are not enough. As a result, we propose to display a more precise location.

i

Information: Domain registrant organization and precise location.

6.1.2.6.3 Digital certificate

Digital certificates are electronic documents to prove the identity of a website. However, only a small portion of them include information about the owner. This includes IV certificates, OV certificates, EV certificates and QWACs. Nonetheless, because QWAC is still very new, we propose to only focus on TLS certificates as they have been battle tested for many years. Therefore, we propose to display to the user the name and location of the subject for which the certificate has been issued when it is available. But more importantly, the location needs to be precise enough to protect against attacks seen in a previous chapter (Section 4.1.2.1) while preserving the privacy of individuals.

i

Information: IV certificate subject name and approximate location.

i

Information: OV certificate subject name and precise location.

i

Information: EV certificate subject name and precise location.

6.1.2.7 First party information is important in developing trust

First party information is all the information provided directly by the website. The included information about the service, the policies, and the products. Because the information about the service and the product varies depending on the type of website, we propose to only explore the policies. More specifically, the privacy policies.

6.1.2.7 First party information is important in developing trust

Information about privacy is complex and generally unstructured. To solve this issue, the World Wide Web Consortium has developed the Platform for Privacy Preferences Project⁵² back in 2002. This protocol allows website owners to describe how they collect and use data in a machine-readable format. However, due to the implementation difficulty, lack of value, and lack of enforcement, this protocol was not widely used. This led the project to be officially retired in 2018 when the GDPR took effect.

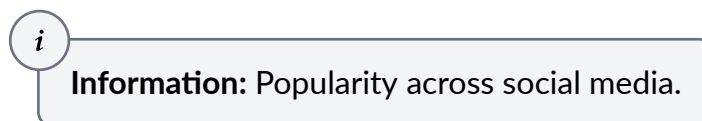
All the necessary information about privacy is explained in the privacy policy page. As a result, we could propose to redirect the user to this page for more information about privacy. However, the added value of displaying a link to the privacy policy page is very low. Therefore, we will not propose any first party information on the privacy aspect.

6.1.2.8 Second party opinions are important in developing trust

Second party opinion is information about others' experience with the same website and their feedback. Over the years, several services have been created over this concept of crowdsourcing. However, being profitable in this space is challenging. Many companies have been at the center of scandals and criticism.

For example, it was discovered that MyWOT⁵³ was selling the browsing history of its users to third parties, which violated the privacy policies of app stores [70]. Similarly, commercial services like Trustpilot⁵⁴ have a business model based on subscriptions from companies listed on their website. This behavior creates a conflict of interest when the platform allows companies to filter what review is displayed or not. Moreover, fake reviews are a major concern on these platforms. As an example, Trustpilot has reported that more than 3 million fake reviews had been removed in 2024 [71].

Therefore, we propose to use a service that collects a wide variety of user experience while not being the core of the business to prevent biased practices. For that, social media are a good match. We propose to display to the user the popularity across different social media to give a broad idea of the popularity of the entity behind the website.



Additionally, relying on social media allows the user to easily check the opinion of other people in his circle. This is useful because these opinions have a higher impact than random people. Furthermore, it reduces the negative effect of fake review because the probability of following a fake account is very low. Nonetheless, this process needs to be done manually by the user. As a result, we propose to display the links to all the known social media accounts to simplify the collection phase for the user.

⁵²<https://www.w3.org/P3P/>

⁵³<https://www.mywot.com/>

⁵⁴<https://www.trustpilot.com/>

i

Information: Social media links.

6.1.2.9 Third-party ratings are important in developing trust

Third parties rating are opinions coming from experts which formalize and amplify the reputation of websites. They are typically in the form of a seal of approval. However, these seals are under criticism.

Research made at University College London [72] reveals that trust seals are not always noticed by users. But when they do, the level of trust toward the website with seal is significantly higher. Nevertheless, qualitative analysis of the interview data revealed significant misconceptions on the meaning of trust seals. Users associate the presence of a trust seal as a proof of the trustworthiness. However, seal of approval are generally only images displayed on a website. Because of that, bad actors can just copy and paste the images to create a fake sense of trust.

Therefore, we propose to use other sources of trusted third-party ratings and we argue that blacklist and whitelist are valuable sources of ratings.

Whitelist

Whitelists are typically based on the popularity. However, as explained in a previous chapter (Section 3.3.3.2), research made in [39] proved how it can be easily abused. Fortunately, they also developed a solution to this problem by aggregation popularity among many whitelists and reduce the probability of abuse. Because this approach has been proven effective over the years, we will adopt it by displaying the popularity rank to the user.

i

Information: Popularity rank (TRANCO⁵⁵).

Blacklist

Blacklists are a powerful source of third-party ratings because it collects reports on websites considered malicious. This approach has better result than whitelist because it suffers less from misclassification. If a website has been flagged as malicious, the legitimate owner will invest time in proving it wrong, while malicious actors will not. Therefore, it is fair to assume that if a website is present on a blacklist, this means that the likelihood of being malicious is high enough to be considered untrustworthy for everybody. As a result, we propose to indicate to the user that a decision about the trustworthiness of the website is already known.

⁵⁵<https://tranco-list.eu/>



Decision: If present in a blacklist, should be considered untrustworthy.

6.1.2.10 Formal controls are important in developing trust

Formal controls are used to define the expected behavior and the penalties in case of non conformance. In general, they are implemented as laws by each country (Section 6.1.2.10.1). Regardless, they can also apply to entities that are not linked to any country. More specifically, formal controls are used to guarantee the correctness of the WHOIS information (Section 6.1.2.10.2) and digital certificates attributes (Section 6.1.2.10.3) explored in a previous section (Section 6.1.2.6).

6.1.2.10.1 Country

With the development of the Internet, most countries have introduced laws to define what is considered unacceptable behavior on the Internet and the according penalties. However, because these laws are defined as a national level, this means that they vary depending on the country. Therefore, we propose to develop more on the legislative background of these countries (Section 6.1.2.10.1.1).

Furthermore, in the context of websites, this is not always clear which country's law should apply because websites are globally available and typically operate in multiple jurisdictions. Therefore, we propose to focus on the country of the owner (Section 6.1.2.10.1.2) and the country where the website is hosted (Section 6.1.2.10.1.3).

6.1.2.10.1.1 Background

In most societies, there are typically three forms of power. The legislative power who define the law. The executive power who executes or enforces the law. And the judicial power who interprets, defends, and applies the law. We propose to give the user a comprehensive background on countries based on indexes on these three aspects. These insights allow users to estimate whether the country effectively prevents cybercrimes with enforced legislations and a strong criminal justice.



Hint: Countries with enforced legislations and a strong criminal justice are more likely to effectively prevent cybercrimes.

Legislative

For the legislative aspect, we propose to display the presence of cyberlaws in the country by relying on the Global Cyberlaw Tracker⁵⁶ developed by UN Trade and Development (UNCTAD). This dataset is the first ever global mapping of cyberlaws who tracks the state of e-commerce legislation in the field of e-transactions, consumer

⁵⁶<https://unctad.org/topic/ecommerce-and-digital-economy/ecommerce-law-reform/summary-adoption-e-commerce-legislation-worldwide/>

protection, data protection, privacy, and cybercrime adoption in the 194 UNCTAD member states.

i

Information: Country's cyberlaw on electronic transactions, consumer protection, privacy and data protection, and cybercrime.

For the executive and judicial aspects, we propose to provide information based on the Rule of Law Index⁵⁷ developed by the World Justice Project. More specifically, we propose to use the regulatory enforcement factor⁵⁸ to represent the executive aspect and the criminal justice factor⁵⁹ for the judicial aspect.

Executive

The regulatory enforcement factor measures the degree to which regulations are fairly and effectively implemented and enforced. However, it does not assess which activities a government chooses to regulate. Fortunately, this aspect was already explored by the previous proposition of cyberlaws.

i

Information: Country's regulatory enforcement index.

Judicial

The criminal justice factor evaluates the effectiveness of the country's criminal justice. It defines an effective criminal justice system as capable of investigating and adjudicating criminal offenses effectively and impartially, while ensuring that the rights of suspects and victims are protected.

i

Information: Country's effective criminal justice index.

6.1.2.10.1.2 Owner

Commonly, the country of the owner can be found based on his legal address. The legal address of individuals is generally the location of their main residence, while for companies, it refers to the main office. In either case, the owner will always be entitled to the law of the country where his legal address is. Therefore, we propose to display the owner's country based on his legal address. More specifically, we propose to rely on the information contained in the WHOIS about the registrant address.

i

Information: Domain registrant country.

⁵⁷<https://worldjusticeproject.org/rule-of-law-index/>

⁵⁸<https://worldjusticeproject.org/rule-of-law-index/factors/2024/Regulatory%20Enforcement/>

⁵⁹<https://worldjusticeproject.org/rule-of-law-index/factors/2024/Criminal%20Justice/>

6.1.2.10.1.3 Host

To connect to the remote server where the website is hosted, the user will use an IP address. These IP addresses represent a location on the Internet, and they are allocated by regional Internet registries. There are four authorities, each one covering a part of the world. RIPE NCC⁶⁰ serves Central and West Asia, Europe, and Russia. LACNIC⁶¹ serves Latin America as well as some Caribbean countries. APNIC⁶² serves East, South, and Southeast Asia and Oceania. ARIN⁶³ serves Antarctica, Canada, the United States, and some Caribbean countries and territories. And AFRINIC⁶⁴ serves all of Africa.

IP allocation works similarly to domain names. Registrant will ask one of the authorities to allocate a range of IPs and public data will be available in their WHOIS services. As a result, we propose to use the country of the registrant as an approximation of the country of the server. However, domain names can be resolved to multiple IP addresses. Therefore, we propose to display to the user the country of all the resolved IP addresses.

i

Information: For all resolved IPs, country of the IP registrant.

6.1.2.10.2 WHOIS

As discussed in depth in a previous chapter (Section 4.3.1), information in the WHOIS provided by the registrant is only verified in certain contexts, but it is not the case by default. For gTLDs, ICANN impose registrar to verify the contact details. For ccTLDs, the requirements differ among each provider. Therefore, we propose to explain to the user that WHOIS information about the registrant is not verified by default.



Hint: Domain registrant information is not verified by default.

Additionally, we propose to explicitly indicate when information is verified. This approach follows the insight gathered from a previous section (Section 4.2.2) that suggested that active negative indicators are better than positive indicators. In more details, we propose to focus on the NIS 2 directive, explored in depth in a previous chapter (Section 4.2.1.2). It has been explained that European ccTLDs are required to verify the registrant identity on a risk-based approach. Therefore, we propose to explain this specific scenario to the user.



Hint: For European ccTLDs, registrant identity is verified when suspicious.

⁶⁰<https://www.ripe.net/>

⁶¹<https://www.lacnic.net/>

⁶²<https://www.apnic.net/>

⁶³<https://www.arin.net/>

⁶⁴<https://www.afrinic.net/>

6.1.2.10.3 Digital certificate

Formal controls are implemented at every step of the TLS certificate lifecycle. Before the certificate is issued, the certificate authority will validate all the information that will be included in the certificate (Section 6.1.2.10.3.1). Then, when issuing the certificate, the certificate authority will define an expiration date, after which the certificate is not valid anymore and needs to go through the validation process again. In addition, the certificate authority may also revoke a certificate before its expiration date if it was compromised or mis-issued (Section 6.1.2.10.3.2).

6.1.2.10.3.1 Validation

Every time a request for a certificate is made, the certificate authority will start by validating the authenticity of the request. When this is done, the certificate authority will ask for a proof that the requestor has authorization or control over the domain name he is requesting a certificate for. This step guarantees a link between the certificate and the domain. Additionally, the certificate authority may perform further verification in the cases of IV certificate (Section 6.1.2.10.3.1.1), OV certificate (Section 6.1.2.10.3.1.2) and EV certificate (Section 6.1.2.10.3.1.3).

6.1.2.10.3.1.1 IV certificate

For IV certificates, the certificate authority verifies the identity of a natural person [73, Section 3.2.3]. More specifically, the applicant's name and address. For the name, the certificate authority should use a government-issued identity document that displays the applicant face. For the address, they should use legal documents like the same government-issued identity document, utility bill or bank statement. As a result, we purpose to summarize these formal controls by saying that the IV certificate owner is verified by the certificate authority using legal documents.



Hint: For IV certificates, individual name and address has been verified by the certificate authority using legal documents.

6.1.2.10.3.1.2 OV certificate

For OV certificates, the certificate authority verifies the organization's identity and address [73, Section 3.2.2]. In more details, the certificate authority should rely on at least one method of documentation or communication. The documentation includes an attestation letter or information from a third-party database, while communication is through an official government agency or a visit to the organization's office. Therefore, we propose to explain to the user that the OV certificate owner company is verified by the certificate authority using legal information.



Hint: For OV certificates, organization identity and address has been verified by the certificate authority using legal information.

6.1.2.10.3.1.3 EV certificate

For EV certificates, the verification is a stricter version of the process for OV certificates [74, Section 3.2.2]. It has the same purpose of verifying the identity and address of the organization but also focuses on helping to establish the legitimacy of the business.

Compared to OV certificates, the process verifies the legal existence and identity of the applicant using a more wide range of acceptable methods of verification. Nevertheless, the requirements are more strict and specific to the type of organization. The applicant may be a representative of a private organization, government entity, business entity, or noncommercial entity. Therefore, we propose to explain to the user that the EV certificate owner company is verified by the certificate authority using strict verification specific to the business category.



Hint: For EV certificates, organization's legal existence and identity have been verified by the certificate authority using strict verification specific to the business category.

And as context, we also propose to display the business category. This allows the user to quickly notice irregularities with his expectation.



Information: EV certificate business category.

Furthermore, to help establish the legitimacy of the organization, the certificate authorities also verify the physical and operational existence. This is done through a rigorous process that has not been proven vulnerable to attacks as of mid-2025. Indeed, the most sophisticated attacks described in a previous chapter (Section 4.1.2.1) were due to a misleading user interface rather than a vulnerability in the verification process. Therefore, we propose to notify the user that the certificate authority has verified the legitimacy of the business using strong verification and that, in their opinion, it is trustworthy.



Decision: For EV certificates, organization legitimacy has been verified by the certificate authority using strict verification.

6.1.2.10.3.2 Revocation

Certificate revocation is an important mechanism to mitigate attacks or accidental compromise but can also be used for many other scenarios. In particular, the standard [75, Section 5.3.1] defines five reasons applicable to TLS certificate. Nevertheless, we will only explore the case of key compromised and privilege withdraw because they can have an impact on the trustworthiness.

Key compromise

A key compromise happens when the confidentiality or the cryptographic properties of the private key cannot be guaranteed anymore. More specifically, Mozilla⁶⁵ explicitly documents that this reason must only be used in the case where the private key has been exposed, can be exposed or can be computed. The certificate authority should only revoke a certificate when provided verifiable evidence of a key compromise. Furthermore, the certificate authority should provide the invalidity date as the first estimated date of the compromised [75, Section 5.3.2]. However, Mozilla suggests to also backdating the revocation date but only in the case of key compromise. As a result, we propose to alert the user that there is proof that a security incident happened due to a vulnerability or a hack. Furthermore, we also propose to indicate the date of the incident. This allows the user to have an understanding of some past security incidents related to the website.

!

Alert: There is proof that a security incident happened due to a vulnerability or a hack on the date of the invalidity or revocation.

Privilege withdraws

A privilege withdraws happens when the subscriber has made an infraction. More specifically, Mozilla⁶⁵ explicitly documents the case of a misused or misissued. This happens when the subscriber violates agreements, a wildcard certificate is used to authenticate a fraudulently misleading subordinate FQDN or when the information in the certificate is incorrect or changed. Therefore, we propose to alert the user that the certificate owner has made an infraction. Furthermore, we propose to also include the date of the revocation as the date when the infraction was sanctioned.

!

Alert: The certificate owner has made an infraction that was sanctioned by the certificate authority on the date of the revocation.

6.1.2.11 Social controls are important in developing trust

Social controls are values and norms used to encourage a desirable behavior in an organization or community. To be efficient, they need to be tracked over time to have a history of past behavior.

We argue that when an entity is behaving against social controls, the other entities in the organization or community will punish it with informal sanctions. This includes disapproval and, in extreme cases, exclusion. Therefore, we propose to use social media popularity measured by followers, views and likes as an indicator of social behavior. If the popularity drops, this could indicate that a part of the public has lost his trust in

⁶⁵https://wiki.mozilla.org/CA/Revocation_Reasons

the entity. To track the evolution of popularity over time, we propose to gather the information during each visit. This allows to alert the user that the trustworthiness status could have evolved due to an event since his last visit.



Alert: Social media popularity (followers, views, likes) dropped since last visit.

6.1.2.12 Security

To connect to a website, two protocols are essential. First, the DNS who resolves the domain name into an IP address. Then the HTTP that allows the user to connect to this IP address and get meaningful answers. Both steps need strong security to guarantee the authenticity, integrity, and confidentiality of information transmitted. For the DNS, DNSSEC provides authentication and integrity while for HTTP, TLS provides authentication, integrity, and confidentiality. Together, DNSSEC and TLS provided full coverage in both ways between the user typing a domain name in a web browser and the server receiving and sending information.

DNSSEC

The initial development of the DNS protocol did not include security measures. This opened the possibility for attackers to develop techniques to manipulate and forge DNS responses. This problem was later acknowledged and DNSSEC was introduced as an extension of DNS to maintain backward compatibility. Technically, DNSSEC relies on cryptographically signing the DNS data. This is done using the same delegation approach as the DNS data. A trust anchor is used at the root level to sign the top-level domain. Then the top-level domain signs the second-level domain and so forth in a tree fashion. Because the rotation of the trust anchor cryptographic keys are done in a public ceremony under the watch of many stakeholders⁶⁶, we can consider DNSSEC safe of unnoticed attacks. Therefore, we propose to explain to the user that DNS data signed with DNSSEC means that the correspondence between the domain name and the server IP address is authentic.



Hint: With DNSSEC, the server IP address has been proven to be linked with the domain name.

TLS

The TLS protocol is commonly used to secure the HTTP communication by preventing eavesdropping and tampering. Technically, this HTTPS version encrypts the data using a set of cryptographic keys also used to authenticate the server. Therefore, we propose to explain to the user that HTTPS means that all communications between his machine and the server are encrypted. More importantly, we propose to highlight the limited

⁶⁶<https://www.iana.org/dnssec/ceremonies/>

scope of TLS in terms of trustworthiness. This will prevent the common misconception explored in a previous chapter (Section 4.2.2.1) around HTTPS being an overall security indicator instead of a connection security indicator.



Hint: With HTTPS, all communications with the server are encrypted but the website may not be trustworthy.

6.2 Protocol

In this section, we will introduce a new protocol to prove the trustworthiness of any website (RQ2). To achieve this, we will build upon the requirements established in the previous chapter (Section 5.2).

In practice, we will propose an approach (Section 6.2.1) and implementation (Section 6.2.2) that are scalable, free of charge, delivers verified information to anybody without waiting time and built on existing infrastructure. Beyond that, we will also address the more complex scenario where a brand is identified by multiple domain names (Section 6.2.3).

6.2.1 Approach

As highlighted in a previous chapter (Section 4.1), criminals conceal the information about the ownership of the website to evade persecution. Based on this insight, we have established our second research question (RQ2) based on technical gaps in the verification of the identity of the website's owner and the transparency of this verified information to the users (Section 4.3). Furthermore, it was highlighted on several occasions that natural and legal person are not treated the same way in those aspects. Therefore, we will start by clarifying our target (Section 6.2.1.1). Following that, we will be able to develop on the aspect of verification (Section 6.2.1.2) and transparency (Section 6.2.1.3) of our approach.

6.2.1.1 Target

Our protocol is intended to be implemented by registrant to prove the trustworthiness to the users of their website. However, the verification and transparency aspect depend on the type of registrant. Moreover, the proportion between individuals and organizations is not always equally distributed.

Individual

In a previous chapter (Section 4), it has been explored that verification of individuals is usually done at the top-level domain and digital certificate level and that privacy laws significantly impact the transparency. More specifically, the GDPR who imposes the redaction of any personal information unless the user has given explicit consent.

Therefore, to propose a lawful solution, we will only focus on voluntary information provided by individuals.

Organization

In a previous chapter (Section 4), the verification and transparency of organization's information has been extensively developed. Like for individuals, the verification is frequently done at the top-level domain and digital certificate level. However, for the transparency, privacy laws should not apply. Basic information about an organization should always be public because it is of public interest, as acknowledged by the NIS 2 directive. Therefore, we will mainly focus on organizations because they have the necessary ground in terms of verification and transparency.

Proportion

The proportions of natural vs. legal person is not public information for many TLDs. Fortunately, some of them publish data that can help draw a global picture. DNSBelgium reports that in 2024 around 74% of registrants for .be domain are companies [76]. This number increases in countries like Norway, where Norid reports that around 80% of .no domains are registered by businesses [77]. On the other hand, Afnic gives numbers in the range between 40% and 60% of legal person for the several TLDs they manage (.fr, .pm, .re, .tf, .wf, .yt) [78]. Overall, we can fairly assume that in Europe, most websites are registered by organization. Therefore, it reinforces the need to prioritize on organization's data rather than individual's.

6.2.1.2 Verification

In a previous chapter (Section 4.3.1), we have identified the need for a scalable solution that can circumvent the limitation of a challenging verification process. We have acknowledged this problem and oriented our proposition around workarounds rather than a new verification process.

Our proposition is to rely on existing verification already done by trustworthy actors. We will develop on two different sources of trust we find applicable to our target defined in the previous section (Section 6.2.1.1). More specifically, the official business registry of each country (Section 6.2.1.2.1) and the public profiles on various platforms (Section 6.2.1.2.2).

6.2.1.2.1 Business registry

Business registries are entities that are used to register a company under a specific jurisdiction. To this extent, they are usually mandated by the government of the jurisdiction that gives them the purpose of protection, accountability, and control. As a result, they are generally the only way to register officially a company under the jurisdiction. For these reasons, we have selected business registries as our primary source of trust. Nevertheless, the information quality and quantity are a major limitation.

Many registries do not have a strong verification process (Section 6.2.1.2.1.1), or the data is simply not publicly available (Section 6.2.1.2.1.2).

6.2.1.2.1.1 Process

The Business Registry Insights ran a survey [79] among 90 jurisdictions in 2024. The results indicate that around 70% of the participants reports consulting, accessing or connecting to other data sources to verify information within the filing procedure. Among them, around another 70% reports consulting the information using automated or telematics ways. Furthermore, the reports highlights that the most commonly used source of information in this case is registers of business names, populations, and addresses.

Based on those insights, we can fairly assume that business registry contains information that is in the majority correctly verified and can be used as a viable source of trust for our protocol.

6.2.1.2.1.2 Availability

According to the Open Company Data Index, there is a growing global movement toward corporate accountability through open data⁶⁷. In 2025, the availability metrics⁶⁸ show that already around 50% of the 208 countries listed provide basic information without charge or registration. Additionally, another 15% is known to provide information not entirely exploitable. This can be due to the presence of duplicates, the low frequency of updates, or the unavailability of the status of the company.

As a result, we can fairly consider that a significant portion of countries provide available information about companies to be used by our protocol.

Additionally, it is worth mentioning that 35% of countries without any publicly available information appears to be in majority the less developed.

6.2.1.2.2 Public profile

With the development of online platforms, public profiles have become an increasingly more popular way of representing individuals as well as companies. According to DataReportal [3, Image 388], in 2025, half of all adult users visit social platforms to learn more about brands and this number tends to increase over the years.

For this reason, we have selected public profiles as our secondary source of trust. Beyond that, this source can be easily adapted for individuals. However, in either cases, social media relies on user provided information. Therefore, the verification process (Section 6.2.1.2.2.1) and availability of the information (Section 6.2.1.2.2.2) are major concerns.

⁶⁷<https://registries.opencorporates.com/why-is-this-important/>

⁶⁸<https://registries.opencorporates.com/metric/basic/>

6.2.1.2.2.1 Process

By default, no platform verifies the data provided by the user and anybody can create an account. This allows plenty of bad actors to register deceptive accounts. To tackle this issue, most platforms implement verification mechanisms to attest the authenticity and legitimacy of the owner. However, the verification procedure varies with each platform.

According to DataReportal [3, Image 398] the most used platform for brand research in 2025 is Instagram with around 60%, who is followed by Facebook, and TikTok with around 50%.

In the three big players, it is worth mentioning that Instagram and Facebook follow the same verification procedures, as they are both controlled by Meta⁶⁹. In more details, it is required that the account represent a real, well-known and highly searched brand or individual⁷⁰. Moreover, it is not allowed to have links to other social media, which limits the possibility to associate an entity across other social media outside the Meta ecosystem. By comparison, TikTok specifically offers ways to link other social media accounts for profiles with more than a thousand followers or verified profiles⁷¹. Similarly to Meta, those verified profile must represent a real business or person featured in multiple news sources⁷².

6.2.1.2.2.2 Availability

There is no obligation to create a public profile for a company to appear legitimate. Therefore, the information may not be available. However, the fact that users rely increasingly on social media to seek brands may incentivize them to create and validate public profiles.

Furthermore, it appears that this trend is correlated to the level of development of countries. For example, Nigeria has around 70% of social platforms usage whereas Belgium only 35% (Figure 6).

⁶⁹<https://www.meta.com/>

⁷⁰<https://www.facebook.com/business/learn/lessons/verify-facebook-instagram-account/>

⁷¹<https://support.tiktok.com/en/getting-started/setting-up-your-profile/linking-another-social-media-account/>

⁷²<https://support.tiktok.com/en/using-tiktok/growing-your-audience/how-to-tell-if-an-account-is-verified-on-tiktok/>

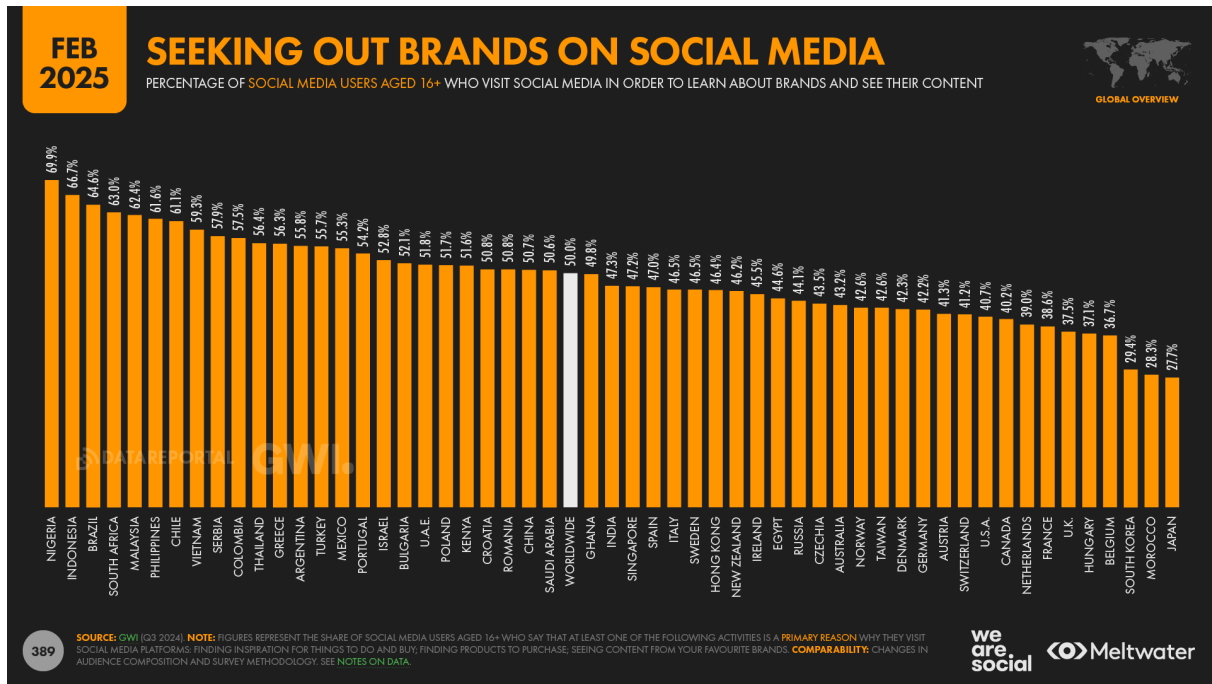


Figure 6: Share of users seeking out brands on social media by country from [3].

More importantly, this insight suggests that public profiles are complementary with business registry when it comes to information about brands. Indeed, it was explored in the previous section (Section 6.2.1.2.1.2) that less developed countries tend not to have publicly available information from business registries.

6.2.1.3 Transparency

As highlighted in a previous section (Section 6.2.1.2), there is an increase in the availability of information about the owner of a website. On one hand, there is a growing global movement toward corporate accountability through open data in business registry (Section 6.2.1.2.1.2). On the other hand, public profiles are increasingly used by users to learn about brands (Section 6.2.1.2.2.2). However, the user is not always aware of these sources of trust if he has no easy access to the information. As a result, our proposition is to allow websites to reference these sources of trust directly on their websites and be more transparent.

6.2.1.3.1 Business registry

Finding information through business registry is generally a cumbersome process. First, the user has to find the website of the registry based on the location of the company. This can be hard for companies operating in several countries. Next, the user has to search for the correct entry using the information he already has. This is typically the name of the company. However, this may not be the legal form used by the business registry. Finally, the user has to find the correct entry among all the results of his request. In the cases where the company name uses widely used words, this can be challenging to find the right one.

To simplify this process, we propose that the website owner explicitly reference the URL of the company's page on the business registry website. Therefore, eliminating the need of a manual process and improving the transparency of the company.

6.2.1.3.2 Public profile

In general, most websites include links to their social media accounts in the webpage's footer. However, the information is displayed in a human-friendly manner, which means that there is no technical method that can guarantee to extract social media accounts from any website. This is because source code analysis does not always work when the location in the source code is not predictable. Even if we could extract all the URLs pointing to social media accounts from a website, it will not always work if other account are referenced. This generally happens on websites hosting user-generated content, where other social media accounts can be referenced.

As a result, we propose to introduce a standardized way for website owners to reference their social media account.

6.2.2 Implementation

In this section, we will start by explaining in details how we propose to implement the approach explored in the previous section (Section 6.2.1). More precisely, we will develop on the aspects of verification (Section 6.2.2.1) and transparency (Section 6.2.2.2) for both business registry and public profiles sources. In addition, we will introduce a method of authentication to guarantee that the source referenced is legitimate (Section 6.2.2.3).

6.2.2.1 Verification

As explored in a previous section (Section 6.2.1.2), the verification processes vary based on the source. More specifically, business registry are impacted by their jurisdiction (Section 6.2.1.2.1) and public profiles by the platform they are hosted on (Section 6.2.1.2.2.1). As a result, the user has no clear understanding of the guarantees that the verification process offers. Therefore, we propose to create a dataset that explains for each source what are the guarantees.

Technically, we propose a simple mapping between a domain name and the explanation of the verification procedure. Furthermore, because the verification has no link with the user requesting the information, we propose to publish this dataset globally for anyone to use locally.

6.2.2.2 Transparency

As described in depth in a previous section (Section 6.2.1.3), our approach is to help website owners reference all the URLs to trust sources directly on their websites. To do so, we propose a protocol that needs to be easy to implement and available at a predictable location on the website.

Technically, we will use a text file stored on the website. This file will contain one URL per line pointing to an external sources of trust. For the predictable location, we will assume that this file will be stored at the root of the domain under the name “trust.txt”.

6.2.2.3 Authentication

In the previous section (Section 6.2.2.2), we have described a way for websites to reference sources of trust. However, there is no guarantee that the relationship is legitimate. To prevent bad actors from referencing anything, we propose to rely on the source to validate the authenticity. In other words, if a website is referencing a source and that this source is referencing the same website, we can consider that the relationship is legitimate.

Technically, we propose to get information from the official public API as much as possible as it provides a reliable interface. And when no machine-friendly API is publicly available, we propose to implement a parser that can extract the domain name referenced directly on the source webpage. However, the parser cannot scan the entire webpage because certain sources allow content to be posted by other users. Therefore, every source of trust needs a custom parser that will only analyze specific part of the source code. Whenever feasible, the parser should focus on the specific location made to specify the owner’s website.

6.2.3 Multiple domains

For many reasons, brands may register multiple domain names for the same purpose. A notable reason is to protect against phishing by registering variations of the main domain. This prevents bad actors from using the cybersquatting techniques explored in a previous chapter (Section 3.2.3). As a result, we must consider that the trust should be transitive between all these domains.

Technically, we propose to treat the other domains as an additional source of trust. Therefore, we need to develop on the aspect of verification, transparency, and authentication.

6.2.3.1 Verification

This additional source cannot provide any verification of the information present on the website because it is managed by the same owner. Therefore, we should make a distinction between additional domains and the initial sources from our approach (Section 6.2.1).

6.2.3.2 Transparency

For the transparency, we propose to reference the other domain as an additional source of trust. However, this additional source needs to be differentiated from the others, as explained in the previous section (Section 6.2.3.1). To do so, we propose to rely on a different syntax in the “trust.txt” file. More specifically, we will rely on the fact that for

the addition source, we need to reference a website rather than a specific webpage. As a result, we propose to reference verified sources with URLs and the additional source with domain names.

6.2.3.3 Authentication

In the previous section (Section 6.2.3.2), we have introduced a new source of trust in the form of a relationship between two domain names. However, the reference may not be legitimate. We propose to require that the other website needs to reference the initial domain name for the relation to be considered legitimate. This can simply be done by using the “trust.txt” file on both sides.

7 Evaluation

In this chapter, we will evaluate the two main propositions developed in the previous chapter (Section 6). More precisely, we will emphasize the strengths and weaknesses of the tool (Section 7.1) and protocol (Section 7.2) in their capacity to combat phishing attacks happening on the Internet (RQ).

7.1 Tool

In this section, we will elaborate on the tool introduced in the previous chapter (Section 6.1). We will start by discussing the advantages (Section 7.1.1) and disadvantages (Section 7.1.2) compared to the countermeasures introduced in a previous chapter (Section 3.3). Please note that because the blacklist and whitelist approach are included in our tools, we will not explore them. Following this, we will explore some limitations of the current propositions (Section 7.1.3) and suggest direction for future work (Section 7.1.4).

7.1.1 Advantage

Our approach focuses on assessing the trustworthiness of any websites (RQ1). This was a result of the identification of several research gaps in the existing countermeasures (Section 3.5.1). In short, we can summarize them into issues about the subjectivity of the decisions (Section 7.1.1.1) and a limited scope that does not include more sophisticated attacks (Section 7.1.1.2).

7.1.1.1 Subjectivity

The research gap highlighted that there is no clear technical distinction between what is considered trustworthy and what is considered phishing (Section 3.5.1). Furthermore, the decision about a website being malicious is subjective and varies based on the approaches.

In similarity-based detection (Section 3.3.1), a threshold is used in the last step to differentiate malicious websites. More importantly, this threshold is typically defined by the creator of the solution and baked into the implementation. This makes the decision based on the subjectivity of its creator.

In machine learning-based detection (Section 3.3.2), the decision is made based on a set of features. In the training phase, these features are selected based on their ability to correctly classify websites. This is done with a dataset composed of websites and how they should be classified. This means that the results are significantly affected by the choice of which website is included in the training dataset.

By comparison, our approach introduces the concept of human firewall (Section 6.1.1) which relies on the user to make the decision. As a result, the subjectivity is based on the final user rather than the creator of the solution.

7.1.1.2 Scope

It has been highlighted in the research gap that detection methods primarily focus on mass phishing where a well-known website is copied (Section 3.5.1). These detection methods do not cover malicious websites that are more sophisticated. In particular, the case where no real third party exist (Section 7.1.1.2.1) or when some techniques are used to evade detection (Section 7.1.1.2.2).

7.1.1.2.1 Fabricated third party

In similarity-based detection (Section 3.3.1), a legitimate counterpart needs to be present in the dataset to detect counterfeit. When the attacker impersonates a fabricated third party, this method cannot work.

In machine learning-based detection (Section 3.3.2), discriminant features need to be present to distinguish malicious websites from benign. However, in the case of websites built from the ground up to look legitimate, such features may not be available. This is because machine learning models primarily rely on features extracted from the URL and the source code. Contextual features like communication and external services are only used as reinforcements.

By comparison, our tool relies on contextual features. This helps detect attacks with fabricated third party that does not include discriminant features in the URL or source code.

7.1.1.2.2 Evasion

In the cloaking technique (Section 3.4.1), malicious content is only displayed to potential victims. This allows to evade detection by displaying a benign version to unwanted clients like crawlers, sandboxed environments, and anti-phishing tools.

In the content obfuscation technique (Section 3.4.2), the source code or visuals are modified to evade detection. This is done by altering the features used by the automated detection.

By comparison, our approach does not rely on any features from the content of the website. Therefore, these evasions techniques have no impact on our tool.

7.1.2 Disadvantage

Our approach focuses on assessing the trustworthiness of any websites (RQ1). However, our tool comes with several disadvantages. In particular, it relies on manual decision, which can have a major impact on performance (Section 7.1.2.1). Additionally,

the process is too universal to compete with more specialized solutions (Section 7.1.2.2) and is still vulnerable to some evasion techniques (Section 7.1.2.3).

7.1.2.1 Performance

In similarity-based detection (Section 3.3.1) as well as machine learning-based detection (Section 3.3.2), the process is entirely automatic. By comparison, our approach relies on the user to make the decision on whether the website is trustworthy or not. This makes the user the main bottleneck for performance because humans have many restrictions in terms of working memory (Section 6.1.1.1.2) and attention (Section 6.1.1.1.3).

7.1.2.2 Universality

In similarity-based detection (Section 3.3.1), only copies of legitimate websites can be detected. Therefore, the design of the solution is optimized for this specific scenario. By comparison, our approach covers a more generic scenario. It is still possible to detect copies of a legitimate website, but our tool gives fewer clues to detect them.

In machine learning-based detection (Section 3.3.2), a wide range of features are used to decide whether a website is malicious or not. By comparison, our tool relies on the user to make the decision (Section 6.1.1). However, humans have restrictions in terms of the quantity and complexity of the features they can manipulate (Section 6.1.1.1.2). As a result, our tool is based on a smaller and less technical set of features.

7.1.2.3 Evasion

In the URL manipulation technique (Section 3.4.3), we have seen that URL shortening services are used to bypass detection. When this is done using trustworthy services, our tool cannot correctly help the user detect malicious websites. This is because our approach will only assess the trustworthiness of the service and not the URL it will redirect to. However, this can be prevented by following the redirection before using the tool.

In the living off trusted sites technique (Section 3.4.4), a trusted platform is used to host malicious content. By definition, our approach cannot work because it only assesses the trustworthiness of the website and not the content on it. Even if the malicious content is hosted on a subdomain, it will not make a difference because our tool only considers the effective domain.

In the compromise of trusted sites technique (Section 3.4.5), the attacker has taken the control of a legitimate entity. However, our tool only assesses the trustworthiness of the website using contextual features. Therefore, the only way for a user to be notified that the website has been compromised is through a blacklist from a third-party (Section 6.1.2.9) or the revocation of the certificate (Section 6.1.2.10.3.2).

7.1.3 Limitation

Beyond the disadvantages of our approach explored in the previous section (Section 7.1.2), we will explore the limitation of our tool that could be improved. We have identified the usability (Section 7.1.3.1), privacy (Section 7.1.3.2), and anonymity (Section 7.1.3.3) as the three main aspects where the current proposition may be limited.

7.1.3.1 Usability

Our tool is intended to be used by a user willing to assess the trustworthiness of a website. This means that the person who wants to use the tool needs to have a reason to do so. In other words, our approach does not cover the initial motivator. We rely on the awareness of the user to decide if a website is suspicious and he needs to be investigated.

7.1.3.2 Privacy

Our approach relies in the vast majority on third parties. Each time our tool is used to check a website, information is transmitted to these external entities, which can compromise the privacy of the user. Furthermore, if the tool was automatically triggered for all websites visited by the user, this would leak the whole navigation history to these external third parties. Therefore, to preserve the user's privacy, our approach should only be used when necessary.

7.1.3.3 Anonymity

For a small portions of features, the information is directly coming from the website we are investigating. This is primarily the case to get the links to the social media account necessary for the principle of second party opinions (Section 6.1.2.8). Moreover, this may also be necessary to get the TLS certificates or DNSSEC information for the principle of information (Section 6.1.2.6.3), formal controls (Section 6.1.2.10.3) and security (Section 6.1.2.12). As a result, this may provide some information to the attacker. More precisely, the attacker would know that the victim has accessed the link and can get more details about the victim, like the device and browser he uses. This may allow the bad actor to modify the attack to be more targeted for a potential second attempt.

7.1.4 Future work

While our approach helps users to assess the trustworthiness of any websites (RQ1), certain aspects may be improved in future works. In particular, we have identified the situation awareness (Section 7.1.4.1) and platform (Section 7.1.4.2) as the two aspects of interest.

7.1.4.1 Situation awareness

In our design decision of the human firewall approach (Section 6.1.1), we have relied on the concept of situation awareness. It was concluded that for using the working memory efficacy, the tool should provide only the information necessary for a good situation awareness. To do so, our proposition is to select features for each principle of trust. However, this does not give any guarantee that the selection we propose is the best. Therefore, future research could focus on improving this selection through other means, like a user survey.

7.1.4.2 Platform

As explained in a previous section (Section 7.1.2.3), our approach is still vulnerable to some evasion techniques. The main issue is that we do not consider websites that can host somebody else's content without being responsible for it. Notably, this is the case for subdomain service providers, URL shortening services exploited in the URL manipulation technique (Section 3.4.3) and platforms exploited in the living off trusted sites technique (Section 3.4.4). Even if the European Union has recently adopted legislation on this issue in the Digital Service Act [80], smaller platforms are still not impacted. Therefore, further research should investigate how to differentiate those platforms and what are the implications in terms of trust.

7.2 Protocol

In this section, we will elaborate on the protocol introduced in the previous chapter (Section 6.2). We will start by comparing our approach with existing solutions by highlighting which aspects have been improved (Section 7.2.1). Later on, we will develop on some limitation of the protocol that could be improved (Section 7.2.2). Finally, we will give direction on the aspects that can accelerate the large-scale deployment of the protocol (Section 7.2.3).

7.2.1 Comparison with existing solutions

Our approach focuses on proving the trustworthiness of any website (RQ2). This question was formulated following the technical gaps identified in the existing solutions (Section 4.3). More specifically, it highlighted that the most common prevention measures implemented by the Internet ecosystem is to verify the owner's identity and show this information to the users. However, both the aspect of verification (Section 7.2.1.1) and transparency (Section 7.2.1.2) suffer from limitations that impact their ability to effectively protect against domain name and website phishing attacks. On the other hand, our approach is designed to address these limitations.

7.2.1.1 Verification

As explored in a previous chapter (Section 4.1), verification is typically conducted at the top-level domain and digital certificate level.

Top-level domain

In top-level domains, verification is only a common practice in among European ccTLDs (Section 4.1.1). However, the verification process is generally only performed with a risk-based approach. By comparison, our approach relies on external sources of verification, which covers a larger proportion of domains. More precisely, surveys suggest that at least 64 jurisdictions have business registry that perform verification (Section 6.2.1.2.1.1). Moreover, other research suggests that around a hundred countries have publicly available information about companies under their jurisdiction (Section 6.2.1.2.1.2).

Digital certificate

In digital certificate, the verification is only conducted for high-paying customers (Section 4.1.2). By comparison, our approach relies on external sources of verification that covers all the burden. As a result, website owners can implement our protocol free of any additional charges.

7.2.1.2 Transparency

As explored in a previous chapter (Section 4.1), the information from the verification conducted at the top-level domain and digital certificate level are made publicly available through WHOIS services and digital certificates attributes.

WHOIS

For the WHOIS services, the system is designed to make available all the information necessary to identify the registrant (Section 4.2.1). However, the information is generally provided by the registrant himself without verification. Moreover, privacy laws like the GDPR require the redaction of the registrant's personal data. As a result, only a small subset is really accurate and publicly available. By comparison, our approach is based on reference to public and verified sources of information. In other words, when information is available from a source, there is a guarantee that the information present is verified and can be lawfully accessed.

Digital certificate

For the digital certificates, the information provided by the subject is verified by the issuer of the certificate (Section 4.1.2). Once done, the required data is inserted into a digital certificate, which the authority then cryptographically signs. By comparison, our approach does not require the authority to validate the relationship, which makes it more scalable. More precisely, the authentication of the references provided by the

protocol is made by verifying that the domain name is mentioned in the trust source (Section 6.2.2.3).

7.2.2 Limitation

As explored in the previous section (Section 7.2.1), our propositions addresses the limitation of the existing solutions in terms of verification and transparency. Nonetheless, we have identified the usage (Section 7.2.2.1) and maintenance (Section 7.2.2.2) as additional limitations that may need further enhancements.

7.2.2.1 Usage

From the website's perspective, our implementation requires that a file containing references to sources of trust is hosted on the server. Moreover, the source of trust needs to reference the domain name publicly. These two requirements may represent friction to the adoption by most websites. Furthermore, the lack of adoption cannot be considered a negative indicator. Therefore, there is no major incentive to adopt our protocol apart from improving the trustworthiness of the participating entities.

From the website user's perspective, the implementation allows the user to directly consult the file hosted on the website. However, the authentication process requires calling an API or using custom parsers for sources that allow other user's content on the page. As a result, the user needs to use a dedicated software to correctly automate these tasks.

7.2.2.2 Maintenance

The implementation of our approach relies on critical pieces that need to be maintained. Without it, the protocol cannot guarantee that the references to sources of trust are legitimate.

For the verification (Section 6.2.2.1), a global database is required to list all the trusted sources and their verification guarantees. If the information is outdated, it could mislead the user about how reliable the website really is. In our proposition, we have opted for a central authority that has the responsibility to maintain and distribute this database. However, this approach may raise concerns about how such authority is managed.

For the authentication (Section 6.2.2.3), custom logic needs to be implemented for each of the sources to retrieve the information. Therefore, it is imperative to maintain synchronization between the source and target implementations. Any change on the source side would require the update of the custom code.

7.2.3 Deployment

Our approach relies on voluntary adoption. Therefore, a large-scale deployment may be difficult. However, we have identified several subjects of interest for the sources

(Section 7.2.3.1), websites (Section 7.2.3.2), and users (Section 7.2.3.3) involved in the process that can help in this regard.

7.2.3.1 Source

Our propositions necessitates that the domain name is referenced by the source of trust. However, because the domain name is typically not considered an essential data, sources of trust may not store or publicly provide such information. Therefore, collaboration with these sources may be necessary to provide a method to specify a domain name and make it publicly available through a public API or displayed on a dedicated page on the source of trust website.

7.2.3.2 Website

Our implementation relies on a file hosted on the root of the website. However, the location and name of this file is not globally accepted and can lead to potential collisions. Therefore, it could be beneficial to reserve a path to be used only for our use case. Technically, this could be done as a Well-Known Uniform Resource Identifiers [81].

Nevertheless, adopting an already defined standard could be more cost-effective. For example, during the writing of this paper, the Organization Trust Relationship Protocol was published to the IETF as an Internet draft [82]. It presents a standard format for organizations to express their trusted relationships with other organizations, as well as identify the social networks they control. Similarly to our proposition, it is implemented as a text file containing references in forms of URLs. However, it specifically targets journalisms publishers and associations. As a result, it may need to be adapted to be applicable for any websites.

7.2.3.3 User

As explained in a previous section (Section 7.2.2.1), our proposition requires a dedicated software to correctly performs the authentication. However, a large-scale adoption of such software would necessitate significant investment. Instead, it could be beneficial to integrate our proposition into other tools. For example, it would be logical that our tool developed in a previous chapter (Section 6.1) could provide and validate the information gathered from the protocol.

8 Conclusion

In this chapter, we will start by highlighting the contributions introduced in this paper (Section 8.1). Once done, we will provide a summary of the overall approach (Section 8.2) we have used to address the question of how to combat phishing attacks happening on the Internet (RQ). In the end, we will conclude with recommendations (Section 8.3).

8.1 Contribution

In this section, we will go through the main chapters of this paper and highlight the contributions we have made. In particular, the literature review (Section 8.1.1), the state of the ecosystem (Section 8.1.2), the requirements (Section 8.1.3) and the propositions (Section 8.1.4). Our primary focus will be on the elements that contrast with the current state of the art.

8.1.1 Literature review

In the literature review chapter (Section 3), we have extended the scope of what phishing is generally considered for. In particular, we have redefined phishing to include the scenario where attackers are impersonating an entity that does not really exist (Section 3.1.3.2). For that, we have introduced the concept of fabricated third party.

This new definition allowed us to explore concepts that are not directly available in scientific research but only documented by the cybersecurity community. More precisely, we have proposed a new anatomy that describes the whole life cycle of such attacks (Section 3.2). Moreover, we have explored a range of evasion techniques that can be used by sophisticated attackers (Section 3.4).

8.1.2 State of the ecosystem

In the state of the ecosystem chapter (Section 4), we have explored in depth the different prevention measures used by the Internet ecosystem. To the best of our knowledge, no prior scientific work has conducted a similar in-depth examination.

In more detail, we have identified that the common method to protect against domain name and website phishing attacks is to verify the identity of the owner of the domain name and show this information to the users (Section 4.1). Yet, this approach is not commonly formulated as a valid countermeasure in the scientific literature.

Beyond that, we have explored the usability issues of the current implementation (Section 4.2). In particular, we have explored the impact of the GDPR (Section 4.2.1.1) and the NIS 2 directive (Section 4.2.1.2) on the verification and transparency aspects. These sections delivered valuable insights that are the result of discussions with

industry experts who are directly involved in the implementation of the those legislation (Acknowledgments).

8.1.3 Requirement

In the requirement chapter (Section 5), we have prioritized a set of aspects that are not typically considered by the existing solutions. Nevertheless, we paid attention to relying on strong building blocks to answer the different research questions.

To answer the question about how to assess the trustworthiness of any website (RQ1), we have decided to go back to the root of what trust really means in an online environment. This leads us to select twelve principles that scientific research has determined are necessary to enable online trust (Section 5.1).

To answer the question about how to prove the trustworthiness of any website (RQ2), we have identified the major issues of existing solution and considered them as the requirements for our proportion. In details, this led us to select the scalability, cost, and reliability as the major points to be improved (Section 5.2).

8.1.4 Proposition

In the proposition chapter (Section 6), we have presented two original approaches, each of which focuses on a different research question.

To assess the trustworthiness of any website (RQ1), we have designed a tool that helps users to make decisions themselves (Section 6.1). This is the result of our unconventional approach that involves humans as a firewall rather than a fully automated decision (Section 6.1.1).

To prove the trustworthiness of any website (RQ2), we have designed a simple protocol that helps websites to provide verified information for their users (Section 6.2). Our approach relies on the use of external verification provided by well-known authorities. More precisely, we have proposed to rely on business registries (Section 6.2.1.2.1) and public profiles (Section 6.2.1.2.2) as sources of verified and available information.

8.2 Approach

The main research question of this paper is how to combat phishing attacks happening on the Internet (RQ). This formulation emphasizes the concept of phishing (Section 8.2.1) and combat (Section 8.2.2) that are the two main pillars of our research.

8.2.1 Phishing

The first objective is to target phishing in a more board definition. In particular, phishing is generally associated with deceptive emails. However, email is only a specific method

of delivery and does not cover all the Internet related attacks (Section 3.2.2). As a result, we have decided to explicitly target domain names and websites as they account for most of the Internet related phishing attacks.

Additionally, by adopting a more complete definition, we can adopt a more general approach. In our case, we have decided to consider phishing as a problem of trustworthiness. When applied to the Internet, the notion of trustworthiness extends the concept of security. A website may be entirely protected in terms of confidentiality and integrity, but if the owner is malicious, it is not trustworthy (Section 2.3).

8.2.2 Combat

The second objective is to combat phishing. To do so, we have reviewed the technical countermeasures from the scientific literature, but our analysis indicated that most of the approach only focuses on reactive methods by detecting phishing websites (Section 3.3). Therefore, we also explored in depth the prevention measures used in practice by the Internet ecosystem (Section 4.1). These realizations inspired us to make propositions that empower users with both reactive (Section 8.2.2.1) and proactive (Section 8.2.2.2) techniques.

8.2.2.1 Reactive

The reactive method aims to answer the question of how to assess the trustworthiness of any website (RQ1). But since trust is subjective, we have decided to adopt a human-centered approach. The user is provided with a set of information that helps him assess whether a website is trustworthy or not (Section 6.1.1).

Technically, we have designed a tool that aggregates information (Information) and displays them in a human friendly manner. Furthermore, to help users better comprehend the situation, the tool provides interpretation advice (Hint) and for faster decision, the tool maintains a record of the user's previous decisions and presents the perspectives of trusted third parties (Decision). In addition, the tool also alerts users for unusual patterns (Alert).

8.2.2.2 Proactive

The proactive method aims to answer the question of how to prove the trustworthiness of any website (RQ2). Our approach is to identify the owner of the website and provide this information to the website user. Consequently, the owner will be held accountable if something unexpected happens.

Technically, we have designed a new protocol that helps websites to provide reference to verified information about themselves. More precisely, we have selected business registry as the main source of trust based on their verification process and availability (Section 6.2.1.2.1). In addition, we have proposed to use public profiles to expand the coverage to potentially any online entity (Section 6.2.1.2.2).

8.3 Recommendation

When it comes to trust, we believe that human should be the central piece. Fully automated solutions can improve trust at a global scale, but human-centric approaches are needed to get the point of view of the final user. Therefore, we recommend that automated solutions are used to filter the most obvious attacks and user-centric approaches for the more sophisticated.

To improve trust on the Internet, we believe that security through transparency should be the way forward. More importantly, in the case of exchange of sensitive information, where the other party should be held accountable if something unexpected happens. Therefore, we recommend that the information necessary to identify the owner of a website is used to raise user awareness.

Bibliography

- [1] Council of European National Top-Level Domain Registries, "Registration data accuracy in European national domain registries: existing practices and challenges." [Online]. Available: <https://centr.org/library/library/download/10478/7435/41.html>
- [2] M. R. Endsley, "SITUATION AWARENESS," *HANDBOOK OF HUMAN FACTORS AND ERGONOMICS*. Wiley, pp. 434–455, Sep. 15, 2021. doi: [10.1002/9781119636113.ch17](https://doi.org/10.1002/9781119636113.ch17).
- [3] S. Kemp, "Digital 2025: Global Overview Report," Feb. 2025. [Online]. Available: <https://datareportal.com/reports/digital-2025-global-overview-report>
- [4] "Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation)." [Online]. Available: <https://eur-lex.europa.eu/eli/reg/2016/679/oj/eng>
- [5] "Directive (EU) 2022/2555 of the European Parliament and of the Council of 14 December 2022 on measures for a high common level of cybersecurity across the Union, amending Regulation (EU) No 910/2014 and Directive (EU) 2018/1972, and repealing Directive (EU) 2016/1148 (NIS 2 Directive)." [Online]. Available: <https://eur-lex.europa.eu/eli/dir/2022/2555/oj/eng>
- [6] "Regulation (EU) No 910/2014 of the European Parliament and of the Council of 23 July 2014 on electronic identification and trust services for electronic transactions in the internal market and repealing Directive 1999/93/EC." [Online]. Available: <https://eur-lex.europa.eu/eli/reg/2014/910/oj/eng>
- [7] "Regulation (EU) 2024/1183 of the European Parliament and of the Council of 11 April 2024 amending Regulation (EU) No 910/2014 as regards establishing the European Digital Identity Framework." [Online]. Available: <https://eur-lex.europa.eu/eli/reg/2024/1183/oj/eng>
- [8] B. M. Leiner et al., "A brief history of the internet," *ACM SIGCOMM Computer Communication Review*, vol. 39, no. 5, pp. 22–31, Oct. 2009, doi: [10.1145/1629607.1629613](https://doi.org/10.1145/1629607.1629613).
- [9] Internet Society, "A policy framework for an open and trusted Internet." [Online]. Available: <https://www.internetsociety.org/resources/doc/2016/policy-framework-for-an-open-and-trusted-internet/>
- [10] Internet Society, "Understanding your Online Identity: An Overview of Identity." [Online]. Available: <https://www.internetsociety.org/resources/doc/2011/understanding-online-identity-overview-identity/>

- [11] Eurostat, "Internet purchases by individuals (2020 onwards)." [Online]. Available: https://ec.europa.eu/eurostat/databrowser/product/page/ISOC_EC_IB20
- [12] European Union, "Telework in the EU before and after the COVID-19: where we were, where we head to." [Online]. Available: https://joint-research-centre.ec.europa.eu/document/download/1ccf7717-ab52-4215-b14a-08d74e9d44fc_en
- [13] Public Interest Registry, "Why do different DNS Abuse measurement projects result in different numbers?." [Online]. Available: <https://netbeacon.org/wp-content/uploads/2024/04/DNS-Abuse-Measurement-Challenges.pdf>
- [14] APWG, "Phishing Attack Trends Report – 4Q 2023," Feb. 2024. [Online]. Available: https://docs.apwg.org/reports/apwg_trends_report_q4_2023.pdf
- [15] Interisle Consulting Group, "Phishing Landscape 2023," Aug. 2023. [Online]. Available: <https://interisle.net/s/PhishingLandscape2023.pdf>
- [16] Interisle Consulting Group, "Phishing Landscape 2024," Jul. 2024. [Online]. Available: <https://interisle.net/s/PhishingLandscape2024.pdf>
- [17] J. Bayer *et al.*, *Study on Domain Name System (DNS) Abuse: Technical Report*. 2022. doi: [10.2759/473317](https://doi.org/10.2759/473317).
- [18] Z. M. Aljazzaf, M. Perry, and M. A. Capretz, "Online Trust: Definition and Principles," in *2010 Fifth International Multi-conference on Computing in the Global Information Technology*, Valencia, Spain: IEEE, Sep. 2010, pp. 163–168. doi: [10.1109/ICCGI.2010.17](https://doi.org/10.1109/ICCGI.2010.17).
- [19] E. E. Lastdrager, "Achieving a consensual definition of phishing based on a systematic review of the literature," *Crime Science*, vol. 3, no. 1, p. 9, Dec. 2014, doi: [10.1186/s40163-014-0009-y](https://doi.org/10.1186/s40163-014-0009-y).
- [20] G. Sonowal, *Phishing and Communication Channels: A Guide to Identifying and Mitigating Phishing Attacks*. Berkeley, CA: Apress, 2022. doi: [10.1007/978-1-4842-7744-7](https://doi.org/10.1007/978-1-4842-7744-7).
- [21] A. Dinaburg, "Bitsquatting: DNS Hijacking without exploitation," Black Hat USA 2011, Jul. 2011. [Online]. Available: https://media.blackhat.com/bh-us-11/Dinaburg/BH_US_11_Dinaburg_Bitsquatting_WP.pdf
- [22] Z. Alkhalil, C. Hewage, L. Nawaf, and I. Khan, "Phishing Attacks: A Recent Comprehensive Study and a New Anatomy," *Frontiers in Computer Science*, vol. 3, p. 563060, Mar. 2021, doi: [10.3389/fcomp.2021.563060](https://doi.org/10.3389/fcomp.2021.563060).
- [23] R. Zieni, L. Massari, and M. C. Calzarossa, "Phishing or Not Phishing? A Survey on the Detection of Phishing Websites," *IEEE Access*, vol. 11, pp. 18499–18519, 2023, doi: [10.1109/ACCESS.2023.3247135](https://doi.org/10.1109/ACCESS.2023.3247135).

- [24] L. Page, S. Brin, R. Motwani, and T. Winograd, "The PageRank Citation Ranking: Bringing Order to the Web.," Nov. 1999. [Online]. Available: <http://ilpubs.stanford.edu:8090/422/>
- [25] Y. Zhang, J. I. Hong, and L. F. Cranor, "Cantina: a content-based approach to detecting phishing web sites," in *Proceedings of the 16th international conference on World Wide Web*, Banff Alberta Canada: ACM, May 2007, pp. 639–648. doi: [10.1145/1242572.1242659](https://doi.org/10.1145/1242572.1242659).
- [26] S. Afroz and R. Greenstadt, "PhishZoo: Detecting Phishing Websites by Looking at Them," in *2011 IEEE Fifth International Conference on Semantic Computing*, Palo Alto, CA, USA: IEEE, Sep. 2011, pp. 368–375. doi: [10.1109/ICSC.2011.52](https://doi.org/10.1109/ICSC.2011.52).
- [27] A. Y. Fu, L. Wenying, and X. Deng, "Detecting Phishing Web Pages with Visual Similarity Assessment Based on Earth Mover's Distance (EMD)," *IEEE Transactions on Dependable and Secure Computing*, vol. 3, no. 4, pp. 301–311, Oct. 2006, doi: [10.1109/TDSC.2006.50](https://doi.org/10.1109/TDSC.2006.50).
- [28] J. Ma, L. K. Saul, S. Savage, and G. M. Voelker, "Beyond blacklists: learning to detect malicious web sites from suspicious URLs," in *Proceedings of the 15th ACM SIGKDD international conference on Knowledge discovery and data mining*, Paris France: ACM, Jun. 2009, pp. 1245–1254. doi: [10.1145/1557019.1557153](https://doi.org/10.1145/1557019.1557153).
- [29] S. Marchal, J. Francois, R. State, and T. Engel, "PhishStorm: Detecting Phishing With Streaming Analytics," *IEEE Transactions on Network and Service Management*, vol. 11, no. 4, pp. 458–471, Dec. 2014, doi: [10.1109/TNSM.2014.2377295](https://doi.org/10.1109/TNSM.2014.2377295).
- [30] G. Xiang, J. Hong, C. P. Rose, and L. Cranor, "CANTINA+: A Feature-Rich Machine Learning Framework for Detecting Phishing Web Sites," *ACM Transactions on Information and System Security*, vol. 14, no. 2, pp. 1–28, Sep. 2011, doi: [10.1145/2019599.2019606](https://doi.org/10.1145/2019599.2019606).
- [31] Y. Pan and X. Ding, "Anomaly Based Web Phishing Page Detection," in *2006 22nd Annual Computer Security Applications Conference (ACSAC'06)*, Miami Beach, FL: IEEE, Dec. 2006, pp. 381–392. doi: [10.1109/ACSAC.2006.13](https://doi.org/10.1109/ACSAC.2006.13).
- [32] I. Corona *et al.*, "DeltaPhish: Detecting Phishing Webpages in Compromised Websites." [Online]. Available: <http://arxiv.org/abs/1707.00317>
- [33] A. K. Jain and B. B. Gupta, "Towards detection of phishing websites on client-side using machine learning based approach," *Telecommunication Systems*, vol. 68, no. 4, pp. 687–700, Aug. 2018, doi: [10.1007/s11235-017-0414-0](https://doi.org/10.1007/s11235-017-0414-0).
- [34] A. Niakanlahiji, B.-T. Chu, and E. Al-Shaer, "PhishMon: A Machine Learning Framework for Detecting Phishing Webpages," in *2018 IEEE International Conference on Intelligence and Security Informatics (ISI)*, Miami, FL: IEEE, Nov. 2018, pp. 220–225. doi: [10.1109/ISI.2018.8587410](https://doi.org/10.1109/ISI.2018.8587410).

- [35] K. L. Chiew, C. L. Tan, K. Wong, K. S. Yong, and W. K. Tjong, "A new hybrid ensemble feature selection framework for machine learning-based phishing detection system," *Information Sciences*, vol. 484, pp. 153–166, May 2019, doi: [10.1016/j.ins.2019.01.064](https://doi.org/10.1016/j.ins.2019.01.064).
- [36] Y. Li, Z. Yang, X. Chen, H. Yuan, and W. Liu, "A stacking model using URL and HTML features for phishing webpage detection," *Future Generation Computer Systems*, vol. 94, pp. 27–39, May 2019, doi: [10.1016/j.future.2018.11.004](https://doi.org/10.1016/j.future.2018.11.004).
- [37] J. Ma, L. K. Saul, S. Savage, and G. M. Voelker, "Identifying suspicious URLs: an application of large-scale online learning," in *Proceedings of the 26th Annual International Conference on Machine Learning*, Montreal Quebec Canada: ACM, Jun. 2009, pp. 681–688. doi: [10.1145/1553374.1553462](https://doi.org/10.1145/1553374.1553462).
- [38] P. Prakash, M. Kumar, R. R. Kompella, and M. Gupta, "PhishNet: Predictive Blacklisting to Detect Phishing Attacks," in *2010 Proceedings IEEE INFOCOM*, San Diego, CA, USA: IEEE, Mar. 2010, pp. 1–5. doi: [10.1109/INFOCOM.2010.5462216](https://doi.org/10.1109/INFOCOM.2010.5462216).
- [39] V. Le Pochat, T. Van Goethem, S. Tajalizadehkhoob, M. Korczynski, and W. Joosen, "Tranco: A Research-Oriented Top Sites Ranking Hardened Against Manipulation," in *Proceedings 2019 Network and Distributed System Security Symposium*, San Diego, CA: Internet Society, 2019. doi: [10.14722/ndss.2019.23386](https://doi.org/10.14722/ndss.2019.23386).
- [40] Y. Cao, W. Han, and Y. Le, "Anti-phishing based on automated individual white-list," in *Proceedings of the 4th ACM workshop on Digital identity management*, Alexandria Virginia USA: ACM, Oct. 2008, pp. 51–60. doi: [10.1145/1456424.1456434](https://doi.org/10.1145/1456424.1456434).
- [41] A. K. Jain and B. B. Gupta, "A novel approach to protect against phishing attacks at client side using auto-updated white-list," *EURASIP Journal on Information Security*, vol. 2016, no. 1, p. 9, Dec. 2016, doi: [10.1186/s13635-016-0034-3](https://doi.org/10.1186/s13635-016-0034-3).
- [42] L. Invernizzi, K. Thomas, A. Kapravelos, O. Comanescu, J.-M. Picod, and E. Bursztein, "Cloak of Visibility: Detecting When Machines Browse a Different Web," in *2016 IEEE Symposium on Security and Privacy (SP)*, San Jose, CA: IEEE, May 2016, pp. 743–758. doi: [10.1109/SP.2016.50](https://doi.org/10.1109/SP.2016.50).
- [43] L. Von Ahn, M. Blum, N. J. Hopper, and J. Langford, "CAPTCHA: Using Hard AI Problems for Security," *Advances in Cryptology – EUROCRYPT 2003*, vol. 2656. Springer Berlin Heidelberg, Berlin, Heidelberg, pp. 294–311, 2003. doi: [10.1007/3-540-39200-9_18](https://doi.org/10.1007/3-540-39200-9_18).
- [44] E. Van Der Does De Willebois, E. M. Halter, R. A. Harrison, J. W. Park, and J. Sharman, *The Puppet Masters: How the Corrupt Use Legal Structures to Hide Stolen Assets and What to Do About It*. The World Bank, 2011. doi: [10.1596/978-0-8213-8894-5](https://doi.org/10.1596/978-0-8213-8894-5).
- [45] R. Clayton and T. Mansfield, "A Study of Whois Privacy and Proxy Service Abuse," 2013. [Online]. Available: <https://www.cl.cam.ac.uk/~rnc1/whoisstudy.pdf>

- [46] ICANN, "Registrar Accreditation Agreement." [Online]. Available: <https://www.icann.org/en/system/files/files/registrar-accreditation-agreement-21jan24-en.pdf>
- [47] Burton, "First part of phishing with EV." [Online]. Available: <https://typewritten.net/writer/ev-phishing/>
- [48] I. Carrol, "Extended Validation Is Broken." [Online]. Available: <https://stripe.ian.sh/>
- [49] C. Thompson, M. Shelton, E. Stark, M. Walker, E. Schechter, and A. P. Felt, "The Web's Identity Crisis: Understanding the Effectiveness of Website Identity Indicators," in *28th USENIX Security Symposium (USENIX Security 19)*, Santa Clara, CA: USENIX Association, Aug. 2019, pp. 1715–1732. [Online]. Available: <https://www.usenix.org/conference/usenixsecurity19/presentation/thompson>
- [50] ICANN, "Temporary Specification for gTLD Registration Data." [Online]. Available: <https://www.icann.org/en/system/files/files/gtld-registration-data-temp-spec-17may18-en.pdf>
- [51] ICANN Org Policy Research and Data Services, "Differentiation between Legal and Natural Persons in Domain Name Registration Data Directory Services (RDDS)." [Online]. Available: https://icann-community.atlassian.net/wiki/download/attachments/115673168/Rec17.2_Legal-Natural_8jul20.pdf
- [52] ICANN, "ICANN Org Response to EPDP Phase 2A Team Questions regarding Legal and Natural Person Study." [Online]. Available: <https://icann-community.atlassian.net/wiki/download/attachments/115674944/ICANN%20Org%20Response%20-%20EPDP%20Phase%202A%20-%20LNP%20-%203%20March%202021.pdf>
- [53] M3AAWG and APWG, "ICANN, GDPR, and the WHOIS: A Users Survey - Three Years Later," Jun. 2021. [Online]. Available: https://www.m3aawg.org/sites/default/files/m3aawg_apwg_whois_user_survey_report_2021.pdf
- [54] ICANN GNSO, "Final Report of the Temporary Specification for gTLD Registration Data Expedited Policy Development Process." [Online]. Available: <https://gnso.icann.org/sites/default/files/file/field-file-attach/epdp-gtld-registration-data-specs-final-20feb19-en.pdf>
- [55] ICANN GNSO, "Final Report of the Temporary Specification for gTLD Registration Data Phase 2 Expedited Policy Development Process." [Online]. Available: <https://gnso.icann.org/sites/default/files/file/field-file-attach/epdp-phase-2-temp-spec-gtld-registration-data-2-31jul20-en.pdf>
- [56] ICANN GNSO, "Final Report of the Temporary Specification for gTLD Registration Data Phase 2A Expedited Policy Development Process." [Online]. Available: <https://gnso.icann.org/sites/default/files/file/field-file-attach/epdp-phase-2a-updated-final-report-13sep21-en.pdf>

- [57] ICANN, “Registration Data Policy.” [Online]. Available: <https://www.icann.org/en/contracted-parties/consensus-policies/registration-data-policy>
- [58] ICANN, “RDRS Usage Metrics Report,” Jan. 2025. [Online]. Available: <https://www.icann.org/en/system/files/files/rdrs-usage-metrics-20jan25-en.pdf>
- [59] A. P. Felt *et al.*, “Rethinking Connection Security Indicators,” in *Symposium On Usable Privacy and Security*, 2016. [Online]. Available: <https://www.usenix.org/conference/soups2016/technical-sessions/presentation/porter-felt>
- [60] Mozilla, “European Commission’s Open Public Consultation on eIDAS.” [Online]. Available: <https://blog.mozilla.org/netpolicy/files/2020/10/2020-10-01-eIDAS-Open-Public-Consultation-EU-Commission-.pdf>
- [61] Marshall Erwin, Carl Gahnberg, Udbhav Tiwari, and Robin Wilton, “Internet Impact Brief: Mandated Browser Root Certificates in the European Union’s eIDAS Regulation on the Internet.” [Online]. Available: https://www.internetsociety.org/wp-content/uploads/2021/11/IIB_Mandated-Browser-Root-Certificates-in-the-European-Unions-eIDAS-EN.pdf
- [62] European Commission, “CEF eSignature pilot on ntQWACs,” Jul. 15, 2020. [Online]. Available: https://ec.europa.eu/futurium/sites/futurium/files/ntqwac_pilot.pdf
- [63] S. Farrell, R. Housley, and S. Turner, “An Internet Attribute Certificate Profile for Authorization.” [Online]. Available: <https://www.rfc-editor.org/info/rfc5755>
- [64] M. Daignault, M. Shepherd, S. Marche, and C. Watters, “Enabling trust online,” in *Proceedings. Third International Symposium on Electronic Commerce*, Research Triangle Park, NC, USA: IEEE Comput. Soc., 2002, pp. 3–12. doi: [10.1109/ISEC.2002.1166905](https://doi.org/10.1109/ISEC.2002.1166905).
- [65] G. A. Miller, “The magical number seven, plus or minus two: Some limits on our capacity for processing information.,” *Psychological Review*, vol. 63, no. 2, pp. 81–97, Mar. 1956, doi: [10.1037/h0043158](https://doi.org/10.1037/h0043158).
- [66] ICANN, “Base Registry Agreement.” [Online]. Available: <https://www.icann.org/en/registry-agreements/base-agreement>
- [67] A. Affinito *et al.*, “Domain Name Lifetimes: Baseline and Threats,” in *Traffic Monitoring and Analysis*, 2022. [Online]. Available: https://cseweb.ucsd.edu/~gakiwate/papers/tma22-domain_lifetime.pdf
- [68] “Code des sociétés et des associations.” [Online]. Available: https://www.ejustice.just.fgov.be/cgi_loi/article.pl?language=fr&lg_txt=f&type=&sort=&numac_search=&cn_search=2019032309&caller=SUM&&view_numac=2019032309f
- [69] “Gesetz zur Durchführung der Verordnung (EU) 2022/2065 des Europäischen Parlaments und des Rates vom 19. Oktober 2022 über einen Binnenmarkt für digitale Dienste und zur Änderung der Richtlinie 2000/31/EG sowie zur

- Durchführung der Verordnung (EU) 2019/1150 des Europäischen Parlaments und des Rates vom 20. Juni 2019 zur Förderung von Fairness und Transparenz für gewerbliche Nutzer von Online-Vermittlungsdiensten und zur Änderung weiterer Gesetze.” [Online]. Available: <https://www.recht.bund.de/eli/bund/bgbl-1/2024/149>
- [70] Norddeutscher Rundfunk, “Nackt im Netz: Millionen Nutzer ausgespäht,” Nov. 2016, [Online]. Available: <https://www.ndr.de/nachrichten/netzwelt/Nackt-im-Netz-Millionen-Nutzer-ausgespaecht,nacktimnetz100.html>
- [71] Trustpilot, “Transparency Report 2024,” 2024. [Online]. Available: <https://cdn.trustpilot.net/trustsite-consumersite/trustpilot-transparency-report-2024.pdf>
- [72] I. Kirlappos, M. A. Sasse, and N. Harvey, “Why Trust Seals Don’t Work: A Study of User Perceptions and Behavior,” *Trust and Trustworthy Computing*, vol. 7344. Springer Berlin Heidelberg, Berlin, Heidelberg, pp. 308–324, 2012. doi: [10.1007/978-3-642-30921-2_18](https://doi.org/10.1007/978-3-642-30921-2_18).
- [73] CA/Browser Forum, “Baseline Requirements for the Issuance and Management of Publicly-Trusted TLS Server Certificates.” [Online]. Available: <https://cabforum.org/working-groups/server/baseline-requirements/documents/CA-Browser-Forum-TLS-BR-2.1.2.pdf>
- [74] CA/Browser Forum, “Guidelines for the Issuance and Management of Extended Validation Certificates.” [Online]. Available: <https://cabforum.org/working-groups/server/extended-validation/documents/CA-Browser-Forum-EV-Guidelines-2.0.1.pdf>
- [75] D. Cooper, S. Santesson, S. Farrell, S. Boeyen, R. Housley, and W. Polk, “Internet X.509 Public Key Infrastructure Certificate and Certificate Revocation List (CRL) Profile.” [Online]. Available: <https://www.rfc-editor.org/info/rfc5280>
- [76] DNS Belgium, “Rapport annuel 2024,” 2024. [Online]. Available: <https://www.dnsbelgium.be/fr/rapport-annuel-2024>
- [77] Norid, “Key figures.” Accessed: Jun. 01, 2025. [Online]. Available: <https://www.norid.no/en/om-domenenavn/statistics/key-figures/>
- [78] Afnic, “Statistiques.” Accessed: Jun. 01, 2025. [Online]. Available: <https://www.afnic.fr/observatoire-ressources/statistiques/>
- [79] Business Registry Insights, “Verification of business registry data,” 2024. [Online]. Available: <https://br-insights.org/reports-dashboards/data-verification-2024/>
- [80] “Regulation (EU) 2022/2065 of the European Parliament and of the Council of 19 October 2022 on a Single Market For Digital Services and amending Directive 2000/31/EC (Digital Services Act).” [Online]. Available: <https://eur-lex.europa.eu/eli/reg/2022/2065/oj/eng>

- [81] M. Nottingham, "Well-Known Uniform Resource Identifiers (URIs)," May 2019. doi: [10.17487/RFC8615](https://doi.org/10.17487/RFC8615).
- [82] R. W. Brown, "Organization Trust Relationship Protocol," Aug. 2024. [Online]. Available: <https://datatracker.ietf.org/doc/draft-org-trust-relationship-protocol/>

Appendices

A Document statistic

A.1 Text

Chapter	Page	Word
1 Introduction	3	1242
2 Problem	6	2667
3 Literature review	24	8990
4 State of the ecosystem	16	5724
5 Requirement	6	2404
6 Proposition	25	9133
7 Evaluation	7	2840
8 Conclusion	3	1244
Total	98	34244

A.2 Reference

Chapter	Footnote	External	Internal
1 Introduction	1	6	31
2 Problem	7	5	28
3 Literature review	18	43	157
4 State of the ecosystem	16	65	77
5 Requirement	0	4	84
6 Proposition	24	25	168
7 Evaluation	0	3	163
8 Conclusion	0	0	85
Total	66	151	793